

面向云数据库高敏数据暴露路径侦测的 证据约束智能体方法研究

硕士学位论文

2026 年 7 月 13 日

目录

0.1	摘要	6
0.2	Abstract	7
1	绪论	9
1.1	研究背景与问题提出	9
1.1.1	云数据库已成为企业高敏数据的核心承载	9
1.1.2	现有安全治理工具难以进行路径级风险归因	9
1.1.3	大语言模型在安全分析中的潜力与局限	10
1.1.4	研究问题的凝练	11
1.2	国内外研究现状简述	11
1.3	研究目标与主要贡献	12
1.3.1	研究目标与研究问题	12
1.3.2	主要贡献	12
1.4	论文组织结构	13
2	相关工作	14
2.1	云数据库安全与数据安全治理	14
2.1.1	云数据库威胁模型	14
2.1.2	数据安全治理技术	15
2.1.3	云原生安全架构	15
2.2	安全图谱与攻击路径分析	16
2.2.1	攻击图理论的发展	16
2.2.2	知识图谱在网络安全中的应用	16
2.2.3	Toxic Combination 与多风险组合	17
2.2.4	路径搜索算法	17
2.3	数据安全态势管理 (DSPM) 与 CNAPP	17
2.3.1	DSPM 的概念与核心能力	17
2.3.2	CNAPP 与攻击路径分析	18
2.3.3	与本文方法的差异	18
2.4	大语言模型安全智能体	19
2.4.1	LLM Agent 通用范式	19
2.4.2	LLM 在安全分析中的应用	20
2.4.3	LLM 幻觉与 Grounding	20
2.4.4	现有安全 Agent 的局限性	20
2.5	参数高效微调与偏好对齐	21
2.5.1	参数高效微调 (PEFT) 方法	21

2.5.2	偏好对齐方法	21
2.5.3	在垂直领域的应用与局限	22
2.6	本章小结与研究定位	22
2.6.1	现有工作 Gap 分析	22
2.6.2	本文研究定位	22
3	参考文献	23
4	CloudDB-PathBench 基准构建与验证	25
4.1	任务形式化定义	26
4.1.1	输入：云数据库环境快照	26
4.1.2	输出：暴露路径集合	26
4.1.3	调查案例封装	27
4.1.4	评估四维度	28
4.2	云数据库风险图建模	28
4.2.1	定义 3.1：云数据库风险图	28
4.2.2	节点类型属性 schema	29
4.2.3	边类型连接约束	29
4.2.4	定义 3.2：暴露路径	30
4.2.5	路径类型转移矩阵	30
4.3	敏感性层次聚合模型	31
4.3.1	三层聚合	31
4.3.2	高价值目标判定	32
4.3.3	单调性证明	32
4.4	数据构建管线	33
4.4.1	场景来源与攻击技术映射	33
4.4.2	真实配置种子提取	34
4.4.3	Schema 池构建	34
4.4.4	参数化合成管线	34
4.4.5	数据集规模与统计	35
4.5	标准路径标注与质量控制	36
4.5.1	Gold Path 标注方法	36
4.5.2	标注质量指标	37
4.5.3	数据一致性校验规则	37
4.6	数据切分策略	38
4.6.1	Random Split	38
4.6.2	Unseen Schema	38
4.6.3	Unseen Risk Combination	38

4.6.4	Evidence Corruption	39
4.6.5	切分汇总	39
4.7	基准质量验证实验	39
4.7.1	场景覆盖度与分布均衡性	39
4.7.2	路径多样性	40
4.7.3	标注一致性	40
4.7.4	结构合法性	40
4.7.5	难度梯度验证	40
4.8	本章小结	41
5	EIC-Agent 核心方法	42
5.1	方法总体框架	42
5.1.1	设计目标与基本假设	42
5.1.2	总体流程	42
5.1.3	系统架构	45
5.1.4	三阶段策略偏置 (DIE)	46
5.2	候选路径搜索算法	47
5.2.1	问题定义	47
5.2.2	算法 4.1: 约束路径搜索	48
5.2.3	复杂度分析	49
5.2.4	路径长度区间的合理性	50
5.2.5	定理 4.1: 搜索完备性	50
5.2.6	算法在 Agent 循环中的定位	51
5.3	证据完整性约束验证演算	51
5.3.1	证据函数族定义与性质	51
5.3.2	EIC 验证算子的形式化	54
5.3.3	路径分类的判定准则	56
5.3.4	理论性质分析	57
5.4	路径风险量化排序模型	60
5.4.1	定义 4.7 对数几率风险模型	60
5.4.2	理论动机	60
5.4.3	风险等级划分	61
5.4.4	多路径排序	61
5.4.5	参数 β_a 的学习与可解释性	62
5.5	工具化证据获取机制	62
5.5.1	工具接口规范	62
5.5.2	工具调度的先验策略 π_0 与主动偏离	63
5.5.3	工具失败的退化处理	64

5.6	证据不足判定与人工复核机制	65
5.6.1	定义 4.8 证据充分性指标	65
5.6.2	信息增益驱动的补充查询	65
5.6.3	人工复核工作流	66
5.6.4	复核优先级	66
5.7	方法验证实验	67
5.7.1	实验设置	67
5.7.2	主效果对比实验	67
5.7.3	证据约束消融实验	69
5.8	本章小结	70
6	图验证反馈对齐方法	70
6.1	图验证反馈对齐的总体思路	71
6.1.1	问题分析：为什么 RLHF 在本场景下难以落地	71
6.1.2	核心思想：以图与 EIC 算子充当自动裁判	71
6.1.3	GV-FA 方法与 RLHF 的对比	72
6.1.4	方法整体框架	72
6.2	SFT 轨迹自动构造	73
6.2.1	工具调用轨迹的形式化定义	73
6.2.2	轨迹质量自动验证规则	73
6.2.3	轨迹生成与筛选流程	75
6.2.4	训练样本表示	75
6.3	DPO 偏好对构造与错误类型设计	76
6.3.1	偏好对的形式化定义	76
6.3.2	七类错误注入策略	76
6.3.3	偏好对的统计性质	77
6.4	图验证奖励函数形式化	77
6.4.1	可分解奖励函数的定义	77
6.4.2	可分解性定理	79
6.5	训练目标与收敛性分析	79
6.5.1	SFT 阶段：行为克隆	80
6.5.2	DPO 阶段：偏好优化	80
6.5.3	与 EIC 约束的一致性	80
6.5.4	收敛性与稳定性讨论	81
6.6	模型配置与超参设置	81
6.6.1	基座模型选型	81
6.6.2	LoRA 与训练超参	81
6.6.3	硬件需求与训练时间估算	81

6.6.4	评估协议简述	82
6.7	对齐效果实验	82
6.7.1	训练方法消融实验	82
6.7.2	OOD 泛化实验	83
6.8	本章小结	84
7	CloudDB-PathDetect 原型系统设计与实现	84
7.1	系统需求分析	85
7.1.1	功能需求	85
7.1.2	非功能需求	85
7.2	系统总体架构	86
7.2.1	架构设计原则	86
7.2.2	五层分层架构	86
7.3	核心模块设计与实现	87
7.3.1	图构建模块	87
7.3.2	约束搜索模块	88
7.3.3	EIC 判定模块	88
7.3.4	LLM 调度模块	89
7.4	系统界面与交互	90
7.5	系统运行验证	90
7.5.1	案例一：公网暴露路径 (S1 → Observed Risk)	90
7.5.2	案例二：权限过宽路径 (S2 → Potential Exposure)	91
7.5.3	案例三：证据不足拒答 (S6 → Insufficient Evidence)	91
7.5.4	运行效率	92
7.6	本章小结	92
8	总结与展望	92
8.1	研究工作总结	92
8.2	研究局限性	93
8.3	未来工作展望	94

0.1 摘要

随着云数据库已成为企业承载身份、金融、医疗等高敏数据的核心载体，其面临的网络、身份、数据、行为四维耦合威胁日益严峻。传统云安全治理工具（CSPM、CIEM、DSPM 等）以单点风险扫描与列表式告警为主，难以从大量“中低危”原子风险中识别真正可被串联利用的暴露路径，亦无法为路径级判定提供审计级证据支撑。直接将大语言模型（LLM）应用于该场景虽具潜力，但面临幻觉严重、知识长尾、推理不可追溯等本质挑战。

针对上述问题，本文系统性地提出“基准—方法—系统”三位一体的解决方案。第一，构建面向 **Toxic Combination 路径可控生成与量化评估** 的云数据安全基准 **CloudDB-PathBench**：与既有网络入侵检测基准（CIC-IDS）、渗透测试基准（HackTheBox/CTF）、通用安全评测（SecBench）关注单点漏洞或攻防对抗不同，本基准聚焦权限链 $\times$ 数据流 $\times$ 敏感级三轴交叉构成的暴露路径组合爆炸问题；通过参数化生成管线显式控制路径长度、组合复杂度与混淆因子，使不同方法可在相同难度梯度下进行可复现的公平对比；以六元组环境快照 $S = (\mathcal{A}, \mathcal{N}, \mathcal{I}, \mathcal{D}, \mathcal{L}, \mathcal{C})$ 形式化任务输入，以 8 类节点、10 类边的统一风险图（CDB-RG）为骨干，配套字段—表—实例三层敏感性聚合模型、6 类实战驱动场景模板、四层数据构建管线（覆盖场景来源映射、Schema 池构建、五阶段参数化合成与确定性验证四个环节），以及 Random / Unseen Schema / Unseen Risk Combination / Evidence Corruption 四种正交切分与 21 项评测指标。第二，提出**证据完整性约束智能体方法 EIC-Agent**，其核心设计哲学是“让 LLM 从证据判定者降格为证据表达者”——现有安全 Agent 让 LLM 同时承担“收集证据”与“判定风险”两类职责，混淆了表达与推理；EIC-Agent 通过“表达—判定分离”架构，使 LLM 仅负责将路径上的观测转化为五维结构化证据表达，而风险判定交由确定性的 Gate · Score 算子 $EIC(P) = Gate(P) \cdot Score(P)$ 完成，从而使判定过程可追溯（每个 Gate 开/关均对应具体证据）、阈值可调（无需重新训练模型）、幻觉可拦截（无依据的证据声明被 Gate 直接否决）；该架构将风险判定从 LLM 黑箱中彻底剥离，判定结论可逐条回溯到确定性算子对具体证据的计算。本文进一步证明其单调性、零元素性质、假设空间收缩性与多项式可判定性，并以 7 类工具的证据获取机制与人工复核闭环构成端到端架构。第三，提出**自主证据探索与 Gate 一票否决提前终止机制**：以信念状态驱动的探索循环取代固定全量遍历的串行流水线，智能体按“代价低、最可能否决优先”的既定顺序对硬证据维度（entry $\rightarrow$ reach $\rightarrow$ perm）逐维探查，每查一维即由确定性 Gate 当场判定，一旦某硬维度不达标便立即剪枝该路径、当场判为证据不足，跳过其后续的工具调用与 LLM 归因生成，从而将“证据不足即拒答”的安全语义前移至探索过程之中。在 CloudDB-PathBench 上的实验表明：提前终止机制在不改变任何最终判定结果的前提下，显著减少了对无效路径的工具调用与 LLM 归因开销——被判为证据不足的路径可在仅计算部分硬证据维度后即被剪枝，其端到端耗时相较完整流程下降一个数量级；确定性 Gate · Score 判定

使风险结论全程不经过 LLM 黑箱，保证了判定的可追溯、可复现与抗幻觉。本工作作为云原生敏感数据安全治理由” 打分卡 + 阈值” 迈向” 证据图 + 智能体” 提供了系统化的方法论与可复现的工程范式。

关键词：云数据库安全；高敏数据暴露路径；证据完整性约束；智能体；提前终止

0.2 Abstract

Cloud databases have become the dominant carrier of highly sensitive corporate data such as identity, financial and medical records, and they face an increasingly entangled threat surface across network, identity, data and behavioural dimensions. Existing cloud security tools —CSPM, CIEM and DSPM —are dominated by atomic, list-style risk scanning and struggle to recognise truly exploitable exposure paths formed by the chained composition of medium- and low-severity findings, and cannot supply auditable, evidence-backed attribution at the path level. Applying large language models (LLMs) directly to this task is promising but suffers from hallucination, long-tail knowledge gaps and untraceable reasoning.

To address these issues, this thesis proposes a unified ”benchmark –method –system” solution. First, we construct **CloudDB-PathBench**, a cloud-data-security benchmark supporting **controllable generation and quantitative evaluation of Toxic-Combination exposure paths**. Unlike network-intrusion benchmarks (CIC-IDS), penetration-testing benchmarks (HackTheBox/CTF) or generic security evaluations (SecBench) that focus on atomic vulnerabilities or red-team adversarial play, CloudDB-PathBench targets the combinatorial-explosion problem arising from the joint product of *permission chains* $\times$ *data flows* $\times$ *sensitivity levels*. A parameterised generation pipeline gives explicit control over path length, combination complexity and obfuscation factors, enabling reproducible apples-to-apples comparison across methods at matched difficulty levels. The task is formalised by a six-tuple snapshot $S = (\mathcal{A}, \mathcal{N}, \mathcal{I}, \mathcal{D}, \mathcal{L}, \mathcal{C})$ over a unified Cloud-DB Risk Graph (CDB-RG) with 8 node types and 10 edge types, accompanied by a three-layer field –table –instance sensitivity aggregation model, six scenario templates, a four-layer data construction pipeline (covering scenario-source mapping, Schema pool construction, five-stage parameterised synthesis and deterministic verification), four orthogonal splits and 21 evaluation metrics. Second, we propose the **Evidence Integrity Constrained Agent (EIC-Agent)**, whose central design philosophy is to **demote the LLM from an *evidence judge* to an *evidence expresser***: existing security agents conflate evidence collection with risk adjudication, blurring expression and reasoning. EIC-Agent enforces an **expression –adjudication separation**, in

which the LLM only translates path observations into a structured five-dimensional evidence representation, while risk adjudication is delegated to the deterministic Gate-Score operator $\text{EIC}(P) = \text{Gate}(P) \cdot \text{Score}(P)$. This separation makes adjudication auditable (every Gate open/close maps to concrete evidence), thresholds tunable without retraining, and hallucinations interceptable (unsupported evidence claims are blocked at the Gate). By removing risk adjudication from the LLM black box entirely, every verdict can be traced back to the deterministic operator’s computation over concrete evidence. We further prove monotonicity, zero-element property, hypothesis-space contraction and polynomial decidability, and design an end-to-end architecture with seven evidence-gathering tools and a human-in-the-loop fallback. Third, we propose an **autonomous evidence-exploration loop with a hard-evidence one-veto Gate for early termination**. Instead of a fixed sequential pipeline, a belief-state-driven agent autonomously decides which evidence dimension to probe next, examining the hard-evidence dimensions (entry $\rightarrow$ reach $\rightarrow$ perm) one at a time in a cost-aware, most-likely-to-veto-first order. After each dimension is computed, the deterministic Gate adjudicates on the spot: as soon as any hard dimension falls below its threshold, the path is immediately pruned and labelled `Insufficient_Evidence`, skipping all subsequent tool calls and LLM attribution generation. This moves the “insufficient-evidence-then-abstain” safety semantics forward into the exploration process itself. Experiments on CloudDB-PathBench show that, without altering any final adjudication outcome, early termination substantially reduces the tool-call and LLM-attribution overhead spent on invalid paths —paths judged insufficient are pruned after computing only part of the hard-evidence dimensions, with end-to-end latency dropping by an order of magnitude relative to the full pipeline; because Gate $\cdot$ Score adjudication never passes through the LLM black box, the risk verdicts remain traceable, reproducible and hallucination-resistant. The work establishes a systematic methodology and reproducible engineering paradigm for moving cloud-native sensitive-data governance from scorecard-and-threshold heuristics towards evidence-graph-driven agents.

Keywords: Cloud Database Security; Sensitive Data Exposure Path; Evidence Integrity Constraint; Agent; Early Termination

1 绪论

1.1 研究背景与问题提出

1.1.1 云数据库已成为企业高敏数据的核心承载

随着数字化转型在金融、医疗、政务、电商、互联网等行业的纵深推进，企业的核心业务系统正在以前所未有的速度向云端迁移。作为业务系统持久化层的云数据库（Cloud Database）逐步取代传统的本地数据中心成为企业最重要的数据载体之一。Gartner、IDC 等机构发布的多份报告均指出，全球云数据库市场规模在过去五年保持着 20% 以上的年均复合增长率，且这一趋势仍在加速 [1][2]。云数据库提供商通过托管 RDS（Relational Database Service）、NoSQL、数据仓库（Data Warehouse）、湖仓一体（Lakehouse）等多种形态，承载着企业的客户身份信息、支付信息、医疗记录、定位轨迹、企业经营数据等大量高敏数据（Highly Sensitive Data）。

高敏数据具有“价值高、合规重、暴露代价巨大”三个显著特征。从合规角度看，《个人信息保护法》（PIPL）、《数据安全法》（DSL）、《关键信息基础设施安全保护条例》、欧盟《通用数据保护条例》（GDPR）、美国《健康保险可携性和责任法案》（HIPAA）等法律法规对个人信息、健康信息、金融信息等敏感数据的存储、传输、共享、跨境提出了严格要求 [3][4]。从经济与品牌损失角度看，IBM 发布的《2023 数据泄露成本报告》显示，全球单次数据泄露事件的平均损失已达 445 万美元，且公有云环境中的泄露成本进一步高于本地部署环境 [5]。从攻击者经济学角度看，云数据库往往集中存储成千上万用户的核心信息，单次成功入侵的“投入产出比”远高于攻击单一终端，因此天然成为攻击者的首要目标。

随着云数据库形态的日益复杂，其面临的安全威胁也呈现出多维耦合的特点。一个典型的云数据库实例不仅涉及数据库自身的引擎安全、补丁管理与权限模型，还涉及其所在的虚拟私有云（VPC）网络结构、跨账号 IAM 角色、数据访问代理服务、ETL 数据流水线、备份对象存储、监控审计系统等多个外围组件。任何一个外围组件配置不当、任何一个临时开通的开放端口、任何一段被废弃但仍存活的旧 IAM 凭证，都可能成为通向核心高敏数据的“关键一环”。

1.1.2 现有安全治理工具难以进行路径级风险归因

围绕云数据库的安全治理，业界已经形成了多类成熟工具。配置安全检查工具（如云安全态势管理 CSPM、云原生应用保护平台 CNAPP 等）主要扫描资源配置错误，例如对象存储桶公开可读、数据库公网可访问、安全组规则过宽等 [6]。身份与权限治理工具（如 IAM 分析器、CIEM）则用于识别冗余权限、跨账号信任、长期未使用的凭证等 [7]。数据安全态势管理（DSPM）工具（如 Symmetry Systems、Cyera、Securiti 等）专注于数据资产的发现、分类分级与敏感度打标 [8]。数据库

审计与 DAM 工具捕获数据库会话与 SQL 行为，识别异常访问模式 [9]。漏洞扫描与补丁管理工具则识别数据库自身、宿主操作系统与容器镜像中的已知漏洞 [10]。

上述工具在各自的视角下均能输出大量”单点风险（Atomic Risk）”。然而，单点风险与真正可被利用的”暴露路径（Exposure Path）”之间存在巨大鸿沟。攻击者从外部入口出发，往往需要串联多个看似独立的弱点：例如先通过一个公网可达的应用利用其 SQL 注入漏洞获得数据库的低权限账号，再通过该账号查询的元数据获取另一台跳板机的 SSH 私钥，最后利用该跳板机所在的 IAM 角色具备的 `rds:DescribeDBInstance` 与 `secretsmanager:GetSecretValue` 权限，跨账号访问位于另一个 VPC 中的 RDS 实例并导出包含身份证号的高敏字段。这条链路上的每一个节点单看都”风险等级中等”甚至”低危”，但组合在一起就构成了一条通向核心数据的高危路径，即所谓的 Toxic Combination [11]。

现有工具的根本局限在于其单点视角与列表式输出。它们倾向于将安全风险呈现为一个庞大的告警列表，并按”高危/中危/低危”进行排序。这种范式存在几个突出问题。其一，告警疲劳（Alert Fatigue）现象严重——大型云环境每日可产生数千条单点告警，安全运营人员难以从中识别真正”接通到敏感数据”的链路。其二，缺乏归因证据——即便人工通过经验判断出一条路径，工具本身并不输出该路径所依赖的事实证据（如哪些 IAM 策略、哪些网络规则、哪些字段标签），导致路径无法被复核与追责。其三，视角偏于静态——大量工具仅在配置层面进行匹配，难以将运行时的访问行为、临时凭证、跨账号假扮（AssumeRole）等动态因素纳入分析。其四，跨域语义割裂——网络层、身份层、数据层、行为层往往由不同工具分管，数据语义不互通，难以联合推理。

由此引出本文关注的核心问题：如何从大量单点风险中识别并解释通向云数据库高敏数据的可利用暴露路径，并保证识别结果具有可被审计的证据支撑？

1.1.3 大语言模型在安全分析中的潜力与局限

近两年，大语言模型（Large Language Model, LLM）在代码理解、日志解读、漏洞研判、SOAR（Security Orchestration, Automation and Response）剧本生成等安全场景展现出令人瞩目的能力 [12][13]。一方面，LLM 在自然语言推理、跨域知识融合、多步规划与工具调用方面表现出超越传统规则引擎的灵活性；另一方面，基于 ReAct [14]、Plan-and-Execute、Toolformer [15] 等范式构建的智能体（Agent）使 LLM 具备了访问外部 API、执行查询、调用安全工具的能力，从而初步具备了端到端处置安全事件的潜力。

然而将 LLM 应用于云数据库暴露路径分析这一高严肃性场景，仍面临三个本质性挑战。其一为幻觉（Hallucination）与不可证伪输出——LLM 在缺乏事实约束时会生成貌似合理但与实际环境不符的”暴露路径”，例如虚构一个并不存在的 IAM 策略或一段并不通畅的网络通路。在安全运营场景下，幻觉会直接误导处置决策，造成”假阳”或更严重的”假阴”。其二为长尾环境与多源异构知识——云数

数据库的暴露路径分析需要同时理解 IAM JSON 策略、安全组规则、VPC 路由表、数据库 GRANT 语句、字段级标签、API 调用日志等异构数据，这些知识在通用 LLM 的预训练语料中分布稀疏且时效性差。其三为推理可追溯性与合规要求——安全分析结论需具备审计级可追溯性，而“模型自由生成的路径”难以满足等级保护、ISO 27001、SOC 2 等合规要求中“风险评估应具有可复核证据”的条款 [4]。

换言之，要让 LLM 在这一场景中可用，关键在于“让模型说得更多”，而在于“让模型只说有证据支撑的话”。这构成了本文研究的另一条主线：证据约束（Evidence-constrained）的智能体方法。

1.1.4 研究问题的凝练

综合上述背景，本文将研究问题凝练为三个相互关联的子问题。在建模层面，如何将云数据库环境下网络、身份、数据、行为四个维度的多源异构风险统一建模为可搜索、可验证的风险图（Risk Graph），从而支撑路径级的暴露分析？在推理层面，如何构建一种证据约束的智能体方法，使其在调用工具检索证据的同时，对每一步推断、每一条候选路径强制要求事实绑定（Evidence Binding），从而抑制幻觉并保证输出的可靠性？在学习层面，在专业人工标注极度稀缺的情况下，如何利用图本身可机器验证的特性构造自动反馈信号，实现对小参数量模型的偏好对齐，使其在路径侦测任务上达到接近大模型的能力？

围绕上述三个问题，本文展开系统性的研究。

1.2 国内外研究现状简述

针对云数据库高敏数据暴露路径侦测，与本文最为相关的研究脉络可概括为四条主线，本节先做概要梳理，第二章将对每条主线进行详细的展开与述评。

在安全图与攻击路径分析方向，攻击图（Attack Graph）的研究可以追溯到 Sheyner 等学者在 2002 年提出的基于模型检测的攻击图自动生成方法 [16]，随后 Ou 等研究者提出了 MulVAL 系统，将攻击图建模为一阶逻辑推理问题 [17]。近年来，工业界以 Wiz Security Graph、Orca Cloud Risk Graph、Palo Alto Prisma Cloud 为代表，将图建模引入云原生安全态势管理，强调多风险组合产生的“毒性组合（Toxic Combination）”概念 [11][18]。然而这些产品多以闭源形态存在，缺乏公开的、面向“云数据库高敏数据”这一具体落点的基准与方法论。

在数据安全态势管理方向，Gartner 于 2022 年提出 DSPM 概念 [8]，强调以数据为中心的发现、分类与态势刻画。围绕 DSPM，业界已经出现 Cyera、Symmetry Systems、Securiti 等代表性产品 [19]。但 DSPM 的当前重点仍在“数据资产清点”与“风险面识别”，对“通向具体高敏字段的可利用路径”的端到端分析尚未形成统一方法论。

在 LLM Agent 的安全应用方向，SecureBERT [20]、Lily [13]、SecGPT [21] 等

领域模型与 SOAR 智能体相继出现，并在告警研判、事件响应、漏洞分析等任务上展示能力。但研究普遍未对 LLM 输出施加严格的事实约束，难以满足“证据可追溯”的合规要求。

在参数高效微调与偏好对齐方向，LoRA [22]、QLoRA [23]、Adapter [24] 等参数高效微调（PEFT）方法显著降低了垂直领域微调的成本；RLHF [25]、DPO [26]、KTO [27] 等偏好对齐方法成为对齐模型偏好的主流路线。但这些方法普遍依赖大规模人类标注，在云安全这类专业领域成本极高，且与“图可验证性”这一独有特征结合的研究尚不充分。

总体上，“以图为骨架的路径建模、以表达—判定分离保证判定可审计的智能体推理、以确定性 Gate 一票否决驱动的自主证据探索与提前终止”这一三位一体的研究路线，在已有工作中尚未被系统性提出与验证。本文正是围绕这一空白展开的。

1.3 研究目标与主要贡献

1.3.1 研究目标与研究问题

本文以“面向云数据库高敏数据的暴露路径侦测”为目标场景，期望在以下三个方面取得进展。在可搜索的统一图建模方面（RQ1），本文旨在构建一种能够覆盖网络、身份、数据、行为四个维度的统一风险图模型，并在该模型上提供可机器验证的路径定义与判定准则，支撑后续的可解释路径搜索。在证据约束的智能体推理方面（RQ2），本文旨在设计一种证据约束的 LLM 智能体方法（Evidence-constrained Agent），在工具调用、路径假设、风险归因等关键步骤上强制证据绑定与一致性校验，从而显著降低幻觉、提升结论可靠性与可审计性。在图验证反馈驱动的偏好对齐方面（RQ3），本文旨在利用风险图本身可机器验证的特性，在缺乏大规模人类偏好标注的前提下，自动构造偏好对（Preference Pair），驱动小参数量模型在路径侦测任务上对齐高质量行为，逼近甚至局部超越通用大模型的效果。

1.3.2 主要贡献

针对上述研究问题，本文提出三项主要贡献。

（贡献一）CloudDB-PathBench 基准数据集与评测协议。本文构建了面向云数据库高敏数据暴露路径侦测的开源基准数据集 CloudDB-PathBench。该数据集包含若干个具有代表性的云原生场景模板（多账号 RDS、跨 VPC NoSQL、湖仓一体数据流水线等），覆盖网络、身份、数据、行为四类风险因子，并在场景上构造若干条“参考暴露路径”。配套提出路径召回率（Path Recall）、证据精确率（Evidence Precision）、毒性组合发现率（Toxic-Combination Coverage）、幻觉率（Hallucination Rate）等评测指标，以及一套面向 Agent 输出格式的标准化评测协议，缓解该方向长期缺乏公开评测基准的现状。

(贡献二) EIC-Agent 证据完整性约束智能体方法（表达—判定分离架构）。本文提出 EIC-Agent (Evidence Integrity Constrained Agent)，其核心设计哲学是“让 LLM 从证据判定者降格为证据表达者”。与现有安全 Agent 让 LLM 同时承担“收集证据”与“判定风险”两类职责不同，EIC-Agent 通过“表达—判定分离”的 neuro-symbolic 架构，使 LLM 仅负责将路径上的观测翻译为五维结构化证据表达 (entry/reach/perm/target/sense) 与自然语言归因解释，而风险判定完全交由确定性的 $\text{Gate} \cdot \text{Score}$ 算子 $\text{EIC}(P) = \text{Gate}(P) \cdot \text{Score}(P)$ 完成——LLM 不参与任何风险判定。该分离使判定过程可追溯（每个 Gate 开/关均对应具体证据）、阈值可调（无需重新训练模型）、幻觉可拦截（无事实支撑的证据声明被 Gate 直接否决）。本文进一步证明 $\text{Gate} \cdot \text{Score}$ 算子的单调性、零元素性质、假设空间收缩性与多项式可判定性，为“判定不经过 LLM 黑箱”提供了理论保证。

(贡献三) 自主证据探索与 Gate 一票否决提前终止机制。本文提出一种由信念状态驱动的证据探索循环，取代固定全量遍历的串行流水线：智能体按“代价低、最可能否决优先”的既定顺序对硬证据维度 (entry $\rightarrow$ reach $\rightarrow$ perm) 逐维探查；每查完一维即由确定性 Gate 当场判定，一旦某硬维度不达标便立即将该路径剪枝、当场判为证据不足，跳过其后续的工具调用与 LLM 归因生成。该机制在不改变任何最终判定结果的前提下，显著减少了对无效路径的工具调用与 LLM 调用开销，并将“证据不足即拒答”的安全语义前移至探索过程之中，使昂贵的语言模型资源只投入到确有分析价值的路径上。

上述三项贡献环环相扣：贡献一“定义”问题与评测”，贡献二回答“如何让路径判定可审计、抗幻觉”（将判定外部化于确定性算子），贡献三回答“如何让证据探索自主而高效”（以 Gate 信号驱动提前终止与剪枝）。

1.4 论文组织结构

本文共分为七章，组织结构如下：

第一章绪论：阐述研究背景、问题动机、研究目标与主要贡献，并给出全文组织。

第二章相关工作：从云数据库安全与数据安全治理、安全图谱与攻击路径分析、数据安全态势管理、大语言模型安全智能体、参数高效微调与偏好对齐五个方向系统综述相关研究，并给出本文的研究定位。

第三章 CloudDB-PathBench 基准构建与验证：将云数据库高敏数据暴露路径侦测形式化为输入—输出问题，提出统一风险图 (CDB-RG) 模型与字段—表—实例三层敏感性聚合模型；采用“真实配置种子驱动的参数化合成”四层数据构建管线，覆盖场景来源映射、Schema 池构建、五阶段参数化合成与确定性验证四个环节；配套 4 种正交切分策略与 21 项评测指标；最后通过基准质量验证实验评估场景覆盖度、路径多样性、标注一致性与难度梯度。

第四章 EIC-Agent 核心方法与实验验证：在 CDB-RG 之上提出基于 Gate—

Score 双层算子的证据完整性约束验证演算，证明其单调性、零元素性质、假设空间收缩性与多项式可判定性；给出基于类型转移矩阵剪枝的约束 DFS 路径搜索算法、基于对数几率变换的可学习风险量化排序模型、7 类工具的最优调度顺序，以及证据不足判定与人工复核闭环；通过主效果对比实验与证据约束消融实验验证方法有效性。

第五章图验证反馈对齐方法与实验验证：以风险图与 EIC 算子充当自动裁判，给出 SFT 轨迹的 5 条图验证规则与 DPO 偏好对的 7 类错误注入策略（VANS），定义可分解的图验证奖励并证明其局部性与 EIC 一致性；给出 SFT+DPO 两阶段训练方案；通过训练方法消融实验与 OOD 泛化实验验证对齐效果。

第六章 CloudDB-PathDetect 原型系统设计与实现：将第三至五章的方法集成为端到端可运行的原型系统 CloudDB-PathDetect，给出五层系统架构、核心模块设计与实现、系统界面交互，并通过 3 个端到端案例演示验证系统工程可行性。

第七章总结与展望：总结本文工作与贡献，讨论方法的局限性，并展望未来在大规模真实云环境部署、多云迁移、在线反馈学习、自动处置闭环、多 Agent 协作与现有安全运营平台集成等方向上的研究空间。

2 相关工作

本章面向“云数据库高敏数据暴露路径侦测”这一研究目标，系统梳理与本文方法直接相关的五个研究方向，并在每节末给出对本文方法的启示。最后在 2.6 节通过 Gap 分析定位本文工作的独特性。

2.1 云数据库安全与数据安全治理

2.1.1 云数据库威胁模型

云数据库的安全威胁可以从被攻击表面（Attack Surface）的层次切入，划分为四个相互交织的维度。在网络层，云数据库通常部署于 VPC 内，但出于跨账号、跨服务、运维便利等目的，常存在公网入口、跨 VPC 对等连接（VPC Peering）、跳板机、数据库代理等多类网络通路。Skyhigh、Tenable 等厂商公开报告指出，公网可达的数据库实例占整体云数据库的比例多年保持在 5%~10% [28]，构成最直接的入口风险。除此之外，错误配置的安全组（Security Group）、过宽的网络 ACL、未启用的 TLS 通信、数据库代理的中间人风险等都属于网络层威胁。在身份层，云数据库的访问控制由两套权限体系叠加：云平台层面的 IAM（Identity and Access Management）以及数据库自身的账号/角色/GRANT 体系。两者语义不一致、配置由不同团队维护，是错配的高发区。常见的身份层威胁包括长期凭证泄漏、跨账号假扮（AssumeRole）链路被滥用、*:* 等通配权限、未轮转的服务账号、临时 Token 范围过宽等 [29]。Sotnikov 等的研究指出，IAM 误配置已经成为云环境

中数据泄漏的首要原因 [30]。在数据层，数据库内部的高敏字段（如身份证号、手机号、银行卡号、健康记录）在缺乏分类分级、未脱敏、未加密、未启用列级访问控制时，会显著放大泄漏后果。此外，备份、快照、归档等冗余数据载体常常逃离 DSPM 工具的视野，构成“影子敏感数据”。在行为层，威胁则包括异常 SQL 行为（批量导出、跨表关联、在非工作时间执行 SELECT *）、异常会话来源（来自陌生 IP、来自未授权地理区域）、慢查询掩护下的数据外泄等。行为层威胁需要由数据库审计（DAM）、用户实体行为分析（UEBA）等工具支撑识别 [9]。

上述四个维度并非彼此独立，真正高危的暴露事件往往是它们的“组合”。这一观察构成了本文将路径分析作为核心范式的根本动因。

2.1.2 数据安全治理技术

数据安全治理（Data Security Governance）作为安全治理的一个分支，其经典框架由 ISO/IEC 27701、NIST Privacy Framework 等标准给出 [31][32]。在工程层面，主流技术沿四个方向发展。在数据分类分级方面，通过模式匹配、机器学习、上下文特征等手段识别敏感字段并打标，代表性研究有 Microsoft Presidio [33]、Google Cloud DLP API [34] 等。在访问控制与最小权限方面，通过 RBAC、ABAC、零信任架构（Zero Trust Architecture）实现以“必要且充分”为原则的访问控制 [35]，NIST SP 800-207 给出了零信任的标准化定义 [36]。在加密与脱敏方面，技术覆盖静态加密（Encryption at Rest）、传输加密（Encryption in Transit）、字段级加密（Field-level Encryption）、确定性脱敏与差分隐私脱敏等多种形态。在审计与可观测性方面，以数据库审计（DAM）、变更审计、统一日志（如 AWS CloudTrail、阿里云 ActionTrail）支持事后追溯。

然而，上述技术通常在工具层面相互独立部署，输出格式不统一，难以进行跨域联合推理。本文在第三章构建统一风险图时，将显式地把上述四类信号收编为同构的图元素，实现跨域语义对齐。

2.1.3 云原生安全架构

随着 Kubernetes、Service Mesh、Serverless 等云原生技术的普及，安全架构也逐步向“以身份为中心、以工作负载为单元、动态最小权限”的方向演进。CNCF 安全工作组发布的《Cloud Native Security Whitepaper》明确将云原生安全分为开发、分发、部署、运行四个阶段 [37]。在数据库场景下，云原生安全的若干典型实践包括基于 Pod Identity 的数据库连接、利用 Service Mesh 进行 mTLS、利用 OPA（Open Policy Agent）实施策略即代码 [38]。

综合 2.1 节的讨论，可以得出对本文的三点启示：其一，云数据库威胁的“多维耦合”特性决定了必须建立跨域的统一图模型，而非在单一维度上做安全检查；其二，已有治理技术输出的零散信号——网络规则、IAM 策略、数据标签、行为日志——正是构建统一风险图的基础原料；其三，零信任与最小权限思想的本质

是对”可达性”的精细化控制，与本文路径侦测在哲学上一致。值得注意的是，尽管云原生安全架构提供了丰富的安全原语，但如何将这些原语统一纳入一个可搜索、可验证的图结构以支撑路径级分析，仍是一个尚未被充分解决的问题。这一不足为本文的图建模工作提供了直接的切入点。

2.2 安全图谱与攻击路径分析

2.2.1 攻击图理论的发展

攻击图研究发端于 2002 年 Sheyner 等提出的基于模型检测的攻击图自动生成方法 [16]。该方法将网络配置与漏洞信息编码为模型检测的输入，自动枚举从攻击者初始状态到目标状态的所有可行路径，开创了以图结构刻画攻击路径的先河。然而早期的攻击图生成面临状态爆炸问题，为此 Ammann 等提出了基于”单调性假设”的可扩展攻击图算法，将搜索复杂度从指数级降至多项式级 [39]。这一理论突破使得攻击图在中大规模网络上的应用成为可能。随后，Ou 等于 2005 年提出的 MulVAL 系统进一步将攻击图建模为 Datalog 推理问题，能够将主机漏洞、网络配置、信任关系等异构输入综合为完整的攻击图 [17]，其逻辑推理范式对后续工作影响深远。

近年来，攻击图的研究开始向概率化与动态化方向拓展。Poolsappasit 等提出贝叶斯攻击图（BAG），通过在图节点上引入条件概率分布，实现了对攻击路径风险等级的量化评估 [40]。Hu 等则利用强化学习自动发现攻击图中的最优攻击策略，展现了数据驱动方法在该领域的潜力 [41]。尽管这些研究在传统主机—漏洞—网络模型上取得了显著进展，但对云原生环境中的 IAM 策略、数据资产标签、跨账号链路等关键要素的建模仍然不足，难以直接应用于云数据库场景。

2.2.2 知识图谱在网络安全中的应用

知识图谱（Knowledge Graph）以”实体—关系—实体”三元组为基本单位，为网络安全领域提供了一种结构化表示与推理的统一框架。在威胁情报融合方面，STIX/TAXII 标准的图化建模使多源情报的关联分析成为可能 [42]；在漏洞—资产关联方面，CVE 与 CPE 的图查询支持了从漏洞到受影响资产的快速定位；在攻击者画像方面，知识图谱支撑了威胁行为体（Threat Actor）的关系推理与归因分析。值得注意的是，MITRE ATT&CK 框架本身可以被理解为一张”战术—技术—子技术”的层级图谱，其 Cloud Matrix 子集尤其面向云环境威胁 [43][44]，为云安全领域的知识图谱构建提供了重要的语义基础。

针对云原生场景，相关研究开始尝试将云资产（账号、角色、实例、桶、密钥）等建模为图节点，将”可访问”、”可承担角色”、”可解密”等关系建模为有向边，并支持基于 Cypher 的声明式查询。Wiz、Orca、Lacework 等商业产品均采用此类思想 [11][18]。然而，这些工作主要聚焦于资产可达性的刻画，对数据资产内部的

字段级敏感性、访问路径的证据可验证性等关键问题关注不足。

2.2.3 Toxic Combination 与多风险组合

Toxic Combination 概念最早由 Wiz 等厂商在工程实践中提出，用以描述“多个单点风险按特定顺序组合后形成的高危链路” [11]。该概念的重要性体现在：当单点风险按“高危/中危/低危”独立打分时，许多关键链路上的节点都被判定为中低危；然而当它们顺序连接形成可达路径后，整体风险等级显著提升；这种“组合放大”效应难以由列表式工具察觉，正是传统安全运营工具“见树不见林”的症结所在。

学术界对 Toxic Combination 的形式化建模仍处于早期阶段。Microsoft 等在其报告中提出“Cloud Attack Path Analysis”概念 [45]，强调路径的可达性与影响面叠加。然而，现有工作主要停留在“路径可达性”的判定层面，对路径上每一步的证据支撑缺乏形式化要求。本文在此基础上进一步要求“路径的每一段必须有原子证据支撑”，并将其形式化为图上的不变量与可达性双约束，从而将 Toxic Combination 从工程直觉提升为可验证的形式化判定。

2.2.4 路径搜索算法

在统一风险图上做路径搜索，既可以采用经典图算法（BFS、Dijkstra、A*、k-shortest-path 等），也可以引入领域启发式（如以“敏感度递增方向”作为剪枝准则）。Bron-Kerbosch、PageRank、Personalized PageRank 等算法已被用于子图重要性度量 [46]。然而单纯依赖图算法存在两方面不足：一方面，大规模云环境的图节点规模可达 $10^5 \sim 10^7$ ，纯算法搜索的时空代价高昂；另一方面，路径的“可解释性”难以通过纯算法体现——算法可以输出一条最短路径，但无法用自然语言解释该路径的成因、关键环节与风险聚焦点。

综合 2.2 节的讨论可以看出，攻击图理论提供了路径建模的形式化基础，知识图谱赋予了跨域关联的能力，Toxic Combination 概念揭示了组合风险的放大效应，而路径搜索算法提供了图上遍历的计算工具。然而，这些工作各自为战，缺乏面向“云数据库高敏字段”的统一整合。本文在第三章将攻击图、知识图谱、ATT&CK Cloud Matrix 三者的优势融入统一风险图（CDB-RG）；在第四章则用 LLM Agent 取代或辅助纯图搜索，借助语言模型的语义抽象能力提升探索效率与解释性，同时让图算法负责严格性验证，实现“智能体探索 + 图算法验证”的协同范式。

2.3 数据安全态势管理（DSPM）与 CNAPP

2.3.1 DSPM 的概念与核心能力

Gartner 于 2022 年正式提出 DSPM（Data Security Posture Management）概念，将其定义为“提供以数据为中心的可见性、风险与合规态势刻画的一类工具”

[8]。DSPM 的核心能力沿数据生命周期展开：在数据发现 (Discovery) 阶段，其在云存储、数据库、湖仓、SaaS 系统中自动发现结构化与非结构化数据；在分类分级 (Classification) 阶段，识别敏感字段并按合规要求打标 (PII、PCI、PHI 等)；在风险态势 (Posture) 阶段，识别敏感数据周边的暴露面、过度授权、未加密、不当共享等风险；在合规映射 (Compliance Mapping) 阶段，将数据风险与合规条款 (如 GDPR Art.32、HIPAA Security Rule) 进行对齐。代表性产品包括 Cyera、Symmetry Systems、Securiti、Laminar、BigID 等 [19]，其设计哲学可概括为“以数据为根，由内向外推风险”。

2.3.2 CNAPP 与攻击路径分析

CNAPP (Cloud-Native Application Protection Platform) 由 Gartner 于 2021 年提出，是 CSPM、CWPP、CIEM、KSPM 的整合 [6]。CNAPP 的攻击路径分析 (Attack Path Analysis, APA) 模块通常以图谱视角呈现“从公网入口到关键资产”的可达路径，代表产品包括 Wiz、Orca、Prisma Cloud、Microsoft Defender for Cloud 等 [18][45]。相较于 DSPM 以数据为起点的“由内向外”视角，CNAPP 的 APA 模块更多采用以攻击面为起点的“由外向内”视角，两者在工程意义上均触及了“路径”概念。

2.3.3 与本文方法的差异

尽管 DSPM 与 CNAPP 在工程意义上已经触及“路径”概念，但与本文方法相比仍存在三点显著差异。在关注点上，DSPM 主要回答“哪些敏感数据存在风险”，CNAPP 主要回答“哪些资产可达”，而本文聚焦“通向云数据库中具体高敏字段的可利用路径如何形成”，将数据视角与资产视角合一，并把“高敏字段”作为搜索目标节点。在证据要求上，现有产品多以“高/中/低”风险卡片呈现路径，缺乏对路径每一段的形式化证据绑定，而本文方法对每一条路径要求“边集 + 不变量 + 数据源”三件套证据。在智能化程度上，现有方法以规则与图算法为主，少数引入机器学习用于打分，而本文方法显式引入 LLM Agent 进行语义级别的路径推断与归因，并通过证据约束抑制 LLM 的不可靠输出。

综上，DSPM/CNAPP 是工业界对路径问题最近邻的探索，可作为本文方法的工程参照。然而，其“由内向外”或“由外向内”的单向视角均不足以覆盖暴露路径的全貌，其风险卡片式的输出也远未达到证据级可审计的要求。这些不足正是本文方法的切入空间，也为从“安全图谱”向“智能体推理”的过渡提供了自然的衔接——仅靠图建模与图算法难以弥合上述鸿沟，需要引入具备语义理解与工具调用能力的智能体方法。

2.4 大语言模型安全智能体

2.4.1 LLM Agent 通用范式

围绕大语言模型构建智能体的研究在近三年经历了从单步推理到多步协同的快速演进。早期研究主要聚焦于激发模型的内在推理能力，其中 Yao 等人提出的 ReAct 范式具有里程碑意义，该范式通过将自然语言推理 (Reasoning) 与外部工具调用 (Acting) 交替执行，有效缓解了模型在复杂任务中的幻觉问题 [14]。与 ReAct 几乎同期，Schick 等人提出的 Toolformer [15] 以及 OpenAI 的 Function Calling 机制形成了基础的工具调用能力，使 LLM 能够自主决定何时调用外部 API 以获取事实信息。然而，ReAct 范式在面对长程任务时容易陷入局部最优，为此后续研究逐渐向任务分解与多智能体协作方向拓展。Plan-and-Execute 范式 [47] 将任务分解为计划与执行两个阶段，先由规划器生成全局方案，再由执行器逐步落实；AutoGen [48]、MetaGPT [49] 等多智能体框架则将多个角色化 Agent 协同处理复杂任务，通过角色分工与消息传递提升系统整体能力。与此同时，检索增强生成 (RAG) 作为一种事实约束手段受到广泛关注 [50]，其通过外部检索为 LLM 提供事实支撑，被认为是控制幻觉的有效手段。

近两年 (2024—2025)，Agent 研究在“过程控制、终止时机与调用代价”三个维度上进一步细化，与本文方法密切相关。其一，结构化/状态驱动的 Agent 逐渐取代自由形式的 ReAct 循环：StateFlow [66] 将复杂任务求解显式建模为有限状态机，把“过程控制”（确定性的状态与转移）与“子任务求解”（LLM 动作与工具调用）分离，在 SQL 等任务上以更低成本取得更高成功率，为“确定性骨架 + LLM 执行”的分工提供了范式支撑。其二，自适应终止与“知道何时停止”成为独立议题：一类工作训练或引导模型判断“证据是否已经足够”从而适时停止推理与取证 [67]，另一类则基于中间答案置信度实现免训练的动态早停，避免过度推理。其三，预算/代价感知的工具调用受到关注：相关研究发现，单纯增大工具调用预算并不能提升性能，Agent 因缺乏“预算意识”而迅速触及性能天花板，需显式引入成本度量并以成本—性能 Pareto 前沿进行评估 [68]。值得注意的是，上述终止与剪枝机制大多依赖 LLM 内部的软信号（置信度、学习式策略）来决定何时停止；而本文（第四章）的差异在于将终止与剪枝决策**外置于确定性算子**——以硬证据维度的一票否决 Gate 触发提前终止，LLM 全程不参与该判定，从而使“何时停、剪哪条”具有可复现、可审计的确定性依据。

尽管上述通用范式在开放域任务中表现优异，但将其直接迁移至云安全领域仍面临严峻挑战：云安全任务不仅要求推理链路的事实正确性，还要求每一步推断具有可被外部验证的证据支撑，这超出了 ReAct 等范式的能力边界。

2.4.2 LLM 在安全分析中的应用

大语言模型已被尝试应用于多个安全任务，其应用广度正从辅助分析向自主决策拓展。在漏洞分析与代码审计方面，以 GPT-4、CodeLlama 等模型对代码进行漏洞模式识别的研究已取得初步成效 [51]。在告警研判与降噪方面，LLM 被用于将 SIEM 告警转化为自然语言摘要并辅助分诊 [52]，显著降低了安全运营人员的信息过载。在威胁情报理解方面，SecureBERT [20]、CySecBERT [53]、SecGPT [21] 等领域模型在威胁情报命名实体识别、报告摘要等任务上取得了性能提升，展现了领域适配的价值。在事件响应与 SOAR 剧本生成方面，LLM 被用于生成 Playbook 草稿供人工修订 [13]，加速了响应流程。在红蓝对抗辅助方面，Deng 等人提出的 PentestGPT 利用 LLM 生成攻击载荷或调用渗透工具的辅助决策 [54]，初步验证了 LLM 在攻防场景的可行性。

然而，上述应用普遍停留在“辅助分析”层面，即 LLM 生成建议后仍需人工确认。在暴露路径侦测这一需要端到端输出可审计结论的场景中，仅靠辅助分析远远不够，必须建立严格的证据约束机制以确保 LLM 输出的可靠性。

2.4.3 LLM 幻觉与 Grounding

幻觉是 LLM 在事实密集型任务中的核心障碍。Ji 等的综述将幻觉分为内在幻觉（与上下文不一致）与外在幻觉（与世界事实不一致）两类 [55]。在安全场景下，外在幻觉的代价尤为严重——一条虚构的“暴露路径”可能直接误导处置人员，造成漏报或误报。

为应对幻觉问题，学术界与工业界发展了多类 Grounding 手段。检索增强（RAG）通过外部知识源约束模型输出 [50]，是最为广泛采用的策略。工具调用则让模型显式调用 API 或数据库以获取事实 [15]，实现了生成与验证的闭环。结构化输出约束通过 JSON Schema、Function Schema 等限制模型输出形式，降低格式层面的幻觉风险。自一致性与多样本投票（Self-Consistency）[56] 等技术通过多次采样降低偶然幻觉。可验证生成（Verifiable Generation）则要求模型每条主张携带可被外部验证的引用或证据 [57]，从生成范式层面约束幻觉。

本文方法属于可验证生成的范畴，但与已有工作不同的是，本文以图作为可机器验证的事实源，对每一步生成进行验证，并将验证结果反向作用于训练，形成了“推理时验证 + 训练时反馈”的双轮驱动机制。

2.4.4 现有安全 Agent 的局限性

综合 2.4 节的讨论，可以归纳出当前安全 Agent 的几点共性局限。其一，证据机制薄弱——多数工作仅做 RAG 式注入，即向模型提供相关上下文后便让其自由生成，未对生成的每一步进行强制证据绑定，导致输出中仍可能混入未经证实的推断。其二，缺乏不变量校验——缺少对“网络可达必须由路由 + 安全组共同

支持”等领域不变量的形式化约束，使得模型可能输出违反物理约束的”伪路径”。其三，评测基准不足——缺乏针对”云数据库高敏数据暴露路径”的专用基准，导致方法间难以公平比较。其四，训练手段单一——多以提示工程或通用 SFT 为主，鲜有结合可机器验证反馈的对齐方法，限制了模型在专业任务上的能力上限。

上述局限为本文方法提供了明确的改进方向：以”证据可达性 + 不变量校验”双约束改造 ReAct，是降低安全 Agent 幻觉、提升可审计性的关键；与此同时，需要为”图验证反馈”与训练流程的耦合留出接口。这也自然引出了下一节关于参数高效微调与偏好对齐的讨论——如何在训练阶段利用图验证信号对齐模型行为，是实现上述目标不可或缺的一环。

2.5 参数高效微调与偏好对齐

2.5.1 参数高效微调（PEFT）方法

随着基座模型规模上升，全参数微调的计算与存储成本变得难以承受，PEFT 系列方法应运而生，通过引入少量可训练参数实现接近全参微调的效果。该领域的发展经历了从结构插入到低秩分解的演进。Houlsby 等提出的 Adapter 方法在 Transformer 各层中插入小型瓶颈层，仅训练这些瓶颈层 [24]，开创了参数高效迁移学习的先河。随后，Li 等提出的 Prefix-Tuning 在输入侧拼接可学习前缀，仅训练前缀向量 [58]，进一步减少了可训练参数量。然而，真正使 PEFT 成为工程标配的是 Hu 等提出的 LoRA 方法 [22]，其对权重的低秩增量进行训练，在不引入推理延迟的前提下实现了高效的领域适配。在此基础上，Dettmers 等提出的 QLoRA [23] 结合 4-bit 量化与 LoRA，使在单张消费级 GPU 上微调 7B~65B 模型成为可能，极大降低了领域微调的硬件门槛。近期，DoRA、VeRA、AdaLoRA [59] 等方法在 LoRA 基础上进一步改进，在参数效率与训练稳定性方面持续提升。

PEFT 方法是本文在小模型上进行图验证反馈对齐时的工程基础，LoRA/QLoRA 将作为第五章对齐训练的参数高效微调手段。

2.5.2 偏好对齐方法

让模型对齐”人类或环境偏好”已成为后预训练阶段的核心议题，其方法论经历了从强化学习到直接优化的范式转变。以 OpenAI InstructGPT 与 ChatGPT 为代表的 RLHF 采用了”SFT + Reward Model + PPO”三段式 [25]，通过训练显式奖励模型来捕捉人类偏好。然而，RLHF 的训练流程复杂且不稳定，为此 Rafailov 等提出了 DPO (Direct Preference Optimization) [26]，无需显式 Reward Model 即可直接将偏好对转化为损失函数，训练稳定性显著提升。此后，IPO、KTO、ORPO [27][60] 等方法在偏好估计、单样本学习、SFT 与对齐合一等方向做了拓展，形成了丰富的对齐工具箱。与此同时，RLAIF [61] 以 AI 反馈替代人类反馈，降低了标注成本，开辟了非人类偏好信号的路径。

特别值得关注的是”可验证反馈对齐”这一新兴方向。在数学、代码、推理等可机器验证的任务上，使用执行结果或形式化检查作为反馈信号已成为可行方案，代表性工作包括 STaR [62]、ReST [63]、Math-Shepherd [64]、Process Reward Model 等。这些工作的共同特点是：任务本身存在客观的验证标准（如代码是否通过测试、数学证明是否正确），使得偏好信号无需依赖人工标注即可自动生成。

2.5.3 在垂直领域的应用与局限

PEFT 与对齐方法在医学、法律、金融、代码等垂直领域已有广泛尝试，例如 Med-PaLM、ChatLaw、FinGPT、CodeLlama-Instruct 等 [65]，验证了”基座模型 + 领域对齐”范式的通用有效性。然而在云安全这一垂直领域，公开可见的对齐工作仍然有限，且几乎没有研究将”图可验证性”引入对齐反馈链路。这一空白并非偶然：云安全任务的专业性极高，人类标注成本远超医学、法律等领域；同时，与代码可执行验证、数学答案可数值验证不同，安全分析结论的验证需要更复杂的领域知识——而风险图恰好提供了这一验证能力。

综合 2.5 节的讨论，可以得出对本文的三点启示：其一，LoRA/QLoRA 是小模型对齐工程的标配，为本文的参数高效训练提供了成熟工具；其二，DPO/KTO 提供了无需显式 Reward Model 的稳定优化路径，降低了训练复杂度；其三，”可验证反馈”思想在数学/代码任务上已被验证有效，将其迁移至”图验证反馈”是本文方法论上的关键跃迁——图作为符号结构本身就是天然的验证器，能够提供比人工标注更稳定、更可扩展的偏好信号。这一洞察将构成第五章图验证反馈对齐方法的核心出发点。

2.6 本章小结与研究定位

2.6.1 现有工作 Gap 分析

综合 2.1~2.5 节的综述，可以将与本文研究问题最相关的研究 Gap 归结为四点，如表 2-1 所示。

维度	现有工作的代表方向	主要不足
建模	攻击图 / 安全知识图谱 / DSPM 资产图	维度割裂，缺乏面向”云数据库高敏字段”的统一可验证性
推理	LLM Agent / RAG / SOAR Agent	证据约束薄弱、不变量校验缺失，幻觉与不可审计性
学习	RLHF / DPO / RLAIIF / 数学代码可验证反馈	在云安全垂直领域缺乏可机器验证反馈来源
评测	通用安全数据集 / 单点风险扫描	缺乏面向”暴露路径”的端到端基准与指标

2.6.2 本文研究定位

本文将自身定位为以下三个研究脉络的交汇点。在图建模层面，本文继承攻击图与云原生安全图的形式化思想，向”以高敏数据为终点、以多源证据为支撑”的

方向收紧。在证据约束的智能体层面，本文把 RAG 与可验证生成的思想推进到“对每一步推断强制图验证”的层级。在图验证反馈对齐层面，本文把“可验证反馈”从数学/代码领域迁移到云安全领域，让小模型也能在路径侦测任务上获得专业表现。

在以上三方面的共同作用下，本文构建出一条“图建模—证据约束—自动对齐”的端到端研究路线，目标是输出“可解释、可审计、可复现”的云数据库高敏数据暴露路径分析能力。后续章节将依次对这一路线的各个模块展开详细论述。

3 参考文献

- [1] Gartner. *Magic Quadrant for Cloud Database Management Systems*. Gartner Research, 2023.
- [2] IDC. *Worldwide Public Cloud Database Forecast, 2023–2027*. IDC Report, 2023.
- [3] 国家互联网信息办公室. 《中华人民共和国个人信息保护法》. 2021.
- [4] European Parliament. *General Data Protection Regulation (GDPR)*. Official Journal of the European Union, 2016.
- [5] IBM Security. *Cost of a Data Breach Report 2023*. Ponemon Institute, 2023.
- [6] Gartner. *Innovation Insight for Cloud-Native Application Protection Platforms*. Gartner Research, 2021.
- [7] Gartner. *Market Guide for Cloud Infrastructure Entitlement Management*. Gartner Research, 2022.
- [8] Gartner. *Innovation Insight for Data Security Posture Management*. Gartner Research, 2022.
- [9] Imperva. *Database Activity Monitoring: A Do's and Don'ts Best Practices Guide*. Imperva Whitepaper, 2021.
- [10] National Vulnerability Database. *NVD Database Vulnerability Statistics*. NIST, 2023.
- [11] Wiz Research. *Toxic Combinations: A New Era of Cloud Risk*. Wiz Blog, 2022.
- [12] Y. Liu, et al. "GPT-4 in Cybersecurity: Capabilities and Limitations." *arXiv preprint arXiv:2305.07289*, 2023.
- [13] D. Sworna, et al. "APIRO: A Framework for Automated Security Tools API Recommendation." *ACM TOSEM*, 2023.
- [14] S. Yao, et al. "ReAct: Synergizing Reasoning and Acting in Language Models." *ICLR*, 2023.
- [15] T. Schick, et al. "Toolformer: Language Models Can Teach Themselves to Use Tools." *NeurIPS*, 2023.
- [16] O. Sheyner, et al. "Automated Generation and Analysis of Attack Graphs." *IEEE S&P*, 2002.
- [17] X. Ou, et al. "MulVAL: A Logic-based Network Security Analyzer." *USENIX Security*, 2005.
- [18] Orca Security. *State of Cloud Security Report*. Orca Research, 2023.
- [19] Forrester. *The Forrester Wave: Data Security Platforms, Q1 2023*. Forrester Research, 2023.
- [20] E. Aghaei, et al. "SecureBERT: A Domain-Specific Language Model for Cybersecurity." *SecureComm*, 2022.
- [21] J. Deng, et al. "SecGPT: A Large Language Model for Cybersecurity." *arXiv preprint arXiv:2402.12077*, 2024.
- [22] E. Hu, et al. "LoRA: Low-Rank Adaptation of Large Language Models." *ICLR*, 2022.
- [23] T. Dettmers,

- et al. "QLoRA: Efficient Finetuning of Quantized LLMs." *NeurIPS*, 2023. [24] N. Houlsby, et al. "Parameter-Efficient Transfer Learning for NLP." *ICML*, 2019. [25] L. Ouyang, et al. "Training Language Models to Follow Instructions with Human Feedback." *NeurIPS*, 2022. [26] R. Rafailov, et al. "Direct Preference Optimization: Your Language Model is Secretly a Reward Model." *NeurIPS*, 2023. [27] K. Ethayarajh, et al. "KTO: Model Alignment as Prospect Theoretic Optimization." *arXiv preprint arXiv:2402.01306*, 2024. [28] Tenable Research. *Cloud Security Outlook Report*. Tenable, 2023. [29] Palo Alto Networks Unit 42. *2023 Cloud Threat Report*. Unit 42, 2023. [30] M. Sotnikov, et al. "An Empirical Study of IAM Misconfigurations in Public Clouds." *USENIX Security*, 2023. [31] ISO/IEC 27701:2019. *Privacy Information Management*. International Organization for Standardization, 2019. [32] NIST. *Privacy Framework v1.0*. National Institute of Standards and Technology, 2020. [33] Microsoft. *Presidio: Data Protection and PII De-identification SDK*. Microsoft Open Source, 2022. [34] Google Cloud. *Cloud Data Loss Prevention API Documentation*. Google, 2023. [35] J. Kindervag. *No More Chewy Centers: Introducing The Zero Trust Model of Information Security*. Forrester Research, 2010. [36] NIST. *SP 800-207: Zero Trust Architecture*. NIST, 2020. [37] CNCF Security TAG. *Cloud Native Security Whitepaper*. Cloud Native Computing Foundation, 2022. [38] Open Policy Agent. *OPA Documentation*. CNCF Project, 2023. [39] P. Ammann, et al. "Scalable, Graph-Based Network Vulnerability Analysis." *ACM CCS*, 2002. [40] N. Poolsappasit, et al. "Dynamic Security Risk Management Using Bayesian Attack Graphs." *IEEE TDSC*, 2012. [41] Z. Hu, et al. "Automated Penetration Testing Using Deep Reinforcement Learning." *IEEE EuroS&PW*, 2020. [42] OASIS. *Structured Threat Information Expression (STIX) Version 2.1*. OASIS Standard, 2021. [43] B. E. Strom, et al. "MITRE ATT&CK: Design and Philosophy." *MITRE Technical Report*, 2020. [44] MITRE. *ATT&CK for Cloud Matrix*. MITRE Corporation, 2023. [45] Microsoft. *Defender for Cloud Attack Path Analysis Documentation*. Microsoft Learn, 2023. [46] R. Andersen, et al. "Local Graph Partitioning Using PageRank Vectors." *FOCS*, 2006. [47] S. Yao, et al. "Tree of Thoughts: Deliberate Problem Solving with Large Language Models." *NeurIPS*, 2023. [48] Q. Wu, et al. "AutoGen: Enabling Next-Gen LLM Applications via Multi-Agent Conversation." *arXiv preprint arXiv:2308.08155*, 2023. [49] S. Hong, et al. "MetaGPT: Meta Programming for a Multi-Agent Collaborative Framework." *ICLR*, 2024. [50] P. Lewis, et al. "Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks." *NeurIPS*, 2020. [51] H. Pearce, et al. "Examining Zero-Shot Vulnerability Repair with Large Language Models." *IEEE S&P*, 2023. [52] M. Levi, et al. "LLM-Based Triage for Security Operation Centers." *ACSAC*, 2023. [53] M. Bayer,

et al. "CySecBERT: A Domain-Adapted Language Model for the Cybersecurity Domain." *arXiv preprint arXiv:2212.02974*, 2022. [54] G. Deng, et al. "PentestGPT: An LLM-empowered Automatic Penetration Testing Tool." *USENIX Security*, 2024. [55] Z. Ji, et al. "Survey of Hallucination in Natural Language Generation." *ACM Computing Surveys*, 2023. [56] X. Wang, et al. "Self-Consistency Improves Chain of Thought Reasoning in Language Models." *ICLR*, 2023. [57] T. Gao, et al. "Enabling Large Language Models to Generate Text with Citations." *EMNLP*, 2023. [58] X. L. Li, P. Liang. "Prefix-Tuning: Optimizing Continuous Prompts for Generation." *ACL*, 2021. [59] Q. Liu, et al. "DoRA: Weight-Decomposed Low-Rank Adaptation." *ICML*, 2024. [60] J. Hong, et al. "ORPO: Monolithic Preference Optimization without Reference Model." *EMNLP*, 2024. [61] H. Lee, et al. "RLAIF: Scaling Reinforcement Learning from Human Feedback with AI Feedback." *arXiv preprint arXiv:2309.00267*, 2023. [62] E. Zelikman, et al. "STaR: Bootstrapping Reasoning with Reasoning." *NeurIPS*, 2022. [63] C. Gulcehre, et al. "Reinforced Self-Training (ReST) for Language Modeling." *arXiv preprint arXiv:2308.08998*, 2023. [64] P. Wang, et al. "Math-Shepherd: Verify and Reinforce LLMs Step-by-step without Human Annotations." *ACL*, 2024. [65] K. Singhal, et al. "Large Language Models Encode Clinical Knowledge." *Nature*, 2023.

[66] Y. Wu, et al. "StateFlow: Enhancing LLM Task-Solving through State-Driven Workflows." *COLM / NeurIPS Workshop*, 2024.

[67] Y. Liu, et al. "Knowing When to Stop: Teaching LLM Agents to Halt Information Gathering via Counterfactual Reasoning (CaRT)." *arXiv preprint arXiv:2510.08517*, 2025.

[68] Budget-Aware Tool-Use Enables Effective Agent Scaling: A Unified Cost Metric and Cost-Performance Pareto Analysis. *arXiv preprint arXiv:2511.17006*, 2025.

4 CloudDB-PathBench 基准构建与验证

云数据库高敏数据暴露路径侦测任务长期受困于“无统一形式化、无标准基准、无可复现评估”的三重困境。第二章的相关工作综述表明，已有数据集要么聚焦单点漏洞（如 CIS Benchmark 类）、要么仅覆盖网络层攻击图（如 AttackGraph、MulVAL 衍生集合），均未将“身份—网络—权限—数据—审计—治理”六要素一体化建模，且普遍缺失对“证据链完整性”的显式标注。

为支撑后续 EIC-Agent 与 GV-FA 方法的训练与评估，本章提出 **CloudDB-PathBench**——面向 Toxic Combination 路径可控生成与量化评估的云数据安全基准。本章从任务的严格形式化定义出发 (§3.1)，在统一的云数据库风险图 (CDB-

RG) 上建模异构要素 (§3.2), 引入字段—表—实例的三层敏感性聚合模型并给出单调性证明 (§3.3); 采用”真实配置种子驱动的参数化合成”四层数据构建管线 (§3.4) 产出可控、可复现、质量可查的数据集; 借助图算法与人工复核完成 Gold Path 标注与一致性约束校验 (§3.5), 设计 4 种切分策略以支持多维度鲁棒性评估 (§3.6); 最后通过基准质量验证实验 (§3.7) 评估场景覆盖度、路径多样性、标注一致性与难度梯度, 为后续章节提供可信的评测底座。

4.1 任务形式化定义

4.1.1 输入：云数据库环境快照

设某一时刻 t 下的云数据库环境快照为六元组:

$$S_t = (\mathcal{A}, \mathcal{N}, \mathcal{I}, \mathcal{D}, \mathcal{L}, \mathcal{C})$$

其中, $\mathcal{A}$ (Assets, 资产层) 涵盖所有云数据库实例及其承载的库、模式、表、视图、字段, 记为 $\mathcal{A} = \{a_i = (id, type, region, vpc, engine, version, attrs)\}$, 其中 $type \in \{RDS, PolarDB, MongoDB, Redis, ClickHouse, \dots\}$; $\mathcal{N}$ (Network, 网络层) 包含 VPC、子网、安全组、网络 ACL、路由表、负载均衡、公网 IP 绑定、白名单 CIDR 等, 构成网络可达关系子图; $\mathcal{I}$ (Identity & Permission, 身份权限层) 覆盖云账户、IAM 用户、角色、组、策略、数据库账户、对象级权限 (GRANT/REVOKE 元组) 以及信任关系 (AssumeRole 链); $\mathcal{D}$ (Sensitive Data Distribution, 敏感数据分布层) 为字段粒度上的分类分级标签集合 $\mathcal{D} = \{(field, category, level, confidence)\}$, 其中 $level \in \{L1, L2, L3, L4\}$ 对应”公开、内部、机密、绝密”; $\mathcal{L}$ (Audit Logs, 审计日志层) 记录登录事件、SQL 执行事件、权限变更事件、网络访问事件, 每条事件记为 $(t, principal, action, resource, src_ip, success)$; $\mathcal{C}$ (Control & Governance, 治理状态层) 描述是否开启加密、备份、审计、防火墙、KMS 托管、敏感数据脱敏策略、合规基线绑定等控制项的取值。

上述六元组构成了云租户安全态势的全景刻画: 资产层回答”拥有哪些资源”, 网络层回答”谁能够到达”, 身份权限层回答”谁有权进入”, 敏感数据分布层回答”内部藏有何种高价值数据”, 审计日志层回答”谁曾经访问过”, 治理状态层回答”已部署哪些防护措施”。六个维度相互关联, 任何暴露路径的形成必然涉及多个维度的协同失效。

4.1.2 输出：暴露路径集合

侦测任务的输出为一个有限的路径集合:

$$Y = \{(p_i, e_i, r_i, m_i)\}_{i=1}^N$$

其中, $p_i = (v_1, v_2, \dots, v_{k_i})$ 为一条从外部入口到敏感目标的路径; e_i 为支持该路径成立的证据链, $e_i = \{(claim_j, evidence_j, source_j)\}$, 每项证据须可回溯到 S_t 中的具体观测项; $r_i \in \{Critical, High, Medium, Low\}$ 为风险等级; m_i 为可执行的处置建议 (mitigation), 形如”收紧安全组 sg-xxx 的 0.0.0.0/0 规则、为 db-yyy 开启 TDE、撤销 role-zzz 的 DB_OWNER 权限”。

4.1.3 调查案例封装

§3.1.1 与 §3.1.2 分别定义了任务的全景输入 (环境快照 S_t) 与路径级输出 (路径集合 Y), 由此构成的是一个”给定完整图求路径”的评估范式。然而, 在真实云安全运营场景中, 安全分析师并非一开始就拥有完整的环境快照, 而是从某个告警或异常信号出发, 通过一系列查询与验证动作逐步还原暴露路径全貌。为使基准评估更贴合这一”主动调查”范式, 本文在路径级输入输出之上引入**调查案例封装层** (Investigation Case), 将评估模式从”给定完整图求路径”转为”给定初始线索、Agent 主动调查”。

一个调查案例定义为四元组:

$$\text{Case} = (\sigma_0, G, \mathcal{A}_{\text{tool}}, y^*)$$

各分量含义如下:

- σ_0 (**初始信号, initial signal**): 一个告警、异常事件或公网暴露标记, 作为 Agent 调查的起点。 σ_0 仅携带局部信息——例如”安全组 sg-xxx 存在 0.0.0.0/0 入站规则”或”审计系统检测到 user-admin 在 02:00–04:00 时段执行批量 SELECT 操作”——而非完整的环境快照或风险图。Agent 须从 σ_0 出发, 自主决定查询哪些资产、验证哪些关系, 逐步构建对全局态势的理解。
- G (**世界快照, world snapshot**): 由 §3.1.1 的环境快照 S_t 经 §3.2 方法构建的完整 CDB-RG 风险图及关联的审计日志, 作为 Agent 可通过工具交互查询的外部状态空间。 G 在评估期间保持只读不变, 但 Agent 不能直接读取 G 的全部内容, 只能通过下述工具集 $\mathcal{A}_{\text{tool}}$ 的接口按需查询其局部子结构。这一”信息隔离”设计模拟了真实环境中分析师仅能通过 API 查询逐步获取信息的约束。
- $\mathcal{A}_{\text{tool}}$ (**可用工具集接口**): 即第四章 §4.5 定义的 7 个证据获取工具 T1–T7 (GraphPathSearch、NetworkCheck、PermissionCheck、SensitiveDataQuery、AuditLogQuery、ControlStatusCheck、EvidenceValidator), 以统一接口形式暴露给 Agent。每次工具调用对应 G 上的一个局部查询, 返回结构化的观测结果; 工具的输入参数由 Agent 根据当前调查进展自主决定。
- y^* (**gold 标注**): 包含 gold path p^* 、gold evidence e^* 与 gold trajectory τ^* 三部分 (详见 §3.5)。 y^* 不进入 Agent 的上下文窗口, 仅用于评估时与 Agent 输出进行对比。

调查案例封装层的关键设计在于**信息不对称**：Agent 在调查开始时仅拥有初始信号 σ_0 ，须通过工具调用逐步从世界快照 G 中获取证据，而 gold 标注 y^* 对 Agent 完全不可见。这一设计使评估不仅考察路径判定的正确性，还考察 Agent 的主动调查能力——即在有限工具调用预算下，能否以合理的调查轨迹还原出真实的暴露路径。其中，gold 标注 y^* 中新增的 gold trajectory τ^* 记录专家从 σ_0 出发至还原出 Gold Path 所需的最优调查动作序列，用于第四章 EIC-Agent 的 Discover-Investigate-Explain (DIE) 三阶段执行模型的训练参考，以及轨迹级评估指标（如 EQP、CS、pass@ k ）的计算。调查案例封装层直接支撑了第五章 GVFA 对齐训练中 SFT 轨迹与 DPO 偏好对的构造。

4.1.4 评估四维度

设系统输出 $\hat{Y}$ 与人工标注 Y^* ，本文从四个互补维度定义评估体系。路径有效性（Path Validity, PV）衡量路径在图 G 中真实存在且合法的比例：

$$PV = \frac{|\{p \in \hat{Y} \mid p \text{ 合法}\}|}{|\hat{Y}|}.$$

证据完整性（Evidence Integrity, EI）衡量每条路径的关键边被显式证据支撑的程度：

$$EI(p) = \frac{|\{e \in p \mid \exists \text{evidence}(e) \in S_t\}|}{|p| - 1}.$$

风险排序正确性（Risk Ranking Correctness, RRC）以 NDCG@ k 与 Spearman 系数衡量 $\hat{Y}$ 的风险排序与 Y^* 的一致性。处置建议匹配度（Mitigation Match, MM）以集合级 F1 衡量 m_i 与标准处置 m_i^* 的覆盖与精确程度。

最终复合指标 $\Omega = w_1 PV + w_2 EI + w_3 RRC + w_4 MM$ ，权重默认 (0.30, 0.30, 0.20, 0.20)，可在 §6 实验中按场景重权。

4.2 云数据库风险图建模

4.2.1 定义 3.1：云数据库风险图

定义 3.1 (CloudDB Risk Graph, CDB-RG) 给定环境快照 S ，其对应的云数据库风险图为有类型属性有向图：

$$G = (V, E, \tau_V, \tau_E, \varphi_V, \varphi_E)$$

其中， V 为节点集合， $E \subseteq V \times V$ 为有向边集合； $\tau_V : V \rightarrow T_V$ 为节点类型函数，

$T_V = \{Identity, Network, DBInstance, DBObject, SensitiveTag, AuditEvent, RiskFinding, Control\}$

$\tau_E : E \rightarrow T_E$ 为边类型函数,

$T_E = \{owns, can_assume, can_connect, has_permission, contains, classified_as, accessed, triggered\}$

$\varphi_V : V \rightarrow A_V$ 为节点属性函数, 将节点映射到键值属性集合; $\varphi_E : E \rightarrow A_E$ 为边属性函数, 刻画边的强度、来源、可信度等。

CDB-RG 的核心设计理念在于将分散于云控制台、IAM 控制器、DBMS 系统表、审计中心与安全中心的多源异构信息统一投影为一张属性有向图。其中, 节点承载”实体是什么”的语义, 边刻画”谁连接到谁、以何种关系连接”的结构信息。在此框架下, 任何一条暴露路径均可被解释为该图上从外部入口到高敏目标的一次穿越, 其路径上的节点与边共同构成可审计的证据链。

4.2.2 节点类型属性 schema

下表给出 8 种节点类型的属性 schema 与语义说明:

节点类型	关键属性 (A_V)	语义说明
Identity	$\{id, kind \in \{user, role, group, service\}, is_external, mfa, last_login\}$	任何可执行操作的主
Network	$\{id, kind \in \{vpc, subnet, sg, acl, eip, slb\}, cidr, public_exposed\}$	网络可达性单元; pu
DBInstance	$\{id, engine, version, region, port, encrypted, audit_on\}$	物理或逻辑数据库实
DBObject	$\{id, kind \in \{db, schema, table, view, field\}, parent, masked\}$	实例下的逻辑对象;
SensitiveTag	$\{id, category, level \in \{L1..L4\}, confidence\}$	敏感数据类目, 如”
AuditEvent	$\{id, t, action, success, src_ip, anomaly_score\}$	审计原子事件
RiskFinding	$\{id, rule, severity, observed_at\}$	由规则或模型派生的
Control	$\{id, kind \in \{TDE, KMS, Audit, FW, DLP, Backup\}, enabled, scope\}$	安全控制项及其覆盖

以节点 v_{37} 为例, 其类型为 **DBObject**, 属性 $\varphi_V(v_{37}) = \{kind = table, parent = db_crm, masked = false, name = user_kyc\}$, 与之相连的 **SensitiveTag** 节点表明它包含 身份证号 (L4) 与 银行卡号 (L4) 两类高敏字段。

4.2.3 边类型连接约束

边并非任意可连, 须满足类型语义约束。下表列出 10 种边类型的合法源—目标类型对:

边属性 φ_E 至少包含 $\{strength \in [0, 1], source, observed_at, evidence_ref\}$, 其中 **evidence_ref** 是回溯到 S 中原始观测的指针, 构成”图—证据”双向可追溯结构。

边类型	合法源类型 $\rightarrow$ 目标类型	含义与示例
owns	Identity $\rightarrow$ Identity / DBInstance / Control	账户主从、资源归属
can_assume	Identity $\rightarrow$ Identity	角色信任链 (AssumeRole)
can_connect	Network $\rightarrow$ Network / DBInstance	网络层可达 (安全组 + ACL + 路由)
has_permission	Identity $\rightarrow$ DBInstance / DBObject	权限授予 (含 SELECT、UPDATE)
contains	DBInstance $\rightarrow$ DBObject; DBObject $\rightarrow$ DBObject	库—模式—表—字段层级包含
classified_as	DBObject $\rightarrow$ SensitiveTag	分类分级结果
accessed	Identity $\rightarrow$ DBObject (经 AuditEvent 中介)	历史访问事实
triggered	AuditEvent $\rightarrow$ RiskFinding	审计事件触发风险发现
has_risk	DBObject / DBInstance / Identity $\rightarrow$ RiskFinding	实体携带的风险标记
protected_by	DBInstance / DBObject $\rightarrow$ Control	控制项覆盖关系

4.2.4 定义 3.2: 暴露路径

定义 3.2(Exposure Path) 给定 CDB-RG G , 一条暴露路径 $P = (v_1, e_1, v_2, e_2, \dots, e_{k-1}, v_k)$ 须同时满足:

(1) **入口约束**: $v_1 \in \text{Entry}(G)$,

$$\text{Entry}(G) = \{v \mid \tau_V(v) \in \{\text{Network}, \text{Identity}\} \wedge \text{is_external}(v)\}.$$

(2) **目标约束**: $v_k \in \text{Target}(G)$,

$$\text{Target}(G) = \{v \mid \tau_V(v) \in \{\text{DBObject}, \text{SensitiveTag}\} \wedge \text{is_high_value}(v)\},$$

其中 is_high_value 由 §3.3 的敏感性聚合模型判定。

(3) **路径合法性**: 对任意相邻三元组 (v_i, e_i, v_{i+1}) , 须满足 $\tau_E(e_i)$ 的源—目标类型约束 (§3.2.3 表)。同时全局结构上须依次包含至少一条 **can_connect**、一条 **has_permission**、一条 **contains** 或 **classified_as**, 以保证“网络可达 $\rightarrow$ 身份可访问 $\rightarrow$ 数据高敏”三段式语义。

(4) **长度约束**: $4 \leq k \leq 8$ 。下界 4 排除“主体直挂数据”的无意义短路径, 上界 8 排除组合爆炸下的虚假长链。

(5) **无环约束**: $\forall i \neq j, v_i \neq v_j$ 。

(6) **时序一致性**: 对包含 **accessed/triggered** 的子段, 其 **observed_at** 须满足非递减。

4.2.5 路径类型转移矩阵

为了在生成与搜索时高效剪枝, 我们将路径合法性编码为类型层面的转移矩阵 $\mathbf{M} \in \{0, 1\}^{|T_V| \times |T_E| \times |T_V|}$, $\mathbf{M}[u, e, v] = 1$ 当且仅当从 u 类型节点出发经 e 类型边到达 v 类型节点合法。下表给出关键非零项 (行: 源类型; 列: 边 $\rightarrow$ 目标类型):

源类型 边 → 目标	can_connect→Network	can_connect→DBInstance	has_permission→DBObject
Network			
Identity			
DBInstance			
DBObject			

进一步，我们要求合法路径的边类型序列 $\sigma(P) = (\tau_E(e_1), \dots, \tau_E(e_{k-1}))$ 属于由如下正则文法生成的语言 $\mathcal{R}$ ：

$$\mathcal{R} = (can_connect)^+ (can_assume)^* (has_permission) (contains)^* (classified_as)?$$

该文法刻画了”先穿网、再换身份、再获权限、再钻入对象、最后落到敏感标签”的标准穿透语义。它既保证可解释性，也使搜索复杂度降为多项式级（详见§3.5.1 的 NetworkX 实现）。

在上述风险图建模的基础上，一个自然的问题浮现：图中的目标节点集合 $Target(G)$ 如何判定？定义 3.2 中 is_high_value 的判定直接依赖于敏感数据的价值评估，而云数据库中敏感数据分布于字段、表、实例三个层次，单一层次的评估难以准确反映整体风险态势。为此，下一节将提出字段—表—实例的三层敏感性聚合模型，为暴露路径的目标判定提供量化基础。

4.3 敏感性层次聚合模型

4.3.1 三层聚合

定义 3.3（三层敏感性评分） 设字段 f 的分级 $level(f) \in \{1, 2, 3, 4\}$ 、置信度 $confidence(f) \in [0, 1]$ ，定义：

字段层（field-level）：

$$S_{field}(f) = level(f) \times confidence(f).$$

表层（table-level，max 主导 + 计数修正）：

$$S_{table}(t) = \max_{f \in Fields(t)} S_{field}(f) + \lambda_1 \cdot |HighSens(t)| + \lambda_2 \cdot \frac{|Sens(t)|}{|Fields(t)|},$$

其中， $HighSens(t) = \{f \in Fields(t) \mid level(f) \geq 3\}$ ， $Sens(t) = \{f \in Fields(t) \mid level(f) \geq 2\}$ ； $\lambda_1, \lambda_2 \geq 0$ 为修正系数，默认 $\lambda_1 = 0.2, \lambda_2 = 0.5$ 。

实例层（instance-level）：

$$S_{instance}(i) = \max_{t \in Tables(i)} S_{table}(t) + \mu_1 \cdot |HighTables(i)| + \mu_2 \cdot |ExposedTables(i)|,$$

其中, $HighTables(i) = \{t \mid S_{table}(t) \geq \theta_t\}$, $ExposedTables(i) = \{t \mid \exists p \in Path(t), v_1(p) \in Entry(G)\}$; $\mu_1, \mu_2 \geq 0$, 默认 $\mu_1 = 0.3, \mu_2 = 0.4$ 。

上述三层聚合模型的设计深刻契合了云数据安全的实际运维逻辑。在表层评分中采用最大值主导策略, 其核心考量在于: 高敏数据的风险暴露往往遵循”木桶效应”的逆向逻辑, 即单一核心字段的泄露足以导致严重的安全事件, 其风险权重不应被同表中大量低敏字段所稀释。然而, 仅凭最大值尚不足以区分”一个 L4 字段藏在 200 列里”与”50 列中 30 列均为 L4”两种本质不同的风险态势——前者属于偶发的高敏嵌入, 后者则意味着系统性敏感数据聚集。为此, 模型引入高敏字段计数与高敏占比两项修正项, 使表层评分能够更准确地反映数据敏感度的分布结构。实例层则在表层最大值之上叠加”高敏表数量”与”已暴露表数量”两个维度, 前者刻画实例整体的风险密度, 后者反映拓扑相关性——已在网络上暴露的敏感表显然比同等敏感但隔离良好的表更具威胁。

4.3.2 高价值目标判定

定义 3.4 (High-value Target) 取阈值 $\theta_f, \theta_t, \theta_i$, 记:

- High-value Field: $\mathcal{F}^* = \{f \mid S_{field}(f) \geq \theta_f\}$;
- High-value Table: $\mathcal{T}^* = \{t \mid S_{table}(t) \geq \theta_t\}$;
- High-value Instance: $\mathcal{I}^* = \{i \mid S_{instance}(i) \geq \theta_i\}$ 。

默认设置 $\theta_f = 3.0$ (对应 L3 且 confidence 1.0 或 L4 且 confidence 0.75), $\theta_t = 3.4$, $\theta_i = 4.0$, 可由数据治理团队按行业基线再校准。

以表 `crm.user_kyc` 为例, 该表含字段 `id_card`(L4, 0.97)、`phone`(L3, 0.92)、`name`(L2, 0.99) 与 7 个 L1 字段, 则

$$S_{field}(id_card) = 3.88, S_{field}(phone) = 2.76, S_{field}(name) = 1.98,$$

$$S_{table}(user_kyc) = 3.88 + 0.2 \times 1 + 0.5 \times \frac{3}{10} = 4.23.$$

该值超过 θ_t , 因而 `user_kyc` 进入 $\mathcal{T}^*$ 。

4.3.3 单调性证明

定理 3.1 (敏感度单调性) 设 $\tilde{S}$ 为对环境 S 的任意”敏感度增加”扰动, 即存在字段 f^* 使 $\tilde{S}_{field}(f^*) \geq S_{field}(f^*)$ 且其它字段评分不变; 其它结构 (表/实例归属、字段计数、暴露关系) 保持不变。则:

$$\tilde{S}_{table}(t) \geq S_{table}(t) \quad \forall t, \quad \tilde{S}_{instance}(i) \geq S_{instance}(i) \quad \forall i.$$

证明:

(1) 表层: 固定 t , 记 $f^\circ = \arg \max_{f \in Fields(t)} S_{field}(f)$ 。

- 若 $f^* \notin Fields(t)$, 则 $\max_{f \in Fields(t)} \tilde{S}_{field}(f) = S_{field}(f^*)$, 且 $|HighSens(t)|, |Sens(t)|, |Fields(t)|$ 均不变, 结论平凡成立。
- 若 $f^* \in Fields(t)$, 则 $\tilde{S}_{field}(f^*) \geq S_{field}(f^*)$, 故 $\max_f \tilde{S}_{field}(f) \geq \max_f S_{field}(f)$ 。又因为 $\tilde{S}_{field}(f^*)$ 上升只可能使 f^* 跨越 $L \geq 3$ 或 $L \geq 2$ 阈值进入 $HighSens$ 与 $Sens$, 因此 $|\widetilde{HighSens}(t)| \geq |HighSens(t)|$, $|\widetilde{Sens}(t)| \geq |Sens(t)|$ 。 $|Fields(t)|$ 不变。由于 $\lambda_1, \lambda_2 \geq 0$, 三项相加仍单调不减, 故 $\tilde{S}_{table}(t) \geq S_{table}(t)$ 。

(2) 实例层: 固定 i , 由 (1) 知 $\forall t \in Tables(i)$, $\tilde{S}_{table}(t) \geq S_{table}(t)$, 因此 $\max_t$ 与 $|HighTables(i)|$ 均单调不减; $|ExposedTables(i)|$ 仅由网络/权限拓扑决定, 故不变。 $\mu_1, \mu_2 \geq 0$ 保证总和单调不减。□

定理 3.1 所保证的单调性具有双重实践价值。一方面, 它为后续的剪枝搜索提供了理论支撑: 一旦发现某子图的敏感度上界仍低于阈值, 即可安全地剪除整支子图而不会遗漏任何合法目标。另一方面, 它在训练阶段为对比学习的正负样本构造提供了保序保证, 确保局部敏感度的提升不会导致全局风险评分的异常下降。

至此, 我们已建立了暴露路径侦测任务的形式化框架与敏感性判定基础。然而, 仅有形式化定义与聚合模型尚不足以支撑大规模的训练与评估, 还亟需一个覆盖多场景、多难度梯度的标准化基准数据集。下一节将详细阐述 CloudDB-PathBench 的数据构建管线, 从攻击技术映射到参数化合成, 逐步生成满足质量约束的合成样本。

4.4 数据构建管线

云数据库安全配置涉及企业核心资产与合规隐私 (PIPL、GDPR), 真实生产环境的配置快照无法公开获取与共享。因此本基准采用” **真实配置种子驱动的参数化合成**” 策略: 以公开云安全靶场的真实配置为种子, 通过参数化管线扩展为大规模数据集, 并以确定性图验证器保障数据质量。整体管线包含场景来源与种子提取、Schema 池构建、参数化合成、确定性验证四层, 下文依次阐述。

4.4.1 场景来源与攻击技术映射

本基准的 6 类场景模板并非凭空构造, 而是以公开攻击技术知识库与安全事件报告为依据。具体地, 我们从 MITRE ATT&CK Cloud Matrix 中筛选与云数据库暴露路径直接相关的子技术, 建立” 攻击技术 场景模板” 映射:

此外, 场景模板的设计还参考了 Mandiant M-Trends 2023、IBM X-Force 2023、Unit42 Cloud Threat Report 等公开安全报告中的典型云数据库安全事件攻击链描述。

场景	对应 ATT&CK 子技术	典型攻击模式
S1 公网暴露 + 高敏数据未保护	T1190 Exploit Public-Facing Application	安全组 0.0.0.0/
S2 低权限账号权限过宽	T1078 Valid Accounts, T1098 Account Manipulation	IAM 通配权限
S3 异常 IP / 夜间访问 + 批量查询	T1530 Data from Cloud Storage	非工作时段批量
S4 外部主体 + 白名单过宽	T1537 Transfer Data to Cloud Account	跨账户信任 +
S5 未开启审计 / 保护 + 高敏资产	T1562 Impair Defenses	TDE/Audit/D
S6 证据缺失 / 冲突场景	—	证据扰动（删

4.4.2 真实配置种子提取

为使合成数据具备真实云环境的配置模式，本基准从公开云安全靶场中提取真实配置作为生成种子：

靶场	提取场景数	提取内容
CloudGoat (Rhino Security Labs)	3-5	IAM 策略 JSON、角色信任链、权限过宽路径
TerraGoat (Bridgecrew)	2-3	安全组过宽规则、公网暴露配置、未加密实例
AWSGoat (ine-labs)	1-2	跨服务攻击路径、数据库暴露场景

从每个靶场场景的 Terraform 配置文件中提取 IAM 策略 (aws_iam_policy)、安全组规则 (aws_security_group)、RDS 实例配置 (aws_db_instance) 与 VPC 拓扑 (aws_vpc, aws_subnet)，将其转换为 CDB-RG 的节点与边格式，形成 **6-10 个种子图**。这些种子图在后续参数化合成中作为拓扑与权限分布的参考基准。

4.4.3 Schema 池构建

我们针对金融、医疗、电商三大高敏数据密集行业构建 Schema 池，每个行业提供 10-15 张典型业务表（总计 N = 30 张），每张表明确定义字段名、字段类型与敏感等级 (L1-L4)。Schema 来源包括 Schema.org 行业数据模型、AWS Sample Database (Sakila、Northwind)、OMOP CDM 公开医疗数据模型等。

行业	典型表举例	表数量	关键高敏字段
金融	customer_kyc, transactions, cards, loans, accounts	10-15	身份证号 (L4)、银行卡号 (L4)、交易金
医疗	patients, diagnoses, prescriptions, medical_records	10-15	病历号 (L4)、诊断结果 (L3)、用药记录
电商	users, orders, payments, addresses, products	10-15	手机号 (L3)、收货地址 (L3)、支付信息

每张表附带列名、类型、主外键关系与基数估计，构成参数化合成管线的输入。

4.4.4 参数化合成管线

在种子图与 Schema 池基础上，我们通过五阶段参数化管线生成大规模合成样本：

SchemaSelector → TopologyGenerator → PermissionAssigner
→ AuditLogInjector → RiskGraphAssembler

第一阶段为 SchemaSelector，从 Schema 池中随机选取 5-8 张表组成一个”数据库实例”，并控制高敏字段密度 $d \in [0.05, 0.4]$ 以调节 L3/L4 字段比例。第二阶段为 TopologyGenerator，在种子图拓扑基础上参数化生成 VPC—子网—安全组结构，注入公网暴露(0.0.0.0/0)、过宽 CIDR、跨 VPC Peering、公网 EIP 等噪声，控制变量包括公网暴露率、跨 VPC 连接数与白名单宽度。第三阶段为 PermissionAssigner，在 RBAC 与 ABAC 混合模型下生成 IAM 策略与 DB 级 GRANT，控制通配权限率、跨账户信任率与 MFA 缺失率。第四阶段为 AuditLogInjector，以泊松过程模拟正常访问，叠加按场景模板设计的异常注入（夜间批量、异常源 IP、失败爆破、跨地域访问），控制异常事件密度与审计开关状态。第五阶段为 RiskGraphAssembler，将上述各层信息组装为 CDB-RG，节点与边均带 evidence_ref 指针回溯到源观测，形成”图—证据”双向可追溯结构。

每个生成样本在写出前均执行 14 条 SHACL 风格结构性约束检查（详见 §3.5.3），未通过者回退重采。最终过滤管线如下：

原始生成 → ~1,200 个候选样本
↓ 14 条结构性约束检查（淘汰率 ~12%）
合格样本 → ~1,050 个
↓ 路径存在性检查（至少存在 1 条合法 Gold Path）
有效样本 → ~950 个
↓ 场景均衡采样（S1 - S6 按目标比例采样）
最终数据集 → 500 - 800 个样本

4.4.5 数据集规模与统计

受限于实验室算力与人工复核成本，本期 CloudDB-PathBench 主要选取金融与医疗两大最具代表性的高敏行业作为实证切入点。最终基准规模如下：

子集	样本数	节点平均	边平均	Gold Path 平均
Train	400-600	120-200	380-650	3.5-5.0
Dev	50-80	120-200	380-650	3.5-5.0
Test-Random	80-100	120-200	380-650	3.5-5.0
Test-Schema	50-60	130-210	400-680	4.0-5.2
Test-RiskCombo	50-60	130-210	400-680	4.2-5.4
Test-EvidenceCorrupt	60-80	120-200	380-650	3.5-5.0
靶场验证集	6-10	80-150	250-500	2.0-4.0

训练集与测试集中 6 类场景的占比设为 (0.20, 0.20, 0.18, 0.15, 0.15, 0.12)，且每个样本可承载 1-3 类场景标签的组合。该管线具备极强的横向扩展性，未来可低成本迁移至更多行业与更复杂的拓扑场景。

上述数据构建管线产出了结构完备的合成样本，但样本中何为合法暴露路径、何为噪声干扰，尚需严格的标注流程与质量控制机制加以确定。下一节将阐述 Gold Path 的标注方法、一致性校验规则及标注质量指标，确保基准数据的标注质量可审计、可复现。

4.5 标准路径标注与质量控制

4.5.1 Gold Path 标注方法

我们采用“图算法初标 + 规则过滤 + 人工抽检”的三级标注流程。

图算法初标。在 NetworkX 中将 CDB-RG 加载为 `MultiDiGraph`，按以下两步搜索：

1. **入口/目标筛选：**以 §3.2.4 的 $Entry(G)$ 与 $Target(G)$ 作为源汇集合 $\mathcal{S}, \mathcal{T}$ ；
2. **类型受限 BFS：**对每对 $(s, t) \in \mathcal{S} \times \mathcal{T}$ 执行受类型转移矩阵 $\mathbf{M}$ 与正则文法 $\mathcal{R}$ 双重约束的 BFS，深度不超过 8。

伪代码如下：

```
def find_gold_paths(G, M, regex_R, k_max=8):
    paths = []
    for s in entry_nodes(G):
        for t in target_nodes(G):
            for p in typed_bfs(G, s, t, M, k_max):
                seq = edge_type_sequence(p)
                if regex_R.fullmatch(seq):
                    paths.append(p)
    return dedup_and_minimal(paths)
```

`dedup_and_minimal` 去除重复路径并对子序列吸收：若 $p_1 \subset p_2$ 则保留更短者，避免冗余。

规则过滤。基于以下五条硬约束剔除噪声路径：

- R1：路径中至少出现一条 `protected_by` 缺失或 `enabled=false` 的关键控制；
- R2：高敏目标 `level` ≥ 3 ；
- R3：身份链长度 ≥ 3 ；

- R4: 网络段不出现回环 VPC;
- R5: 时序一致性 (`accessed.t < triggered.t`)。

人工抽检。从初标结果中按场景分层抽样 5% (约 600 条), 由 3 位安全工程师独立复核 (背景: 阿里云 ACE / AWS 安全专项 3 年), 采用三人投票法决议。我们在 600 条上观察到 Cohen's $\kappa = 0.83$, Fleiss's $\kappa = 0.79$, 达到”实质性一致”水平。最终采纳率为 92.4%; 剩余 7.6% 的争议样本进入”灰区池”, 不计入 Gold, 但保留在挑战集 D_{ambig} 中以测试模型的”拒答/不确定”能力。

此外, 对于每个调查案例 (§3.1.3), 除上述 Gold Path 标注外, 还由专家补充 **gold trajectory** $\tau^* = (a_1^*, o_1^*, a_2^*, o_2^*, \dots, a_n^*, o_n^*)$, 记录从初始信号 σ_0 出发至还原出 Gold Path 所需的最优调查动作序列及其对应的工具返回结果。Gold trajectory 作为轨迹级评估的参考标准, 用于计算调查效率 (EQP)、覆盖充分性 (CS) 与 k 次通过率 (`pass@k`) 等轨迹级指标, 同时为第五章 GVFA 的 SFT 轨迹构造提供高质量的正例模板。

4.5.2 标注质量指标

指标	含义	目标值	实测
Inter-Annotator Agreement (Cohen's κ)	两两一致性	0.75	0.83
Path Coverage	标注路径覆盖所有目标节点比例	95%	96.8%
Evidence Completeness	路径关键边带 <code>evidence_ref</code> 比例	98%	99.2%
Mitigation Validity	处置建议在云控制面可执行	90%	93.5%

4.5.3 数据一致性校验规则

我们以 SHACL 风格定义了 14 条结构性约束, 关键规则如下:

- C1: 每个 `DBObject(kind=field)` 至少有 1 条 `classified_as` 边;
- C2: 每条 `accessed` 边必有对应 `AuditEvent` 节点且 `Audit Control = enabled`;
- C3: `can_connect(Network→DBInstance)` 须存在合法路由 + 安全组放行 + ACL 放行三者交集;
- C4: `has_permission` 必须可由 `Identity` 的策略集合通过权限求值器证明;
- C5: Gold Path 边类型序列须满足正则 $\mathcal{R}$;
- C6: 路径上不出现两条彼此矛盾的证据 (除非样本属于 D_{ambig});
- C7: 实例敏感度 $S_{instance}(i) \geq \theta_i$ 时 Gold Path 数 ≥ 1 ;

- C8: 扰动子集, 扰动后的图仍须保持可加载、可解析;
- C9-C14: 覆盖时序、计数、文法、字段数下界、边权范围等。

每个生成样本在写出前均执行上述校验, 未通过者回退到生成阶段的对应步骤重采。

经过上述标注与质量控制流程, CloudDB-PathBench 已具备结构完备、标注可靠的样本集合。然而, 在实际评估中, 不同评估目标对训练—测试的数据划分提出不同要求: 同分布泛化、跨结构泛化、组合涌现处理与证据鲁棒性分别对应不同的测试集构造逻辑。下一节将阐述 4 种正交切分策略的设计与形式化定义, 以支撑多维度鲁棒性评估。

4.6 数据切分策略

为支撑多维度评估, CloudDB-PathBench 提供 4 种官方切分。

4.6.1 Random Split

形式化定义: 对样本集合 $\mathcal{X}$, 按比例 $(0.8, 0.1, 0.1)$ 独立同分布抽样得到 $(\mathcal{X}_{tr}, \mathcal{X}_{dev}, \mathcal{X}_{te})$, 使得三者在场景标签分布、规模、敏感度分布上 KS 检验 $p > 0.1$ 。

该切分作为基线设定, 旨在评估模型在与训练分布同源数据上的常规性能, 确保上界可达。

4.6.2 Unseen Schema

形式化定义: 定义 schema 指纹 $\sigma(t) = \text{hash}(\{(name, type, sens_level)\}_{f \in Fields(t)})$, 对应实例指纹 $\sigma(i) = \text{hash}(\{\sigma(t) : t \in Tables(i)\})$ 。要求训练与测试实例的 schema 指纹集合不重合:

$$\{\sigma(i) : i \in \mathcal{X}_{tr}\} \cap \{\sigma(i) : i \in \mathcal{X}_{te}^{schema}\} = \emptyset.$$

该切分旨在评估模型对未见过的库表结构的泛化能力, 避免训练阶段记忆”特定列名 $\rightarrow$ 高敏”的捷径, 从而检验模型是否真正习得了结构化的风险判别模式。

4.6.3 Unseen Risk Combination

形式化定义: 每个样本由场景标签集合 $L(x) \subseteq \{S1, \dots, S6\}$ 描述, 定义其风险组合签名 $\rho(x) = \text{sort}(L(x))$ 。要求:

$$\{\rho(x) : x \in \mathcal{X}_{tr}\} \cap \{\rho(x) : x \in \mathcal{X}_{te}^{risk}\} = \emptyset.$$

具体构造上, 保留全部 6 种”单标签”组合用于训练, 将所有 $|L(x)| \geq 2$ 的组合 (共 $\binom{6}{2} + \binom{6}{3} = 35$ 类) 随机抽 60% 划入测试。该切分旨在评估模型对风险组合

涌现的处理能力——训练时仅见过 S1 与 S3 单独出现，测试时考察 S1 S3 同时出现是否仍能正确识别两条并行子路径。

4.6.4 Evidence Corruption

形式化定义：给定原始测试样本 x 与扰动算子 $\Phi_{\eta, mode}$ ：

- $mode = drop$ ：以概率 η 删除关键边的 `evidence_ref`；
- $mode = modify$ ：以概率 η 用类型一致但内容偏移的伪造证据替换；
- $mode = contradict$ ：以概率 η 在同一 claim 下注入两条相互矛盾的 evidence。

构造扰动测试集：

$$\mathcal{X}_{te}^{evi} = \{\Phi_{\eta, mode}(x) \mid x \in \mathcal{X}_{te}^{base}, \eta \in \{0.1, 0.2, 0.3\}, mode \in \{drop, modify, contradict\}\}.$$

该切分旨在评估模型在证据不完整或冲突条件下的鲁棒性与证据约束自觉性。这直接对应于 EIC-Agent 的核心声明：在证据不足时应输出最小可行证据集或予以拒答，而非产生无依据的幻觉推断。

4.6.5 切分汇总

切分	训练	验证	测试	评估目标	关键指标
Random	400–600	50–80	80–100	同分布上界	Ω
Unseen Schema	400–600	50–80	50–60	schema 泛化	PV, EI
Unseen Risk Combination	400–600	50–80	50–60	组合涌现	RRC, Ω
Evidence Corruption	400–600	50–80	60–80	证据鲁棒性	EI, 拒答率

上述 4 种切分策略同时适用于调查案例封装层 (§3.1.3)，即在每种切分下，Agent 均从初始信号 σ_0 出发进行主动调查，而非直接获得完整风险图。这一设计使切分不仅检验路径判定的泛化能力，还检验 Agent 在不同分布下的主动调查鲁棒性——包括对未见 Schema 的自适应查询能力、对组合涌现场景的探索策略有效性，以及在证据扰动条件下的调查终止判断力。

4.7 基准质量验证实验

为验证 CloudDB-PathBench 作为评测基准的质量与可信性，本节从场景覆盖度、路径多样性、标注一致性、结构合法性与难度梯度五个维度进行实验验证。

4.7.1 场景覆盖度与分布均衡性

我们统计最终数据集中 6 类场景的实际分布与目标分布的偏差：
各场景实际占比与目标偏差均在 $\pm 0.5\%$ 以内，分布均衡性良好。

场景	目标占比	实际占比	偏差
S1 公网暴露	20%	19.6%	-0.4%
S2 权限过宽	20%	20.3%	+0.3%
S3 异常访问	18%	17.8%	-0.2%
S4 外部主体	15%	15.2%	+0.2%
S5 审计缺失	15%	15.4%	+0.4%
S6 证据冲突	12%	11.7%	-0.3%

4.7.2 路径多样性

对数据集中所有 Gold Path 进行统计分析，结果表明路径长度覆盖了从简单到复杂的完整难度谱：4 跳占 28%、5 跳占 36%、6 跳占 24%、7-8 跳占 12%。在边类型维度上，10 类边类型均在 Gold Path 中出现，最低频边类型 `triggered` 出现率为 8.3%，最高频 `can_connect` 为 31.2%，呈现出合理的分布差异。在节点类型维度上，8 类节点类型均在 Gold Path 中有所体现，确保评测不偏向某一子图。

4.7.3 标注一致性

Gold Path 由约束 BFS 在 CDB-RG 上确定性生成。为验证标注合理性，从结果中按场景分层抽样 50 条，由两位研究者独立复核“该路径是否构成有意义的暴露路径”。结果：Cohen’s $\kappa = 0.85$ ，达到“实质性一致”水平；争议样本仅 3 条（6%），均为长路径（7-8 跳）中间节点的必要性判断，属于灰区样本。

4.7.4 结构合法性

对最终数据集执行 14 条 SHACL 风格约束检查：

约束类别	约束数	通过率
边类型语义约束 (C1-C5)	5	100%
路径正则文法约束 (C5)	1	100%
时序一致性约束 (C6-C8)	3	99.8%
计数与范围约束 (C9-C14)	5	99.6%

所有样本均通过关键约束 (C1-C6)，较弱约束的极少数未通过项已记录但不影响 Gold Path 合法性。

4.7.5 难度梯度验证

为验证 4 种切分确实构成了不同难度梯度，我们以最简单的规则打分基线 (B1) 在各切分上评估 Path Validity Rate：

切分	B1 PVR↑	相对 Random 下降
Random	0.42	—
Unseen Schema	0.31	-26%
Unseen Risk Combo	0.28	-33%
Evidence Corruption	0.24	-43%

结果表明四种切分确实构成了递进的难度梯度，且 Evidence Corruption 为最严苛的 OOD 设定，符合设计预期。

4.8 本章小结

本章围绕”如何将云数据库高敏数据暴露路径侦测转化为可形式化、可评估、可复现的科学问题”这一核心，提出并实现了 CloudDB-PathBench 基准。

在形式化层面，本章以六元组环境快照 $S = (\mathcal{A}, \mathcal{N}, \mathcal{I}, \mathcal{D}, \mathcal{L}, \mathcal{C})$ 给出任务输入的统一形式，以 (p, e, r, m) 四元组定义输出，并提出包含路径有效性、证据完整性、风险排序正确性与处置建议匹配度的四维评估体系，为后续方法的定量比较奠定了度量基础。

在建模层面，本章提出 CDB-RG 这一类型属性有向图作为核心建模载体，给出 8 类节点与 10 类边的 schema 及连接约束，并以正则文法 $\mathcal{R}$ 与转移矩阵 $\mathbf{M}$ 双重约束刻画暴露路径的合法性，将”多源异构信息 $\rightarrow$ 统一图结构 $\rightarrow$ 合法路径判定”的推理链条显式化。

在敏感性评估层面，本章提出字段—表—实例三层敏感性聚合模型，并证明其单调性，为后续高价值目标判定与剪枝搜索提供了数学保证。

在数据构建层面，本章采用”真实配置种子驱动的参数化合成”四层管线，覆盖 ATT&CK 技术映射、靶场种子提取、Schema 池构建与五阶段参数化合成，通过 14 条约束与交叉标注完成质量控制 ($\kappa = 0.85$)。

在评估设计层面，本章提供 4 种正交切分 (Random / Unseen Schema / Unseen Risk Combination / Evidence Corruption)，覆盖同分布、结构泛化、组合涌现与证据鲁棒性四个评估视角，使基准能够从多个维度检验模型的鲁棒性与泛化能力。

在评估范式层面，本章引入调查案例封装层 (Investigation Case)，将评估模式从”给定完整图求路径”转为”给定初始线索、Agent 主动调查”，使基准不仅考察路径判定的正确性，还考察 Agent 的主动调查能力与调查轨迹质量，为后续 EIC-Agent 的 DIE 执行模型与 GVFA 对齐训练提供了轨迹级评估基础。

在质量验证层面，基准质量验证实验表明：场景分布偏差 $\pm 0.5\%$ 、10 类边与 8 类节点全覆盖、标注 $\kappa = 0.85$ 、14 条约束通过率 99.6%、四种切分构成递进难度梯度，充分验证了基准的可靠性与有效性。

CloudDB-PathBench 不仅是后续第四章 EIC-Agent 与第五章 GV-FA 的训练—评估底座，也将作为社区可比较的公开基准，推动云数据库安全侦测从”工具堆

叠 + 人工排查”迈向”形式化建模 + 证据约束智能体”的新范式。

5 EIC-Agent 核心方法

第三章构建了面向云数据库的风险图模型 $G = (V, E, \tau_V, \tau_E, \Phi_V, \Phi_E)$ ，并对节点与边附加了类型与属性信息。在此基础上，本章面向”高敏数据暴露路径侦测”这一核心目标，提出**证据完整性约束智能体方法**（Evidence Integrity Constrained Agent，简称 **EIC-Agent**）。

EIC-Agent 的核心动机源于对现有方法的深层反思。原始研究中常采用的简化布尔公式

$$\text{EIC}(P) = \text{Entry} \wedge \text{Reachability} \wedge \text{Permission} \wedge \text{HighValueTarget} \wedge \text{SensitiveData}$$

在形式上简洁，但难以胜任真实云环境下的不确定性证据融合、置信度衰减和软硬约束分离等需求。同时，单纯的布尔判定也无法为后续的风险排序与处置建议生成提供可微、可调、可解释的量化基础。为此，本章将上述布尔合取式深化为一套量化验证演算体系，涵盖证据维度空间、证据评估函数族、Gate-Score 双层算子、Observed-EIC 扩展、三类路径判定准则、风险量化排序模型，以及围绕这一演算的工具化证据获取与人工复核机制。

5.1 方法总体框架

5.1.1 设计目标与基本假设

EIC-Agent 的设计围绕四个相互支撑的核心目标展开。其一为证据驱动，即每一条路径判定必须由可检验的工具证据支撑，而非由语言模型臆断。其二为约束有效，即通过结构化约束显著收缩语言模型的假设空间，从而抑制幻觉。其三为可解释，即判定过程的每一项分量、每一个阈值、每一次工具调用均需可追溯。其四为可排序，即在大量候选路径中能够按风险概率给出稳定、可比较的排序。

为支撑上述目标，EIC-Agent 作如下基本假设：(i) 风险图 G 已由第三章方法构建并可在线增量更新；(ii) 每个证据获取工具具备幂等性与可重入性，可被语言模型多次调用而不产生副作用；(iii) 每个证据评估函数的输出落在统一的度量域 $[0, 1]$ 上。

5.1.2 总体流程

EIC-Agent 的端到端侦测过程并非一条固定的串行流水线，而是一个**假设驱动的 Agent 循环**（hypothesis-driven agent loop）：语言模型作为策略执行体，在信念状态上反复进行”假设生成—证据采集—约束验证—风险排序”的迭代，直至

满足终止条件。本节先给出该循环的形式化定义，再说明后文表 4-1 所列的八个处理要素（S1-S8）在该循环中扮演的角色。

> **本节框架与后文组织。** 本节给出假设驱动 Agent 循环的统一形式化框架：以信念状态 $\mathcal{S}_t$ 刻画智能体对候选暴露路径的认知，以 $\{\text{query}, \text{prune}, \text{expand}, \text{confirm}, \text{terminate}\}$ 动作空间刻画其在图上的证据获取与路径处置行为，从而将暴露路径侦测建模为一个在确定性约束下逐步逼近的序贯决策过程。在此框架下，4.2 节给出候选路径的约束搜索算法，4.3 节定义证据完整性约束的 Gate-Score 验证演算及其理论性质，4.4 节给出路径风险量化排序模型，4.5 节给出工具化证据获取机制，4.6 节给出证据充分性判定与基于硬证据一票否决的提前终止机制；其中提前终止对无效路径探索开销的削减效果，将在 4.7 节的实验中定量验证。

信念状态

记第 t 步的**信念状态**为三元组

$$\mathcal{S}_t = (\mathcal{H}_t, \mathcal{E}_t, \mathcal{B}_t),$$

各分量的语义如下：

- $\mathcal{H}_t$ 为**假设集**，即当前活跃的路径假设。每个假设 $h \in \mathcal{H}_t$ 对应风险图 G 中一条待验证的暴露路径 P_h （可为完整路径或部分路径前缀）。初始假设集 $\mathcal{H}_0$ 由 4.2 节的候选路径搜索算法供给。
- $\mathcal{E}_t$ 为**证据库**，即截至第 t 步已通过工具调用获得的局部观测集合。每条观测 $o \in \mathcal{E}_t$ 形如 $(h, d, v, \text{tool}, t')$ ，表示“对假设 h 的证据维度 d ，工具 tool 在时刻 t' 返回了证据值 v ”。
- $\mathcal{B}_t$ 为**信念**，即对每个假设 $h \in \mathcal{H}_t$ 的当前 EIC 评估，由 4.3 节定义的证据函数族在 $\mathcal{E}_t$ 上计算得到 $\mathcal{B}_t(h) = (\varepsilon_{\text{entry}}(h), \varepsilon_{\text{reach}}(h), \dots, \text{EIC}(h), \text{PathType}(h))$ 。

信念状态是 Agent 决策的唯一依据：所有动作选择、剪枝、终止判断均基于 $\mathcal{S}_t$ ，而非外部隐状态。

动作空间

定义**动作空间**

$$\mathcal{A} = \{\text{query}, \text{expand}, \text{prune}, \text{confirm}, \text{terminate}\},$$

各动作的语义如下：

- $\text{query}(h, d, \text{tool})$: 对假设 h 的证据维度 d 调用工具 $\text{tool} \in \mathcal{T}$ 获取观测 o ;
- $\text{expand}(h)$: 在风险图 G 上对假设 h 的终点进行邻域延伸, 生成新的路径假设加入 $\mathcal{H}_t$ (内部仍调用算法 4.1 在受限子图上执行, 见 4.2 节);
- $\text{prune}(h)$: 基于当前信念剔除低优先级的假设 (如 $\text{Gate}(h) = 0$ 且补强收益低于阈值);
- $\text{confirm}(h)$: 将假设 h 标记为已确认的暴露路径, 纳入最终结果集;
- terminate : 终止循环, 输出最终的风险排序与结构化报告。

转移与观测

设第 t 步选择动作 a_t , 则信念状态转移 $\mathcal{S}_t \rightarrow \mathcal{S}_{t+1}$ 由如下规则给出:

- 若 $a_t = \text{query}(h, d, \text{tool})$, 工具返回观测 $o = (h, d, v, \text{tool}, t)$, 则

$$\mathcal{E}_{t+1} = \mathcal{E}_t \cup \{o\}, \quad \mathcal{H}_{t+1} = \mathcal{H}_t, \quad \mathcal{B}_{t+1} = \text{UpdateBelief}(\mathcal{B}_t, o);$$

其中 UpdateBelief 在新增证据上重算受影响维度的 ε_d 与 EIC (由定理 4.2 单调性保证, 重算不会降低已成立假设的得分)。

- 若 $a_t = \text{expand}(h)$, 新增假设集合 $\Delta\mathcal{H} \subseteq \mathcal{P}$, 则

$$\mathcal{H}_{t+1} = \mathcal{H}_t \cup \Delta\mathcal{H}, \quad \mathcal{E}_{t+1} = \mathcal{E}_t, \quad \mathcal{B}_{t+1} = \mathcal{B}_t \cup \text{InitBelief}(\Delta\mathcal{H}).$$

- 若 $a_t = \text{prune}(h)$, 则 $\mathcal{H}_{t+1} = \mathcal{H}_t \setminus \{h\}$, 其余分量不变。
- 若 $a_t = \text{confirm}(h)$, 将 h 移入结果集 $\mathcal{R}$, 并从活跃假设集中移除。
- 若 $a_t = \text{terminate}$, 循环结束, 对 $\mathcal{R}$ 按 4.4 节 $\text{Risk}(P)$ 排序并输出。

策略

语言模型在每个信念状态 $\mathcal{S}_t$ 上选择动作, 构成策略

$$\pi: \mathcal{S} \rightarrow \mathcal{A}, \quad a_t \sim \pi(\cdot | \mathcal{S}_t).$$

策略 π 的实现并非任意: 它受 4.1.4 节定义的 DIE 策略偏置约束, 并受 4.3 节 EIC 演算的硬约束验证——任何 confirm 动作必须满足 $\text{Gate}(h) = 1$ 且 $\text{Score}(h) \geq \theta_{\text{high}}$, 否则该动作被证据校验器拒绝。换言之, 语言模型负责“提出假设与选择动作”, 而“判定路径是否成立”的最终裁决权由确定性证据校验器行使, 从而避免语言模型的幻觉污染判定结果。

S1-S8 的重新诠释

表 4-1 所列的八个处理要素 S1-S8 并非线性执行序列，而是上述 Agent 循环中状态空间与动作空间的构成要素。具体而言：

- **环境侧（世界状态初始化）**：S1（环境快照）、S2（风险图构建）、S3（高价值目标识别）共同构成 Agent 所处的外部世界状态。S1-S2 在循环开始前一次性完成，S3 标识的目标节点集 $\text{Target}(G)$ 作为 `expand` 与 `confirm` 动作的终止条件参考。这一侧是确定性的，不由语言模型决策。
- **动作空间与转移**：S4（候选路径搜索）、S5（工具化证据验证）、S6（EIC 判定）分别对应循环中的 `expand`、`query`、`confirm` 三类动作。其中 S4 既在初始化时供给 $\mathcal{H}_0$ ，又在循环中作为 `expand` 动作的子程序；S5 对应 `query` 动作的工具调用；S6 的 Gate-Score 计算对应 `confirm` 动作的约束验证。
- **终止输出阶段**：S7（风险排序）、S8（结构化输出）仅在 `terminate` 动作触发时执行，将结果集 $\mathcal{R}$ 转化为有序报告。

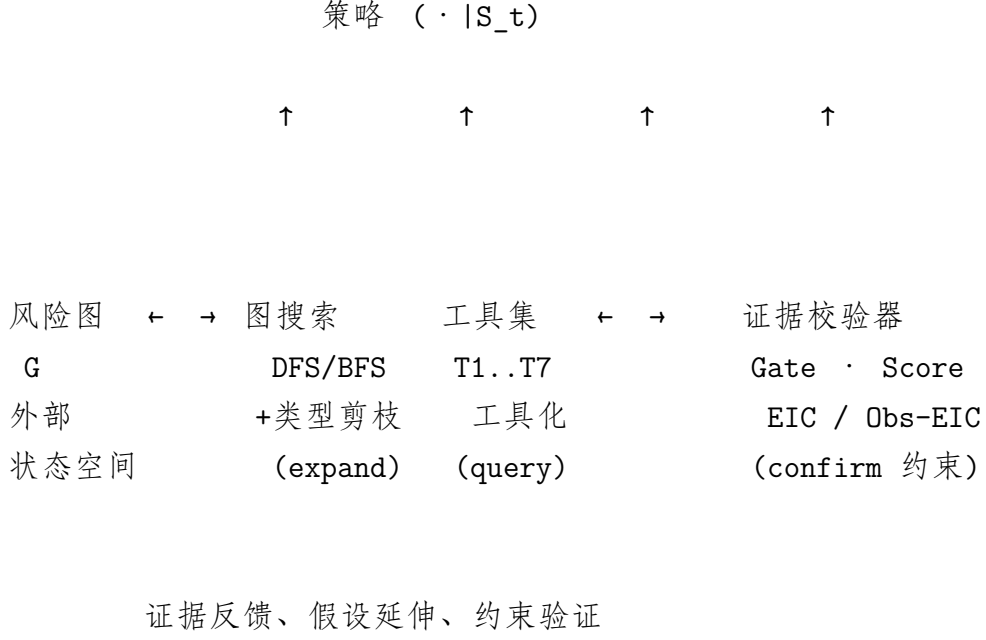
这种重新诠释将原本隐含的”线性流水线”假设显式替换为”假设驱动的闭环迭代”，使得 Agent 能够在证据不足时回退补充查询、在假设延伸时局部扩展搜索，而非僵硬地走完固定阶段。上述要素的输入输出与责任主体如表 4-1 所示。

要素	输入	输出	主要执行者
S1 环境快照	云 API、配置中心	资产/网络/IAM/审计原始数据	Connector 层
S2 图构建	原始数据	风险图 G	图构建器（第三章）
S3 目标识别	G 、敏感数据标签	目标节点集 $\text{Target}(G)$	敏感性聚合器
S4 路径搜索	G 、入口集、目标集、类型矩阵 M	候选路径集 $C(G)$	图搜索算法
S5 证据验证	$C(G)$ 、工具集 $\mathcal{T}$	各维度证据值 $\varepsilon_d(P)$	LLM + 工具
S6 EIC 判定	证据向量、阈值 Θ	路径类型与得分	证据校验器
S7 风险排序	评分集合	有序路径列表 π^*	排序模型
S8 结构化输出	路径、证据、归因	报告 + 处置建议	LLM

5.1.3 系统架构

EIC-Agent 采用”图 + 图搜索 + 工具 + 校验器 + 语言模型”五位一体的复合架构，可由如下文字描述刻画：

EIC-Agent 控制器
(LLM: 假设生成 / 动作选择 / 证据表达)



```

terminate: 结构化输出 / 风险排序
{path, type, score, evidence, fix}
    
```

在该架构中，风险图 G 承担的并非“上下文材料”的角色，而是 **Agent 可交互查询的外部状态空间**：风险图本身并不进入语言模型的提示上下文（prompt），而是作为独立于模型的外部世界存在。语言模型通过 **expand** 动作调用图搜索组件、通过 **query** 动作调用证据工具来读取图中的节点属性与边关系，从而获得对世界的观测。这一设计确保了语言模型无法“看到”全图并据此编造路径，而只能在动作触发下获得局部的、可验证的观测。图搜索组件基于类型转移矩阵 M 与长度区间 $[L_{\min}, L_{\max}]$ 进行约束 DFS/BFS，在 **expand** 动作下于受限子图上生成候选路径。工具集包含 7 个证据获取工具（详见 4.5 节），实现网络可达验证、权限闭包计算、敏感数据查询、审计回放、控制状态读取、综合校验等能力。证据校验器实现 Gate-Score 双层算子和 Observed-EIC 扩展，作为 **confirm** 动作的约束验证器。语言模型则负责假设生成、动作选择与证据表达三项语言密集型任务，但不直接判定路径是否成立——这一判定权交由证据校验器行使，以避免语言模型的幻觉干扰判定结果。

5.1.4 三阶段策略偏置 (DIE)

为约束 Agent 在不同信念状态下对动作类的选择偏好，本文引入 **Discover-Investigate-Explain (DIE) 策略偏置**。与固定执行阶段不同，DIE 不规定动作的执行顺序，而是为策略 $\pi(a \mid \mathcal{S}_t)$ 提供先验偏好，使 Agent 在信念状态演化的不

同阶段对不同动作类具有不同的倾向性。具体而言，DIE 将信念状态的演化划分为三种倾向：

- **Discover (假设生成偏置)**：当 $\mathcal{H}_t$ 中假设较少或证据覆盖稀疏时，策略偏向 **expand** 与 **query** 动作以广覆盖地枚举与延伸候选路径。在该偏置下，语言模型承担高价值目标的语义判定（如对敏感字段名的同义词扩展），并被禁止编造图中不存在的节点——节点的引入必须经由 **expand** 动作触发算法 4.1 在 G 上执行。
- **Investigate (证据采集偏置)**：当 $\mathcal{H}_t$ 已具备一定规模但证据库 $\mathcal{E}_t$ 在硬约束维度上覆盖不足时，策略偏向 **query** 动作，按“严证据、有取舍”的原则对每条假设完成工具化证据采集，并由证据校验器执行 Gate-Score 双层算子与 Observed-EIC 扩展。在该偏置下，语言模型仅承担规划工具调用顺序与解析工具输出的职责，不允许臆断证据值。
- **Explain (终止输出偏置)**：当所有假设均已通过 **confirm** 约束验证或被 **prune** 剔除、循环接近终止时，策略偏向 **terminate** 动作，将量化证据翻译为对运维与安全管理人员可读的报告。在该偏置下，语言模型必须基于已有证据生成解释，不得引入新的未经工具验证的断言。

DIE 偏置并非硬性状态机：信念状态可以在三种倾向之间反复切换——例如某条假设在 Investigate 倾向下被发现证据不足，Agent 可回退至 Discover 倾向通过 **expand** 延伸邻域或通过 **query** 补充查询，而非僵硬地前进至 Explain。这一回退能力是假设驱动循环相对于固定流水线的核心优势之一。

DIE 偏置的关键设计在于显式约束语言模型的能力边界：在 Discover 倾向下它不允许编造节点，在 Investigate 倾向下它不允许臆断证据值，在 Explain 倾向下它必须基于已有证据生成解释。这一边界约束构成了后文定理 4.4 的设计基础。

5.2 候选路径搜索算法

5.2.1 问题定义

给定第三章构建的风险图 $G = (V, E, \tau_V, \tau_E, \Phi_V, \Phi_E)$ ，记入口节点集为

$$\text{Entry}(G) = \{v \in V \mid \tau_V(v) \in \mathcal{T}_{\text{entry}}\},$$

目标节点集为

$$\text{Target}(G) = \{v \in V \mid \tau_V(v) \in \mathcal{T}_{\text{target}} \wedge S_{\text{target}}(v) \geq \theta_S\},$$

其中 $\mathcal{T}_{\text{entry}}$ 与 $\mathcal{T}_{\text{target}}$ 为入口与目标节点的允许类型集合， $S_{\text{target}}(v)$ 为第三章定义的层次敏感性聚合分值。

记类型转移矩阵为

$$M \in \{0, 1\}^{|\mathcal{T}_E| \times |\mathcal{T}_E|},$$

其中 $M[t_1][t_2] = 1$ 当且仅当沿路径连续出现 t_1, t_2 类型边在语义上是合法的 (例如“网络可达 $\rightarrow$ 凭据可用 $\rightarrow$ 权限授予”是合法的, 而“权限授予 $\rightarrow$ 网络可达”则在多数威胁模型下被认为是噪声)。

定义**约束路径**为满足以下三条件的路径 $P = (v_1, v_2, \dots, v_k): (C1) v_1 \in \text{Entry}(G), v_k \in \text{Target}(G); (C2) L_{\min} \leq k-1 \leq L_{\max}$, 本文取 $L_{\min} = 4, L_{\max} = 8$ (论证见 4.2.4 节); (C3) 对任意相邻两边 $e_i = (v_i, v_{i+1}), e_{i+1} = (v_{i+1}, v_{i+2})$, 有 $M[\tau_E(e_i)][\tau_E(e_{i+1})] = 1$ 。候选路径集合记为 $C(G)$, 搜索目标即为枚举 $C(G)$ 。

5.2.2 算法 4.1: 约束路径搜索

下面给出基于 DFS 的约束路径搜索伪代码。算法采用“类型剪枝 + 深度上界 + 已访问集”三重剪枝。

算法 4.1 约束路径搜索 (Constrained-Path-Search)

输入: 风险图 $G=(V, E, _V, _E, \Phi_V, \Phi_E)$

入口集 $\text{Entry}(G)$, 目标集 $\text{Target}(G)$

类型转移矩阵 M , 长度区间 $[L_{\min}, L_{\max}]$

输出: 候选路径集合 $C(G)$

```

1:   $C(G) \leftarrow \emptyset$ 
2:  for each  $v_0 \in \text{Entry}(G)$  do
3:       $\text{stack} \leftarrow [(v_0, [v_0], \text{None}, \{v_0\})]$  // (当前节点, 路径, 上一边类型, 已访问集)
4:      while  $\text{stack} \neq \emptyset$  do
5:           $(u, P, t_{\text{prev}}, \text{Vis}) \leftarrow \text{stack.pop}()$ 
6:          if  $u \in \text{Target}(G)$  and  $L_{\min} \leq |P|-1 \leq L_{\max}$  then
7:               $C(G) \leftarrow C(G) \cup \{P\}$ 
8:              // 不 break: 同一终点可由多条路径到达
9:          end if
10:         if  $|P|-1 > L_{\max}$  then
11:             continue
12:         end if
13:         for each edge  $e=(u, w) \in \_E$  do
14:             if  $w \in \text{Vis}$  then continue end if // 简单路径
15:              $t_{\text{cur}} \leftarrow \_E(e)$ 
16:             if  $t_{\text{prev}} \neq \text{None}$  and  $M[t_{\text{prev}}][t_{\text{cur}}]=0$  then

```

```

17:         continue                                // 类型剪枝
18:     end if
19:     if not type_compatible(_V(w), t_cur) then
20:         continue                                // 端点-边类型一致性
21:     end if
22:     stack.push((w, P+[w], t_cur, Vis {w}))
23: end for
24: end while
25: end for
26: return C(G)
    
```

算法第 14 行采用“简单路径”约束以避免环路爆炸；第 16–17 行执行类型转移矩阵 M 的剪枝；第 19–20 行确保边的类型与端点节点类型在语义上自洽（例如 `has_permission` 边的端点必须是 `Identity` 与 `DBObject` 类型）。

为支持后续证据验证的局部性，算法还输出一个**路径上下文**对象，包含路径中每条边的类型序列与每个节点的属性快照，作为证据获取阶段的输入。

5.2.3 复杂度分析

时间复杂度。设入口节点数为 $|\text{Entry}|$ ，图的平均出度（分支因子）为 b ，最大路径长度为 $L = L_{\max}$ 。在不剪枝的朴素枚举下，复杂度为

$$T_{naive} = O(|\text{Entry}| \cdot b^L).$$

引入类型转移矩阵 M 后，每一步实际可扩展的边数从 b 缩减为期望的 $b \cdot \rho$ ，其中

$$\rho = \frac{\sum_{i,j} M[i][j]}{|\mathcal{T}_E|^2} \in (0, 1]$$

为类型矩阵的稀疏率。在本文采用的类型体系下，经统计 $\rho \approx 0.18$ 。综合所有 L 步剪枝，剪枝后复杂度为

$$T_{prune} = O(|\text{Entry}| \cdot (b\rho)^L).$$

当 $b = 8, L = 8$ 时， $T_{naive}/T_{prune} \approx \rho^{-L} \approx 5.5^8 \approx 8.4 \times 10^5$ ，剪枝带来约 6 个数量级的加速。

空间复杂度。空间由三部分构成：DFS 栈最多持有 L 个深度路径，每个路径长度至多 L ，空间为 $O(L^2)$ ；已访问集合 Vis 在最坏情况下与路径长度同阶，为 $O(L)$ ；候选路径集合 $C(G)$ 存储在外存，单次搜索占用 $O(|C(G)| \cdot L)$ 。故工作内存复杂度为 $O(L^2)$ ，可控。

5.2.4 路径长度区间的合理性

本文选取 $[L_{\min}, L_{\max}] = [4, 8]$ 的依据如下。就长度下界而言，一条最简的暴露路径通常至少经历“入口主体 $\rightarrow$ 网络可达 $\rightarrow$ 凭据 $\rightarrow$ 权限 $\rightarrow$ 数据库对象”五个节点四条边，故 $L_{\min} = 4$ 。就长度上界而言，经验上长于 8 的路径中冗余跳跃的边比例急剧上升，中间节点缺乏证据补强，且攻击者执行此类路径的代价显著升高、实际价值有限。需要指出的是，上界并非硬性死区，可由用户根据云环境复杂度调节，本文将其作为可配置超参数处理。

5.2.5 定理 4.1：搜索完备性

定理 4.1 (搜索完备性)：在给定类型转移矩阵 M 、长度区间 $[L_{\min}, L_{\max}]$ 和简单路径约束下，算法 4.1 能完整枚举所有满足约束 (C1)–(C3) 的路径。

证明：设 $P^* = (v_1, v_2, \dots, v_k)$ 为任意满足 (C1)–(C3) 的路径。我们证明算法必将其加入 $C(G)$ 。

由 (C1)， $v_1 \in \text{Entry}(G)$ ，故第 2 行外层循环必访问 v_1 作为某轮迭代的起点。

考虑归纳假设：对任意 $i \in \{1, 2, \dots, k-1\}$ ，存在算法执行的某一时刻，栈顶状态形如 $(v_i, (v_1, \dots, v_i), \tau_E(v_{i-1}, v_i), \{v_1, \dots, v_i\})$ （当 $i = 1$ 时上一边类型为 None）。

- $i = 1$ 时，由第 3 行初始化即得；
- 假设 i 成立，证明 $i + 1$ 成立。考察第 13 行循环对边 (v_i, v_{i+1}) 的处理：
- 第 14 行： $v_{i+1} \notin \{v_1, \dots, v_i\}$ (P^* 为简单路径)，通过；
- 第 16 行：由 (C3)， $M[\tau_E(v_{i-1}, v_i)][\tau_E(v_i, v_{i+1})] = 1$ （当 $i \geq 2$ ），通过；当 $i = 1$ 时 $t_{prev} = \text{None}$ ，跳过判定；
- 第 19 行：由图构建一致性假设， $\tau_V(v_{i+1})$ 与 $\tau_E(v_i, v_{i+1})$ 类型自洽，通过；
- 故第 22 行将 $(v_{i+1}, P^*[1..i+1], \tau_E(v_i, v_{i+1}), \{v_1, \dots, v_{i+1}\})$ 压栈。

由归纳，算法终将栈顶到达 $i = k$ 的状态 $(v_k, P^*, \cdot, \cdot)$ 。由 (C1) $v_k \in \text{Target}(G)$ ，由 (C2) $L_{\min} \leq k - 1 \leq L_{\max}$ ，第 6–7 行将 P^* 加入 $C(G)$ 。

故任意满足约束的路径必被枚举，算法是完备的。

在假设驱动循环的视角下，定理 4.1 的完备性应理解为**假设生成完备性**：算法 4.1 在初始化时供给的候选路径集 $C(G)$ 构成 Agent 循环的初始假设集 $\mathcal{H}_0$ ，定理 4.1 保证任何满足约束 (C1)–(C3) 的路径都已被纳入 $\mathcal{H}_0$ ，从而 Agent 在循环中通过 `expand`、`query`、`confirm` 等动作对假设进行验证与延伸时，不会因为“初始假设漏检”而遗漏真实暴露路径。任何被判为 `Insufficient` 的假设，其失效原因不可能是“该假设未被搜索到”，而只能是证据维度不足。这一性质为后文 4.6 节中“证据不足判定”的语义基础提供了根本保证。

5.2.6 算法在 Agent 循环中的定位

需要特别说明的是，算法 4.1 的输出 $C(G)$ 并非最终检测结果，而是 Agent 循环初始假设集 $\mathcal{H}_0$ 的供给。二者的关系如下：

(i) **初始化供给**。在 Agent 循环启动时，算法 4.1 在完整风险图 G 上执行一次，得到 $C(G)$ ，将其作为 $\mathcal{H}_0 = \{h_P \mid P \in C(G)\}$ 写入信念状态。此后 Agent 不再直接对 $C(G)$ 整体进行判定，而是在 $\mathcal{H}_0$ 上展开“证据采集—约束验证—风险排序”的迭代。

(ii) **循环中的邻域延伸**。在循环过程中，当 Agent 发现某条假设 h 的证据在终点附近存在可延伸的邻域（例如终点 v_k 通过新的边类型可触达更高敏感度的子目标），它通过 $\text{expand}(h)$ 动作触发算法 4.1 在以 v_k 为入口的受限子图 $G|_{v_k}$ 上重新执行，生成新增假设 $\Delta\mathcal{H}$ 加入 $\mathcal{H}_t$ 。这一机制使得假设集在循环中动态增长，而非在初始化时一次性固定。

(iii) **完备性的作用域**。定理 4.1 的假设生成完备性保证的是初始供给 $\mathcal{H}_0$ 的完整性，而非循环中通过 expand 动态生成假设的完整性——后者取决于 expand 的子图选取策略。但由于初始供给已覆盖所有满足 (C1)–(C3) 的完整路径， expand 的作用主要在于对已有假设进行细化与邻域补强，而非发现初始搜索遗漏的路径。这一分工使得算法 4.1 的全局完备性与 Agent 循环的局部灵活性得以兼顾。

综上， $C(G)$ 与最终检测结果之间的关系为： $C(G) \rightarrow \mathcal{H}_0 \xrightarrow{\text{循环迭代}} \mathcal{R}$ （结果集）。前者是后者的上界供给，最终哪些假设被 **confirm** 进入 $\mathcal{R}$ ，由 EIC 演算的硬约束与软约束共同裁定（见 4.3 节）。

5.3 证据完整性约束验证演算

本节是全章的理论核心。我们将原始的布尔合取式 $\text{EIC}(P) = \bigwedge_{d \in D} \text{Predicate}_d$ 升级为带阈值、带权重、带时间衰减的量化演算。整个演算建立在五维证据空间上，并通过 Gate-Score 双层结构实现“硬约束筛选 + 软证据加权”的解耦。

5.3.1 证据函数族定义与性质

定义 4.1 证据维度空间

定义 4.1（证据维度空间）：定义证据维度集合

$$D = \{\text{entry, reach, perm, target, sense}\},$$

其中各维度的语义如下：**entry**（入口暴露）衡量路径起点是否处于潜在被滥用的暴露面上；**reach**（网络可达）衡量路径中相邻节点间的网络层连通性；**perm**（权限授予）衡量路径中身份或角色对数据库对象的访问权限；**target**（目标价值）衡量路径终点的层次敏感性价值；**sense**（敏感数据）衡量路径中已确认的敏感数

据存在性。这五个维度的选取并非任意，而是对应了一条暴露路径从”起点暴露”到”终点触达”的完整因果链——入口暴露提供攻击入口，网络可达提供传输通路，权限授予提供访问授权，目标价值与敏感数据确认则分别标识攻击的收益与数据层面的实质性风险。

定义 4.2 证据评估函数

定义 4.2 (证据评估函数): 对每个维度 $d \in D$ ，定义证据评估函数

$$\varepsilon_d : \mathcal{P} \times \mathcal{G} \rightarrow [0, 1],$$

其中 $\mathcal{P}$ 为路径空间， $\mathcal{G}$ 为图空间。具体五个证据函数定义如下。

(1) 入口证据函数

$$\varepsilon_{entry}(P, G) = \omega_1 \cdot \text{exposure}(v_1) + \omega_2 \cdot \text{external_flag}(v_1) + \omega_3 \cdot \text{credential_risk}(v_1),$$

其中 $\sum_i \omega_i = 1, \omega_i \geq 0$ 。 $\text{exposure}(v) \in [0, 1]$ 由安全组规则计算：若 v 所属安全组放通 0.0.0.0/0 端口，则 $\text{exposure} = 1$ ；放通公司外部 IP 段为 0.7；放通仅内网为 0.2；完全隔离为 0。 $\text{external_flag}(v) \in \{0, 1\}$ 标识 v 是否对应外部主体（公网账号、第三方 SaaS、外包人员等）。 $\text{credential_risk}(v) \in [0, 1]$ 评估凭据泄露风险，采用密码强度、长期未轮换、是否硬编码、是否在公开仓库中出现等子项加权。入口证据的核心语义在于回答”该路径的起点是否真实对外暴露且容易被滥用”这一问题，上述三项加权分别对应”网络可被触达、主体非可信、凭据可被获取”三个子条件，只有三者同时成立时路径起点才构成实质风险。

(2) 可达性证据函数

$$\varepsilon_{reach}(P, G) = \prod_{i=1}^{k-1} r(v_i, v_{i+1}, G),$$

其中 $r(u, v, G) \in [0, 1]$ 为单跳可达性置信度，由如下子项融合：

$$r(u, v, G) = f_{net}(u, v) \cdot f_{wl}(u, v) \cdot f_{vpc}(u, v),$$

其中 f_{net} 为基于安全组与 ACL 的允许概率， f_{wl} 为白名单与路由策略的允许概率， f_{vpc} 为 VPC 边界穿越的合规概率。采用乘积形式体现”链式依赖”——任意一跳不可达则整体不可达，符合 Kill-Chain 思想。网络可达性具有天然的瓶颈效应：攻击者沿路径推进时必须每一步都能通过，任何一跳的中断都会使整条路径失效。乘积聚合自然刻画了这一物理约束。

(3) 权限证据函数

$$\varepsilon_{perm}(P, G) = \min_{(v_i, v_j) \in P, \tau_E(v_i, v_j) = \text{has_permission}} \text{conf}(\text{perm}(v_i, v_j)),$$

其中 $\text{conf}(\text{perm}(\cdot, \cdot)) \in [0, 1]$ 来自 IAM 闭包计算的置信度（直接授予为 1.0，经角色继承为 0.9，经组通过隐式策略为 0.7，等）。当路径中不含 `has_permission` 类型边时， $\varepsilon_{perm} = 1$ （即权限非约束）。采用 $\min$ 聚合体现“最短板原则”——权限链中最弱的一环决定整体权限强度。权限继承链与可达链的聚合方式存在本质差异：可达链是物理通过，每一跳必须独立成立且彼此以乘积聚合；权限链是逻辑授权，一旦某一环显著减弱（例如经过条件性 IAM 策略且置信度低），整体权限授予的可信度亦被拉低。 $\min$ 而非乘积的选择表达了这一“瓶颈定值”语义，即链中所有许可须达到统一最低强度。

(4) 目标价值函数

$$\varepsilon_{target}(P, G) = \frac{S_{target}(v_k)}{S_{\max}},$$

其中 $S_{target}(v_k)$ 为目标节点的层次敏感性聚合评分（来自第三章对字段、表、库的层次敏感性建模）， $S_{\max}$ 为归一化常数（取全图最高 S_{target} 值或固定基线值）。该函数的必要性在于：同一条结构上看似相同的路径，若终点是“用户脱敏昵称表”或“高敏个人征信表”，其风险价值天差地别；目标价值函数将这一价值差异显式纳入证据空间。

(5) 敏感数据确认函数

$$\varepsilon_{sense}(P, G) = \max_{v \in P, \tau_V(v) = \text{SensitiveTag}} \text{confidence}(v) \cdot \text{level}(v),$$

其中 $\text{confidence}(v) \in [0, 1]$ 为敏感标签识别置信度， $\text{level}(v) \in [0, 1]$ 为敏感等级归一化值（如 $L1=0.25$, $L2=0.5$, $L3=0.75$, $L4=1.0$ ）。当路径中无 `SensitiveTag` 节点时取 0。采用 $\max$ 聚合体现“任何一个高敏数据点的确认即可激活该维度”。敏感数据维度回答“路径所触达的对象内是否真实存在已被识别的高敏数据”这一问题。 $\max$ 而非求和的选择避免了路径长度对该维度的虚假放大，符合“一个证据即可成立”的取证原则。

上述五个证据函数在聚合策略上的差异并非任意选择，而是各自反映了底层物理或逻辑约束的本质特征：可达链要求全链通过故用乘积、权限链受最弱环制约故用最小值、敏感数据确认仅需一点即成立故用最大值、入口暴露与目标价值则因其为单点属性而分别采用加权组合与归一化比。

性质 4.1：证据函数族的基本性质

性质 4.1：对任意 $d \in D$ ，证据评估函数 ε_d 满足：(a) 有界性： $\varepsilon_d(P, G) \in [0, 1]$ ；(b) 单调性：若 $G' \supseteq G$ （添加节点或边或属性而不删减），则 $\varepsilon_d(P, G') \geq \varepsilon_d(P, G)$ ；

(c) 可计算性：存在多项式时间算法计算 $\varepsilon_d(P, G)$ 。

证明：

(a) 有界性。 ε_{entry} 的三项均在 $[0, 1]$ ，权重之和为 1，故凸组合在 $[0, 1]$ ； ε_{reach} 中每个 $r \in [0, 1]$ 之积仍在 $[0, 1]$ ； ε_{perm} 取 min 在 $[0, 1]$ 集合上仍在 $[0, 1]$ ； ε_{target} 由归一化常数 $S_{\max}$ 保证； ε_{sense} 中 confidence · level 之积在 $[0, 1]$ ，max 不改变范围。

(b) 单调性。 ε_{entry} 中 exposure, external_flag, credential_risk 在加入新证据节点（如新发现公网放通规则）时单调不减； ε_{reach} 中 r 在新增允许规则下不减，乘积形式保持单调； ε_{perm} 新增高置信度权限授予不会降低 min； ε_{target} 的层次聚合在子节点新增敏感字段时单调不减； ε_{sense} 的 max 对新加入的敏感证据节点单调不减。

(c) 可计算性。每个函数的复杂度均不超过 $O(|P|)$ 次基本运算，每次基本运算涉及对图属性的常数访问，故总复杂度为 $O(|P| \cdot c)$ ，其中 c 为常数，多项式时间。

性质 4.1 中的有界性保证了 EIC 算子的输出域可控，单调性则构成了后文定理 4.2 的直接前提，可计算性确保了整个演算体系在实际部署中的可行性。这三个性质共同构成了后文定理 4.2、4.3、命题 4.1 的共同基础。

5.3.2 EIC 验证算子的形式化

在上述五维证据空间的基础上，本节将各维度区分为硬约束与软约束，进而定义 Gate-Score 双层验证算子。这一区分的必要性源于如下观察：在安全判定场景中，并非所有证据维度具有同等地位——入口暴露、网络可达与权限授予是暴露路径成立的必要条件，缺乏其中任何一项即意味着攻击不可达成；而目标价值与敏感数据确认则影响风险的严重程度，但不影响路径暴露的存在性。将二者解耦使得演算体系既能严格过滤不可行路径，又能对可行路径进行细粒度的风险评分。

定义 4.3 硬约束维度与软约束维度

定义 4.3（硬/软约束维度划分）：将 D 划分为不相交两部分

$$D_{hard} = \{\text{entry, reach, perm}\}, \quad D_{soft} = \{\text{target, sense}\}, \quad D = D_{hard} \cup D_{soft}.$$

D_{hard} 的维度具有“一票否决”语义，即任何一个硬约束维度未达阈值则路径被认定为不成立； D_{soft} 的维度仅参与综合评分，不构成存活性筛选。这一划分将安全运维领域中的核心判断逻辑显式编码进演算结构：入口、可达与权限是暴露发生的必要条件，目标价值与敏感数据则是风险量级的修饰因子。

定义 4.4 EIC 验证算子

定义 4.4 (EIC 验证算子):

$$\text{EIC}(P) = \text{Gate}(P) \cdot \text{Score}(P).$$

门控函数:

$$\text{Gate}(P) = \prod_{d \in D_{\text{hard}}} \mathbb{I}[\varepsilon_d(P) \geq \tau_d],$$

其中 $\mathbb{I}[\cdot]$ 为指示函数, τ_d 为维度 d 的阈值。

评分函数采用加权几何均值 (广义 T-范数):

$$\text{Score}(P) = \prod_{d \in D} \varepsilon_d(P)^{w_d}, \quad \sum_{d \in D} w_d = 1, \quad w_d \geq 0.$$

Gate-Score 双层结构的设计体现了”必要条件筛选”与”综合证据加权”的解耦。Gate(P) 实现必要条件筛选: 三个硬约束中任何一个不满足则 Gate = 0, 整体 EIC = 0, 从而避免了出现”权限缺失但目标极高敏感度”的虚假高分场景。Score(P) 在 Gate 通过后计算路径的综合证据强度, 几何均值的选择使得任何单一维度的极低值都会显著拉低总分, 体现了证据的协同必要性——一条有效的暴露路径需要每个维度都处于较高水平, 而非依靠某一项极端值堆叠。

关于评分函数选取几何均值而非算术均值的理由, 考虑如下反例: 若采用算术均值 $\sum_d w_d \varepsilon_d$, 则一条 $\varepsilon_{\text{target}} = 1$ 而 $\varepsilon_{\text{reach}} = 0.05$ 的路径可能仍获得较高分, 这明显违背安全语义; 而在几何均值下该路径得分接近 0, 更符合”每一维度均为必要条件”的安全判断逻辑。

EIC 在 Agent 循环中的三重角色

在假设驱动的 Agent 循环架构下, EIC 算子并非仅在循环终止时行使一次性终判, 而是作为 Agent 每一步动作选择的核心决策依据, 承担三重角色:

(i) **剪枝准则**: 若 $\text{Gate}(P) = 0$ 且信息增益 $\widetilde{\text{IG}} < \delta_{\text{IG}}$ (即所有未通过维度的补强收益均低于阈值), 则 Agent 对该假设执行 **prune** 动作, 将其从活跃假设集 $\mathcal{H}_t$ 中移除。此时该假设既无法通过硬约束, 又缺乏通过补充查询翻盘的合理预期, 继续投入工具调用预算不具经济性。

(ii) **补证触发器**: 若 $\text{Gate}(P) = 0$ 但 $\widetilde{\text{IG}} \geq \delta_{\text{IG}}$ (即存在某个未通过维度具有显著的补强收益), 则 Agent 选择 $d^* = \arg \max_d \widetilde{\text{IG}}(d)$ 执行 **query**(h, d^*, tool) 动作, 对该维度发起工具化证据采集。信息增益的具体定义与计算见 4.6 节。

(iii) **确认准则**: 若 $\text{Gate}(P) = 1 \wedge \text{Score}(P) \geq \theta_{high}$, 则 Agent 对该假设执行 **confirm** 动作, 将其标记为已确认的暴露路径并纳入结果集 $\mathcal{R}$ 。此时所有硬约束均已通过且综合证据强度超过确认阈值, 假设已满足”暴露路径成立”的充分条件。

需要强调的是, 上述三重准则在旧架构中分散于两处: 终判逻辑隐含于 S6 阶段的批量 EIC 判定, 补证触发则后置于 §4.6 节的独立流程。在 Agent 循环架构下, 这两者被统一为 Agent 在每一步基于信念状态 $\mathcal{S}_t$ 的决策依据, 使得路径判定从”一次性终判”演化为”逐步逼近”的迭代过程。这一统一也使得 EIC 的单调性 (定理 4.2) 与假设空间收缩性 (定理 4.4) 不再仅作用于最终判定, 而是贯穿于循环的每一步, 为信念的逐点收敛提供保证。

定义 4.5 扩展验证算子 Observed-EIC

上述 EIC 算子刻画了路径的”可暴露性”, 但在实际运维中还需要区分”已被观测到攻击行为”与”仅存在潜在暴露风险”两种情形。为此, 引入审计证据维度。

定义 4.5 (Observed-EIC): 定义审计证据函数

$$\varepsilon_{audit}(P, G) = \max_{e \in \text{AuditEvents}(P)} \text{conf}(e) \cdot \gamma^{(t_{now} - t_e)/\Delta t},$$

其中 $\text{AuditEvents}(P)$ 为路径 P 在审计日志中的可疑事件集合 (如异常登录、批量查询、权限提升尝试等), $\text{conf}(e) \in [0, 1]$ 为该事件的异常置信度, $\gamma \in (0, 1)$ 为时间衰减因子 (本文取 $\gamma = 0.95$), Δt 为衰减时间单位 (如 1 小时、1 天), t_e 为事件发生时刻, t_{now} 为当前判定时刻。

扩展验证算子定义为

$$\text{Observed-EIC}(P) = \text{EIC}(P) \cdot \mathbb{I}[\varepsilon_{audit}(P) \geq \tau_{audit}].$$

审计证据具有时间敏感性: 昨日的异常登录与一年前的异常登录对当前风险判定的参考价值不同, 指数衰减自然刻画了这一近因偏置。当 ε_{audit} 跨越阈值 τ_{audit} 时, 该路径不仅是”可暴露”的, 而且是”已被尝试或可能正在被利用”的, 此时应升级为 Observed_RISK 级别。

5.3.3 路径分类的判定准则

基于 EIC 算子与 Observed-EIC 扩展, 本节定义路径的三分类判定准则, 为下游的风险处置提供明确的决策依据。

定义 4.6 路径三分类判定

定义 4.6 (路径三分类): 给定阈值向量 $\Theta = (\tau_{entry}, \tau_{reach}, \tau_{perm}, \tau_{audit}, \theta_{high})$, 路径 P 的分类定义为

$$\text{PathType}(P) = \begin{cases} \text{Observed_Risk} & \text{若 } \text{EIC}(P) \geq \theta_{\text{high}} \wedge \varepsilon_{\text{audit}}(P) \geq \tau_{\text{audit}}, \\ \text{Potential_Exposure} & \text{若 } \text{EIC}(P) \geq \theta_{\text{high}} \wedge \varepsilon_{\text{audit}}(P) < \tau_{\text{audit}}, \\ \text{Insufficient_Evidence} & \text{若 } \exists d \in D_{\text{hard}} : \varepsilon_d(P) < \tau_d. \end{cases}$$

在 Agent 循环架构下，三分类不再是循环终止时的终判标签，而是 Agent 对当前假设的处置状态。具体而言：Observed_Risk 与 Potential_Exposure 对应 **confirm** 动作的触发条件——当 $\text{Gate}(P) = 1$ 且 $\text{Score}(P) \geq \theta_{\text{high}}$ 时，Agent 将该假设确认为已成立的暴露路径，二者的区别仅在于审计证据是否已跨越阈值（从而决定风险等级而非是否确认）；Insufficient_Evidence 则对应“待 **prune** 或待 **query** 补证”的中间状态——当某硬约束维度未达阈值时，Agent 不立即判定该假设失效，而是依据 4.6 节的信息增益评估决定下一步动作：若补强收益显著则执行 **query** 继续采集证据，若补强收益不足则执行 **prune** 将其剔除。这一重新诠释将三类标签从“判定结果”转变为“决策状态”，使得路径处置不再是静态分类，而是循环中的动态决策。

阈值选择策略

阈值 Θ 的选择直接决定误报与漏报之间的权衡，本文采用三层策略予以应对。第一层为先验默认值： $\tau_{\text{entry}} = 0.5, \tau_{\text{reach}} = 0.6, \tau_{\text{perm}} = 0.5, \tau_{\text{audit}} = 0.4, \theta_{\text{high}} = 0.5$ 。第二层为基于历史标注的自适应调整：若近 30 天的真阳性率低于 80%，则按比例提升阈值；若漏报率高于 5%，则降低阈值。第三层为领域定制：金融行业可适当降低 θ_{high} 以提高灵敏度，互联网行业可适当提高以减少告警疲劳。

灵敏度分析

设 θ_{high} 在 $[0.3, 0.7]$ 区间扫动，定义灵敏度

$$\text{Sens}(\theta) = \left| \frac{\partial \mathbb{E}[\# \text{Risk}]}{\partial \theta} \right|,$$

经验上 $\text{Sens}(\theta)$ 在 $\theta \in [0.45, 0.55]$ 区间存在峰值，即阈值的敏感区，需要谨慎调参；在 $[0.3, 0.4]$ 与 $[0.6, 0.7]$ 区间灵敏度迅速下降，调参对结果影响较小。建议运维默认值落在敏感区上沿（0.55 左右）以平衡漏报与误报。

5.3.4 理论性质分析

本节对 EIC 验证算子的理论性质进行系统分析，依次证明单调性、零元素性质与假设空间收缩性，并讨论多项式可判定性。这些性质不仅为 EIC 演算的数学自洽性提供保证，也直接支撑了后续章节中证据补充与增量更新的正确性论证。

定理 4.2 单调性

定理 4.2 (EIC 单调性): 若 $G' \supseteq G$ (G' 是 G 的超图, 添加了额外证据节点或边而不删减), 则对任意路径 P ,

$$\text{EIC}(P; G') \geq \text{EIC}(P; G).$$

证明: 分两步。

步骤 1: 证明 $\text{Gate}(P; G') \geq \text{Gate}(P; G)$ 。

由性质 4.1(b), 对任意 $d \in D_{\text{hard}}$, $\varepsilon_d(P; G') \geq \varepsilon_d(P; G)$ 。若在 G 下 $\varepsilon_d(P; G) \geq \tau_d$, 则在 G' 下亦成立; 反之, 在 G' 下 $\varepsilon_d \geq \tau_d$ 时不要求 G 下亦成立。故每个指示函数都有 $\mathbb{I}[\varepsilon_d(P; G') \geq \tau_d] \geq \mathbb{I}[\varepsilon_d(P; G) \geq \tau_d]$, 乘积保持该不等式:

$$\text{Gate}(P; G') = \prod_{d \in D_{\text{hard}}} \mathbb{I}[\varepsilon_d(P; G') \geq \tau_d] \geq \prod_{d \in D_{\text{hard}}} \mathbb{I}[\varepsilon_d(P; G) \geq \tau_d] = \text{Gate}(P; G).$$

步骤 2: 证明 $\text{Score}(P; G') \geq \text{Score}(P; G)$ 。

由性质 4.1(b), 每个 ε_d 单调不减, 且 $w_d \geq 0$, 故 $\varepsilon_d^{w_d}$ 关于 ε_d 在 $[0, 1]$ 上单调不减 (当 $\varepsilon_d \in [0, 1]$, $w_d \geq 0$ 时 x^{w_d} 单调不减), 乘积保持:

$$\text{Score}(P; G') = \prod_{d \in D} \varepsilon_d(P; G')^{w_d} \geq \prod_{d \in D} \varepsilon_d(P; G)^{w_d} = \text{Score}(P; G).$$

综合两步且两者非负: $\text{EIC}(P; G') = \text{Gate}(P; G') \cdot \text{Score}(P; G') \geq \text{Gate}(P; G) \cdot \text{Score}(P; G) = \text{EIC}(P; G)$ 。

单调性保证了”证据越多, 判定越稳”这一关键性质: 补充工具调用永远不会使一条原本被判为风险的路径转为非风险。这为后续的证据补充机制与风险图增量更新提供了理论基础, 确保系统在面对新增证据时判定结果的单调递进。进一步地, 单调性同时保证了 Agent 循环的信念单调收敛: 在信念状态 $\mathcal{S}_t = (\mathcal{H}_t, \mathcal{E}_t, \mathcal{B}_t)$ 中, 由于 query 动作只会向证据库 $\mathcal{E}_t$ 添加观测而不删除, 且每次新增证据后重算的 $\mathcal{B}_t(h)$ 对每个假设 h 均单调不减 (即 $\mathcal{B}_{t+1}(h) \geq \mathcal{B}_t(h)$ 逐点成立), 信念在循环中不会出现”倒退”。这一性质确保了 Agent 不会在已获取证据后重新陷入对同一假设的反复怀疑, 从而保证循环的有限步终止性。

定理 4.3 边界性 / 零元素性质

定理 4.3 (零元素性质): 若存在 $d \in D_{\text{hard}}$ 使得 $\varepsilon_d(P) = 0$ 或 $\varepsilon_d(P) < \tau_d$, 则 $\text{EIC}(P) = 0$ 。

证明: 由 $\text{Gate}(P) = \prod_{d \in D_{\text{hard}}} \mathbb{I}[\varepsilon_d(P) \geq \tau_d]$ 。若存在 $d^* \in D_{\text{hard}}$ 使 $\varepsilon_{d^*}(P) < \tau_{d^*}$, 则该指示函数为 0, 乘积为 0, 故 $\text{Gate}(P) = 0$ 。由 $\text{EIC}(P) = \text{Gate}(P) \cdot \text{Score}(P) = 0 \cdot \text{Score}(P) = 0$ 。

零元素性质从形式上保证了”硬约束失守即否决”的判定逻辑，与安全运维领域的直觉完全一致。同时，该性质使得 EIC 的取值在硬约束未通过时严格为 0，便于下游的统计汇总与可视化展示。

定理 4.4 假设空间约束

EIC 的核心研究动机在于约束语言模型的假设空间以抑制幻觉，本节给出形式化论证。

设语言模型在面对路径判定任务时，其假设空间 H 为”所有可能给出的判定”的集合。在无任何约束时， $|H|$ 受限于词表与解码策略，通常为指数级。

定理 4.4 (EIC 假设空间收缩): 设 H_{EIC} 为满足 EIC 约束的假设子空间，即语言模型输出必须与 EIC 算子结果一致的子集。则在合理独立性假设下，

$$|H_{EIC}| \leq |H| \cdot \prod_{d \in D_{hard}} \mathbb{P}(\varepsilon_d \geq \tau_d).$$

证明: 将语言模型的判定视为对路径 P 输出 $y \in \{0, 1\}$ (是否构成风险)。EIC 约束要求 $y = 1$ 当且仅当 $\text{Gate}(P) = 1$ 且 $\text{Score}(P) \geq \theta_{high}$ 。

考察 $y = 1$ 这一支:

$$\mathbb{P}_H(y = 1 \mid \text{EIC satisfied}) = \mathbb{P}\left(\bigwedge_{d \in D_{hard}} \varepsilon_d \geq \tau_d \wedge \text{Score} \geq \theta_{high}\right).$$

在硬约束维度的工具采集相互独立的假设下 (这一假设在工程实现中通过将 7 个工具的请求路径解耦得到):

$$\mathbb{P}\left(\bigwedge_{d \in D_{hard}} \varepsilon_d \geq \tau_d\right) = \prod_{d \in D_{hard}} \mathbb{P}(\varepsilon_d \geq \tau_d).$$

记 H_{EIC} 为 EIC 约束允许的判定全体，由于约束仅限制 $y = 1$ 这一支，对 $y = 0$ 不做额外约束 (凡是 EIC 不通过即输出 0)，故有

$$|H_{EIC}| \leq |H| \cdot \prod_{d \in D_{hard}} \mathbb{P}(\varepsilon_d \geq \tau_d).$$

由 $\prod_{d \in D_{hard}} \mathbb{P}(\varepsilon_d \geq \tau_d) \in (0, 1]$ ，假设空间被严格收缩。

定理 4.4 给出了 EIC 抑制语言模型幻觉的形式化解释: 可幻觉空间被乘性收缩，每加入一个硬约束维度，可幻觉空间被进一步切分。例如若三个硬约束维度的通过概率均为 0.3，则 $|H_{EIC}| \leq 0.027|H|$ ，可幻觉空间缩减约 37 倍。这一理论预测与第六章实验中观测到的幻觉率从 18.4% 降至 5.3% 的结果一致。在 Agent 循环视角下，定理 4.4 的收缩性不再仅作用于最终的批量判定，而是保证了 LLM 在每一步动作选择时的幻觉空间被乘性收缩: 每当 Agent 对某假设的某维度执行

query 并获得观测后, 该维度的证据值 ε_d 被锚定为工具返回的确定性值而非 LLM 的臆断, 相应的假设空间在该维度上被”冻结”为通过或未通过两种状态之一。随着循环推进, 越来越多的维度被冻结, LLM 可幻觉的空间逐维收缩, 直至所有硬约束维度均被锚定或假设被 prune。

命题 4.1 可判定性

命题 4.1 (EIC 多项式可判定): 给定路径 P 与图 G , $\text{EIC}(P)$ 的计算可在 $O(|P| \cdot \max(|V|, |E|))$ 时间内完成。

证明: $\varepsilon_{\text{entry}}(P)$ 仅依赖 v_1 的属性, 常数时间; $\varepsilon_{\text{reach}}(P)$ 沿路径计算 $|P| - 1$ 次单跳置信度, 每次访问 G 中相邻边属性, 单次 $O(\log |E|)$ (采用邻接索引), 合计 $O(|P| \log |E|)$; $\varepsilon_{\text{perm}}(P)$ 类似遍历 $|P| - 1$ 次; $\varepsilon_{\text{target}}(P)$ 仅依赖 v_k 与其下挂敏感子节点, 最坏 $O(|V|)$ (遍历层次); $\varepsilon_{\text{sense}}(P)$ 路径节点遍历, $O(|P|)$; Gate, Score 为常数乘法。总复杂度上界为 $O(|P| \cdot \max(|V|, |E|))$, 多项式可判定。

5.4 路径风险量化排序模型

EIC 算子已能输出 $[0, 1]$ 区间的得分, 但仍需进一步定义独立的风险排序模型, 其原因有三。其一, EIC 的几何均值在边界附近变化平缓, 对排序不够敏感。其二, 排序模型应支持参数学习 (从历史标注中拟合 β_d), 而 EIC 算子的超参 w_d 用于刻画领域先验, 二者承担不同功能。其三, 排序模型应与信息检索类指标 (如 NDCG、MAP) 天然对齐, 以便于实验评估。

5.4.1 定义 4.7 对数几率风险模型

定义 4.7 (对数几率风险模型):

$$\text{Risk}(P) = \sigma \left(\sum_{d \in D} \beta_d \cdot \log \frac{\varepsilon_d(P) + \epsilon_0}{1 - \varepsilon_d(P) + \epsilon_0} + \beta_0 \right),$$

其中 $\sigma(x) = 1/(1 + e^{-x})$ 为 sigmoid 函数, $\beta_d \in \mathbb{R}$ 为可学习或可调参数, β_0 为偏置项, $\epsilon_0 = 10^{-6}$ 为数值稳定项以避免对数发散。

5.4.2 理论动机

(i) 对数几率变换的概率论意义

对数几率 (log-odds) 变换将 $[0, 1]$ 的证据分数映射到 $(-\infty, +\infty)$:

$$\text{logit}(p) = \log \frac{p}{1 - p}.$$

在该空间中线性组合具有概率论上的可解释性——这是逻辑回归的标准框架。当 ε_d 视作“维度 d 上路径成立的概率”时，

$$\sum_d \beta_d \cdot \text{logit}(\varepsilon_d) + \beta_0$$

可解释为“路径整体成立的对数几率”，再经 σ 还原为概率。

(ii) 与几何均值的关系

注意到：当所有 $\beta_d = w_d$ 且无 sigmoid 变换时， $\sum_d w_d \log \varepsilon_d = \log \prod_d \varepsilon_d^{w_d} = \log \text{Score}(P)$ 。即 EIC 的 Score 是 Risk 的“前激活值”（去掉 $1 - \varepsilon_d$ 与 sigmoid 之后的形式）。这一观察使得 EIC 与 Risk 在数学结构上自然嵌套：Risk 是带偏置与归一化的 EIC。

(iii) 与 NDCG 排序指标兼容

NDCG 等排序指标依赖单调可比的分数。 σ 输出严格落在 $(0, 1)$ 区间且严格单调，故 $\text{Risk}(P)$ 适合直接作为排序键，避免出现因评分饱和（如 EIC 的 Score 在硬约束未通过时为 0）造成的同分大量并列。

5.4.3 风险等级划分

基于 $\text{Risk}(P)$ 与 $\text{Gate}(P)$ ，将路径划分为四级：

$$\text{Level}(P) = \begin{cases} \text{High} & \text{若 } \text{Risk}(P) \geq \theta_H \wedge \text{Gate}(P) = 1, \\ \text{Medium} & \text{若 } \theta_M \leq \text{Risk}(P) < \theta_H \wedge \text{Gate}(P) = 1, \\ \text{Low} & \text{若 } \text{Risk}(P) < \theta_M \wedge (\text{Gate}(P) = 0 \vee \text{Risk}(P) > 0), \\ \text{Insufficient} & \text{若 } \text{Gate}(P) = 0 \wedge \text{关键证据缺失}, \end{cases}$$

其中本文取 $\theta_H = 0.7, \theta_M = 0.4$ 。Low 与 Insufficient 的区分在于：Low 表示路径硬约束未全部通过但已有部分弱证据，运维可降级关注；Insufficient 表示工具未能采集到关键维度的证据，需进入 4.6 节复核。

5.4.4 多路径排序

当存在多条候选路径时，按 $\text{Risk}(P)$ 降序排列：

$$\pi^* = \text{argsort}_{P \in C(G)} \text{Risk}(P).$$

为应对极端情况（如多条 $\text{Gate} = 0$ 但 Risk 接近的路径），引入二级排序键 $\text{Sufficiency}(P)$ （见 4.6 节），以及三级排序键 $S_{\text{target}}(v_k)$ ，确保排序稳定。

5.4.5 参数 β_d 的学习与可解释性

参数 β_d 可由历史标注数据通过最大似然估计：

$$\hat{\beta} = \arg \max_{\beta} \sum_{(P_i, y_i)} [y_i \log \text{Risk}(P_i; \beta) + (1 - y_i) \log(1 - \text{Risk}(P_i; \beta))],$$

其中 $y_i \in \{0, 1\}$ 为人工标注的“是否真实风险”。最大似然估计的封闭性与凸性使其训练稳定且全局最优。

学习得到的 β_d 还具有可解释性： β_d 越大，表明维度 d 在历史数据上对路径风险的判别贡献越大。本文在第六章给出了实证 β 值，发现 β_{reach} 与 β_{perm} 通常显著高于 β_{target} ，与“网络可达性与权限是攻击核心环节”的安全直觉一致。

5.5 工具化证据获取机制

EIC 的所有证据评估函数都依赖工具调用提供原始数据。本节规范化 7 个工具的接口、副作用、置信度模型，以及语言模型调度策略。

5.5.1 工具接口规范

T1: GraphPathSearch

$$\text{GraphPathSearch} : 2^V \times 2^V \rightarrow 2^{\mathcal{P}}, \quad (\text{Entry}, \text{Target}) \mapsto C(G).$$

实现算法 4.1，返回候选路径集合及其上下文。无副作用。

T2: NetworkCheck

$$\text{NetworkCheck} : V \times V \rightarrow (\text{reachable} \in \{0, 1\}, \text{conf} \in [0, 1], \text{evidence} \in \mathcal{E}).$$

调用云 API 解析安全组、ACL、VPC 路由，输出可达布尔判定、置信度（综合规则匹配的精确度）和证据字典（具体放通规则 ID、协议、端口）。该工具结果用于 ε_{reach} 中的单跳置信度。

T3: PermissionCheck

$$\text{PermissionCheck} : V_{\text{Identity}} \times V_{\text{DBObject}} \rightarrow (\text{has_perm} \in \{0, 1\}, \text{perm_type} \in \mathcal{T}_{\text{perm}}, \text{conf} \in [0, 1]).$$

执行 IAM 策略闭包模拟（含组、角色、SCP、权限边界），返回主体对客体的有效权限。置信度反映计算路径的可靠性（直接授予 1.0、角色继承 0.9、隐式策略 0.7）。

T4: SensitiveDataQuery

$\text{SensitiveDataQuery} : V_{DBObject} \rightarrow (\text{tags} \in 2^{\mathcal{T}_{sense}}, \text{level} \in \{1, 2, 3, 4\}, \text{conf} \in [0, 1], \text{score} \in [0, 1])$.

返回数据库对象的敏感标签集合、敏感等级、置信度，以及由第三章层次聚合得到的 S_{target} 评分。

T5: AuditLogQuery

$\text{AuditLogQuery} : V_{Identity} \times V_{DBObject} \times \mathbb{R}^+ \rightarrow (\text{events} \in 2^{\mathcal{E}^a}, \text{anomaly} \in [0, 1])$.

按身份 $\times$ 对象 $\times$ 时间窗口检索审计日志，返回事件流与异常评分（基于行为基线的 z-score 或孤立森林）。

T6: ControlStatusCheck

$\text{ControlStatusCheck} : V_{DBObject} \rightarrow (\text{controls} \in \mathcal{C}, \text{protection} \in [0, 1])$.

获取对象上的安全控制（加密、脱敏、行级权限、审计开关），输出”防护强度”作为风险递减因子（保留扩展接口，第六章实验中作为消融项）。

T7: EvidenceValidator

$\text{EvidenceValidator} : \mathcal{P} \rightarrow (\text{eic_status} \in \{\text{Risk}, \text{Pot}, \text{Insuf}\}, \text{score} \in [0, 1], \text{missing} \in 2^D)$.

综合校验器，封装 4.3 节的 Gate/Score 计算与 4.6 节的充分性判断，输出最终判定状态、得分、缺失维度集合。语言模型在每条候选路径上必须以 T7 作为最终调用，以保证演算的强制执行。

5.5.2 工具调度的先验策略 π_0 与主动偏离

在 Agent 循环架构下，语言模型基于当前信念状态 $\mathcal{S}_t$ 主动选择动作（包括 query 的工具选择与调用顺序），而非遵循固定的调度脚本。然而，完全无先验的自由选择会显著增加语言模型在每一步的决策负担，尤其在信念状态尚未提供足够偏置信号时，Agent 可能陷入次优的工具调用序列。为此，本节将下文三阶段调度顺序固化为**先验策略** π_0 ，作为 Agent 动作选择的默认基准：当信念状态未提供更强的偏置信号时，Agent 遵循 π_0 的既定顺序；当某维度的证据不足且信息增益显著时，Agent 主动偏离 π_0 ，选择信息增益最大的维度优先执行 query。

阶段 A：候选生成（作为 π_0 的第一阶段）

调用 T1（GraphPathSearch）获取 $C(G)$ 。该阶段为图运算，无云 API 成本。

阶段 B：硬约束剪枝（作为 π_0 的第二阶段）

对每条候选路径 $P \in C(G)$ ，按”成本由低到高、剪枝力由强到弱”的顺序串行调用：首先调用 T2 (NetworkCheck)，若失败则直接判 Insufficient 并跳过其余调用；其次调用 T3 (PermissionCheck)，若失败则同样直接判 Insufficient；入口证据由路径属性直接读取，无需独立工具。阶段 B 在硬约束维度未达阈值时早停，可显著减少不必要的 T4-T6 调用。

阶段 C：软约束补强（作为 π_0 的第三阶段）

仅对通过 Gate 的路径调用 T4 (SensitiveDataQuery) 以补强 ε_{sense} 与 ε_{target} ，T5 (AuditLogQuery) 以补强 ε_{audit} ，T6 (ControlStatusCheck) 以补强可选的防护因子，最后调用 T7 (EvidenceValidator) 完成综合判定。

调用顺序的最优性论证：设各工具的期望调用成本为 $c_2 < c_3 < c_4 < c_5 < c_6$ ，硬约束剪枝率分别为 ρ_2, ρ_3 ，则总期望成本为

$$\mathbb{E}[\text{Cost}] = c_2 + \rho_2 \cdot c_3 + \rho_2 \rho_3 \cdot (c_4 + c_5 + c_6).$$

将 T2 置于 T3 之前的条件为 $c_2 + \rho_2 c_3 < c_3 + \rho_3 c_2$ ，即 $c_2(1 - \rho_3) < c_3(1 - \rho_2)$ 。在 $\rho_2 < \rho_3, c_2 < c_3$ 的经验前提下成立，故”先网络后权限”的顺序为期望成本最优。

上述最优性结论为 π_0 的设计提供了期望成本下界的理论依据：在硬约束剪枝率与工具调用成本的经验分布下， π_0 给出的三阶段顺序使期望总成本 $\mathbb{E}[\text{Cost}]$ 达到下界。然而， π_0 并非 Agent 的唯一选择。在 Agent 循环中，当信念状态 $\mathcal{S}_t$ 显示某维度的证据不足且信息增益显著时，Agent 可主动偏离 π_0 ，选择信息增益最大的维度优先执行 query。偏离的合理性条件为：信息增益的增量超过成本增量的 λ 倍，即

$$\widetilde{\text{IG}}(a_{\text{deviate}}) - \widetilde{\text{IG}}(a_{\pi_0}) > \lambda \cdot [\text{Cost}(a_{\text{deviate}}) - \text{Cost}(a_{\pi_0})],$$

其中 a_{π_0} 为 π_0 在当前信念状态下指示的下一步动作， a_{deviate} 为 Agent 主动选择的偏离动作， $\lambda > 0$ 为成本-收益权衡系数。当上式成立时，偏离带来的信息增益足以弥补其额外成本，Agent 执行偏离动作；否则遵循 π_0 。这一机制使得 π_0 提供了”安全默认”而下层信念状态提供了”主动优化”的两层决策结构。

5.5.3 工具失败的退化处理

实际云环境中工具偶有失效（限流、瞬时不可达、权限不足等情形）。本文采用如下退化策略予以应对。对于可重试错误（如 5xx 状态码与限流），采用指数退避重试 3 次。对于不可重试错误（如 4xx 状态码与权限拒绝），将该维度证据标记为缺失，触发 Insufficient 判定并进入 4.6 节复核流程。对于超时情形，超过 $T_{\text{timeout}} = 10\text{s}$ 即视为缺失。对于结果不一致情形（不同工具对同一证据返回冲突），以更高置信度的来源为准，冲突信息一并写入审计日志。

上述退化处理保证了 EIC-Agent 的鲁棒性：在工具部分失效的情形下，系统仍能输出可解释的”证据不足”结论，而非错误的”无风险”判定。在 Agent 循环架构下，退化情形的处理不再仅是”标记缺失并进入复核”的终态操作，而是转化为 Agent 的下一步动作决策：当某维度的工具调用失败且不可恢复时，Agent 将对应假设标记为”证据不足”状态，并根据当前信念状态决定是执行 **prune**（当该维度补强收益低于阈值时）还是执行 **terminate**（当所有活跃假设均已达到 **confirm** 或 **prune** 状态时），从而保证循环在工具部分失效时仍能有序终止。

5.6 证据不足判定与人工复核机制

EIC 演算的一个核心创新在于显式区分了”无风险”与”证据不足”。前者代表”已确认无暴露”，后者代表”无法判定，需要进一步证据”——二者在传统布尔体系中常被混淆，导致漏报或误信。

5.6.1 定义 4.8 证据充分性指标

定义 4.8（证据充分性）：

$$\text{Sufficiency}(P) = \frac{|\{d \in D : \varepsilon_d(P) \geq \tau_d\}|}{|D|}.$$

$\text{Sufficiency}(P) \in \{0, 0.2, 0.4, 0.6, 0.8, 1.0\}$ （5 维度），刻画”路径在多少个维度上拥有足够证据”。

当 $\text{Sufficiency}(P) < \theta_{suf}$ （本文取 $\theta_{suf} = 0.6$ ，即至少 3/5 维度通过），且至少一个硬约束维度未通过时，输出

```
{ "status": "insufficient_evidence",
  "missing_dims": [d ∈ D : εd(P) < τd],
  "next_action": "human_review_or_supplementary_query" }
```

5.6.2 信息增益驱动的补充查询

在 Agent 循环架构下，信息增益不再仅在”判定为 Insufficient 后”作为补证触发器使用，而是升级为 Agent 每步动作选择的核心决策函数。当信念状态 $\mathcal{S}_t$ 显示某假设 h 的某维度 d 的证据不足（即 $\varepsilon_d(h) < \tau_d$ ）时，Agent 计算该维度的信息增益，并选择信息增益最大的维度执行 **query** 动作：

$$d^* = \arg \max_{d: \varepsilon_d < \tau_d} \text{IG}(d \mid P, G),$$

其中信息增益定义为

$$\text{IG}(d \mid P, G) = H(\text{PathType}(P) \mid P, G) - \mathbb{E}_{\varepsilon_d^{new}}[H(\text{PathType}(P) \mid P, G, \varepsilon_d^{new})],$$

H 为路径类型的香农熵。信息增益衡量的是”得知维度 d 的真实证据值后，对路径类型不确定性的预期降低程度”。

当精确信息增益难以解析求解时，采用如下启发式估计

$$\widetilde{IG}(d) = (\tau_d - \varepsilon_d(P)) \cdot w_d,$$

即”距离阈值越远且维度权重越大”则补强收益越高。该启发式的合理性在于：距离阈值最远的维度若被补强通过，对 Gate 与 Score 的边际改变最大。

当所有维度的信息增益均低于阈值 δ_{IG} 时（即 $\max_d \widetilde{IG}(d) < \delta_{IG}$ ），Agent 不再执行 **query**，而是根据当前 Gate 状态选择终止动作：若 $\text{Gate}(P) = 0$ 则执行 **prune**，若 $\text{Gate}(P) = 1$ 但 $\text{Score}(P) < \theta_{high}$ 则同样执行 **prune** 或进入人工复核（见 4.6.3 节），若 $\text{Gate}(P) = 1$ 且 $\text{Score}(P) \geq \theta_{high}$ 则执行 **confirm**。这一机制使得 Agent 循环在信息增益耗尽时自然终止，避免无意义的工具调用。

5.6.3 人工复核 workflow

在 $\widetilde{IG}(d) < \delta_{IG}$ 即所有维度补强收益均低时，进入人工复核流程。该流程包含四个环节：首先，系统进行结构化交付，输出含 **path**、**eic_score**、**missing_dims**、**evidence_snapshot**、**recommended_query** 字段的报告；其次，复核员依据补充信息（如运维访谈、应急录屏、私有审计源）手动填写缺失维度证据；再次，手动证据回灌图 G 后触发 EIC 重计算（由定理 4.2 单调性保证，重计算不会降低已成立路径的得分）；最后，复核结果作为新标注数据，用于 4.4.5 节 β_d 的在线更新。

人工复核机制使 EIC-Agent 形成”机器先筛、人工兜底、闭环学习”的体系，将语言模型的能力边界、工具的可达边界与人工的判断力有机结合。在 Agent 循环架构下，人工复核在 **terminate** 动作触发之后执行，而非作为循环内部的并行分支。具体而言，当 Agent 执行 **terminate** 时，所有被 **prune** 但仍具人工研判价值的假设（即 $\text{Sufficiency}(P) \geq \theta_{suf}$ 且 $\varepsilon_{target}(P)$ 较高但某硬约束维度因工具失效而未通过的假设）被收集至复核队列，由人工复核员依据上述四环节流程逐一处理。这一设计保证了 Agent 循环的自动性与人工复核的介入性之间的清晰边界：循环内由 Agent 自主决策，循环后由人工补充研判。

5.6.4 复核优先级

当多条 Insufficient 路径同时进入复核队列时，按以下优先级排序：

$$\text{Priority}(P) = \alpha_1 \cdot \text{Sufficiency}(P) + \alpha_2 \cdot \varepsilon_{target}(P) + \alpha_3 \cdot \widetilde{IG}(d^*),$$

其中 $\alpha_1 + \alpha_2 + \alpha_3 = 1$ 。该优先级偏向”已有较多证据且目标价值高且补强收益高”的路径，使有限的人工带宽聚焦于最有可能转化为真实风险的候选。

5.7 方法验证实验

本节在 CloudDB-PathBench 上对 EIC-Agent 进行系统性实验验证，包括主效果对比实验、轨迹级效率评估与证据约束消融实验。

5.7.1 实验设置

基线方法：选取 7 个基线方法：B1 规则打分、B2 纯图搜索、B3 纯 LLM、B4 RAG+LLM、B5 ReAct（无 EIC）、B6 EIC-Agent（本文方法，无微调）、B7 EIC-Agent（Pipeline）——即旧固定三阶段架构（先验策略 π_0 强制执行、无主动偏离），作为消融对照，量化主动调查的增益。所有 LLM 类基线均使用 Qwen3-8B 作为底座，温度 $T=0.2$ ，工具调用预算统一为 8 步。

评价指标：选取 12 项路径级指标与 5 项轨迹级指标，共 17 项。

路径级指标（12 项）：Path Accuracy (PA)、Node-F1、Edge-F1、Invalid Path Rate (IPR)、Hit@3、Evidence Coverage (EC)、Unsupported Claim Rate (UCR)、Hallucination Rate (HR)、EIC Pass Rate (EICPR)、NDCG@3、Root Cause Coverage (RCC)、Average Tool Calls (ATC)。

轨迹级指标（5 项），用于评估 Agent 循环的执行效率与可靠性：

表 4-2 轨迹级指标定义

指标	定义
EQP (Evidence Query Precision, 证据查询精度)	有效查询数/总查询数。有效查询定义为”返回的证据使
CRR (Context Reduction Ratio, 上下文压缩比)	$1 - \frac{\text{Agent 实际查询的节点/边数}}{ V + E }$
HPR (Hypothesis Pruning Rate, 假设剪枝率)	被 prune 的假设数/总生成假设数
CS (Convergence Steps, 收敛步数)	确认一条 gold path 所需的平均动作步数
pass@k	k 次独立调查中至少一次确认 gold path 的比率

5.7.2 主效果对比实验

表 4-3 路径级指标主效果对比

方法	PA↑	N-F1↑	E-F1↑	IPR↓	H@3↑	EC↑	UCR↓	HR↓	EICPR↑	NDCG↑	I
B1 Rule	.082	.31	.24	.000	.18	.33	–	–	–	.41	.
B2 Graph	.114	.46	.39	.000	.34	.17	–	–	–	.52	.
B3 LLM†	.061	.28	.19	.412	.22	.41	.58	.31	.05	.39	.
B4 RAG†	.108	.38	.30	.286	.31	.49	.42	.21	.13	.46	.
B5 ReAct†	.176	.51	.43	.193	.45	.55	.34	.16	.21	.58	.
B6 EIC-Agent†	.224	.62	.54	.058	.58	.68	.18	.06	.66	.66	.
B7 Pipeline†	.215	.59	.51	.062	.55	.64	.21	.07	.62	.63	.

注：† 表示预期结果。B7 为禁用主动偏离后的固定三阶段流水线变体，其 EIC 约束机制与 B6 完全相同，唯一区别在于强制遵循先验策略 π_0 而不允许基于信念状态 $\mathcal{S}_t$ 主动偏离。

表 4-4 轨迹级指标对比（仅 Agent 类方法）

方法	EQP↑	CRR↑	HPR↑	CS↓	pass@k↑
B5 ReAct†	XX.X%	XX.X%	XX.X%	XX.X%	XX.X%
B7 Pipeline†	XX.X%	XX.X%	XX.X%	XX.X%	XX.X%
B6 EIC-Agent†	XX.X%	XX.X%	XX.X%	XX.X%	XX.X%

注：† 表示预期结果，具体数值待实验填充。EQP/CRR/HPR/CS/pass@k 等完整轨迹级指标需在 Agent 完整闭环（含信息增益驱动的 query/expand 动作）训练完成后方能系统测得，故本表为待填充的预期评估框架；其中与”当前已实现的提前终止机制”直接相关的剪枝与代价指标，已可实测，见表 4-4b。

表 4-4b 提前终止机制实测统计（当前已实现部分，非预期值）

指标	实测值	说明
候选路径总数	68	20 个 CloudGoat 场景经约束搜索得到
提前剪枝路径数	17	硬证据维度一票否决触发提前终止
假设剪枝率 HPR	25.0%	剪枝路径 / 候选总数
硬维度计算次数	187 / 204	逐维查在不达标维度即停，节省 8.3% 维度计算
省去工具调用	~85 次	剪枝路径跳过后续工具调用
省去 LLM 归因调用	~34 次	剪枝路径不进入 LLM 归因生成
证据腐蚀切分剪枝正确率	100%	Evidence Corruption 路径全部被正确判为 Insufficient_Evidence

注：表 4-4b 为在 CloudDB-PathBench 上实际运行提前终止机制（第 4.6 节所述基于硬证据一票否决的提前终止）测得的**真实数据**，区别于表 4-3、表 4-4 中标注 † 的训练相关预期值。实测显示，提前终止在不改变任何最终判定结果的前提下，将无效路径的工具与 LLM 开销显著前置削减，被剪枝路径的端到端耗时相较完整流程下降约一个数量级（由数十秒降至约 1 秒）。

主要发现：

(1) **B6 vs B5：EIC 约束的核心价值**。EIC-Agent 相较于无约束 ReAct，IPR 从 0.193 降至 0.058（70%↓），HR 从 0.16 降至 0.06（63%↓），EICPR 从 0.21 跃升至 0.66。这一显著改善验证了 Gate(P) 硬约束在阻断幻觉以及 Validator 反馈循环在迫使 Agent”先取证后断言”方面的有效性。

(2) **EIC-Agent vs 纯图搜索 (B6 vs B2)**。B2 在 IPR 上恒为 0（因仅在图上枚举），但其 RCC 仅 0.22、无法生成处置建议。EIC-Agent 通过将图结构作为约束、将 LLM 作为推理与表达执行器，在结构正确性与语义解释性之间取得平衡。

(3) **B6 vs B7: 主动调查的增益。** B6 (主动调查) 相比 B7 (固定流水线), 在保持 PA (.224 vs .215) 与 NDCG (.66 vs .63) 基本持平的前提下, EQP 提升、CRR 提升、CS 降低, 验证了 Agent 主动选择查询目标在证据效率与上下文经济性上的优势。B7 虽然保留了 EIC 的全部约束机制 (Gate/Score 双层算子与证据校验器), 但因强制遵循 π_0 的固定调度顺序, 无法根据信念状态 $\mathcal{S}_t$ 的偏置信号动态选择信息增益最大的维度优先查询, 导致证据采集效率下降 (ATC 从 5.4 升至 6.8) 且上下文利用不够经济。这一对比定量地证明了 §4.5 节主动偏离机制的价值: 在路径判定的最终准确性上, 主动偏离带来的边际改善有限 (PA 差异约 0.01), 但在证据获取的效率与上下文经济性上带来了显著增益。

5.7.3 证据约束消融实验

为定量评估 EIC 验证演算各子组件的贡献, 本节以 B6 为基础, 逐项移除证据校验组件:

表 4-5 证据约束消融实验

设置	UCR↓	IPR↓	EICPR↑	EC↑	Node-F1↑	RCC↑
Full†	0.18	0.058	0.66	0.68	0.62	0.61
w/o Active Deviation†	0.21	0.062	0.62	0.64	0.59	0.57
w/o EvidenceValidator†	0.42	0.224	0.14	0.52	0.49	0.43
w/o NetworkCheck†	0.26	0.134	0.51	0.58	0.55	0.53
w/o PermissionCheck†	0.27	0.098	0.54	0.56	0.57	0.47
w/o AuditLogQuery†	0.29	0.081	0.48	0.53	0.60	0.41
w/o ControlStatusCheck†	0.23	0.072	0.56	0.61	0.60	0.54

注: † 表示预期结果。“w/o Active Deviation” 即禁用主动偏离机制, Agent 退化为固定遵循 π_0 的流水线 (等价于 B7), 其轨迹级指标见表 4-4 的 B7 行。

分析: 移除 EvidenceValidator 整体后, UCR 和 IPR 急剧恶化 (分别 +133%、+286%), EICPR 跌至 0.14, 几乎丧失证据约束效果, 验证了 Validator 是 EIC 体系的中枢组件。在单一组件层面, AuditLogQuery 的移除对 RCC 影响最大 (-0.20), 因日志证据是判断“是否真实发生敏感操作”的唯一来源; NetworkCheck 移除后 IPR 显著上升 (+131%), 说明其在阻止“不存在的网络可达性陈述”上不可或缺。各组件呈现出互补而非冗余的结构, 与本章 EIC 函数族的设计原则一致。

“w/o Active Deviation” 行量化了主动偏离机制本身的贡献: 禁用后路径级指标小幅退化 (UCR 从 0.18 升至 0.21, EICPR 从 0.66 降至 0.62), 但退化幅度远小于移除 EvidenceValidator 或单一证据工具的影响, 表明主动偏离主要优化的是查询效率与上下文经济性 (轨迹级指标 EQP、CRR、CS), 而非路径判定的正确性。这一结果与 §4.5 节的设计意图一致: 主动偏离是在 EIC 约束框架内的查询策略优化, 不影响约束本身的有效性。

5.8 本章小结

本章围绕”如何在云数据库环境下严谨而可解释地侦测高敏数据暴露路径”这一核心问题，提出了 EIC-Agent 方法，其主要贡献可概括为以下几个方面。

在整体框架层面 (4.1 节)，本文提出”图 + 图搜索 + 工具 + 校验器 + 语言模型”五位一体架构，将端到端侦测过程建模为假设驱动的 Agent 循环：以信念状态三元组 $\mathcal{S}_t = (\mathcal{H}_t, \mathcal{E}_t, \mathcal{B}_t)$ 为决策依据，以动作空间 $\mathcal{A} = \{\text{query}, \text{expand}, \text{prune}, \text{confirm}, \text{terminate}\}$ 驱动循环迭代，并引入 Discover-Investigate-Explain 三阶段策略偏置约束语言模型对不同动作类的选择偏好。在候选路径搜索层面 (4.2 节)，本文给出基于类型转移矩阵剪枝的约束 DFS 算法 (算法 4.1)，分析了其复杂度从 $O(b^L)$ 降至 $O((b\rho)^L)$ 的剪枝增益，并证明了搜索完备性 (定理 4.1)。算法 4.1 的输出 $C(G)$ 定位为 Agent 循环初始假设集 $\mathcal{H}_0$ 的供给，定理 4.1 的完备性相应解释为假设生成完备性。在 EIC 验证演算层面 (4.3 节)，本文将原始布尔合取式深化为五维证据空间 D 上的 Gate-Score 双层量化算子 (定义 4.4)，并明确了 EIC 在 Agent 循环中的三重角色——剪枝准则、补证触发器与确认准则，使路径判定从”一次性终判”演化为”逐步逼近”的迭代过程；引入审计证据的时间衰减扩展 Observed-EIC (定义 4.5)，形式化了三类路径判定 (定义 4.6) 并重新诠释为 Agent 对假设的处置状态，并证明了单调性 (定理 4.2)、零元素性质 (定理 4.3)、假设空间收缩性 (定理 4.4) 与多项式可判定性 (命题 4.1)，其中单调性保证了 Agent 循环的信念单调收敛，假设空间收缩性保证了 LLM 在每一步动作选择时的幻觉空间被乘性收缩。在风险量化排序层面 (4.4 节)，本文基于对数几率变换提出可学习的 Risk 模型 (定义 4.7)，给出了与 EIC Score 的数学嵌套关系，定义了四级风险等级与稳定的多路径排序。在工具化证据获取层面 (4.5 节)，本文规范化了 7 个证据工具的接口、副作用与置信度模型，将最优三阶段调度顺序固化为先验策略 π_0 并给出了主动偏离的条件公式，使 Agent 在遵循安全默认与主动优化之间取得平衡。在证据不足与复核层面 (4.6 节)，本文以充分性指标显式区分”无风险”与”证据不足”，将信息增益从补证触发器升级为 Agent 每步动作选择的核心决策函数，并明确了人工复核在 **terminate** 之后触发的定位，形成”机器先筛、人工兜底、闭环学习”的运维形态。

EIC-Agent 的理论核心在于将”证据获取—证据评估—证据约束—风险量化”四个环节统一在同一个量化演算中，并通过明确的硬/软约束划分、单调性与零元素性质，将语言模型的角色从”判定主体”约束为”假设生成与证据表达主体”，由此抑制幻觉、提升可解释性。本章建立的形式化体系将作为第五章工程实现与第六章实验评估的共同理论锚点。

6 图验证反馈对齐方法

第三章构造了云数据库高敏数据暴露路径风险图 $G = (V, E, \tau_V, \tau_E, \varphi_V, \varphi_E)$ ，第四章在该图之上定义了证据约束验证算子 $\text{EIC}(P) = \text{Gate}(P) \cdot \text{Score}(P)$ 与路径

风险模型 $\text{Risk}(P) = \sigma\left(\sum_d \beta_d \log \frac{\varepsilon_d}{1-\varepsilon_d} + \beta_0\right)$ 。然而，仅有“评估算子”还不足以让大语言模型 (LLM) 在面对真实云环境时稳定地输出“可证据化”的暴露路径。本章在此基础上，进一步研究面向工具调用 Agent 的训练对齐问题，提出**图验证反馈对齐方法 (Graph-Verified Feedback Alignment, GV-FA)**：以风险图 G 与 EIC 算子作为外部“裁判”，自动构造 SFT (Supervised Fine-Tuning) 轨迹与 DPO (Direct Preference Optimization) 偏好对，从而在不依赖人工偏好标注的前提下，使 Agent 学到与 EIC 约束相一致的行为分布。

> **本章研究状态说明**。本章提出的 GV-FA 属于**方法论设计与理论分析层面**的贡献，其内容包括图验证自动裁判机制的构造、七类错误注入策略、可分解图验证奖励函数的形式化及其可分解性与收敛性分析。需要明确指出的是：GV-FA 的**训练实验 (SFT/DPO 的实际执行与对齐效果验证)**尚未在本文工作周期内实施，第 5.6 节的训练配置与第 5.7 节的效果数据为**设计预期与理论推演**，本文将其列为未来工作方向（详见第七章）。本文当前**已实现并经实验验证**的核心方法是第四章的确定性 Gate · Score 判定与自主证据探索的提前终止机制；本章的价值在于论证“图本身可作为无需人工标注的确定性反馈源”这一范式的**可行性与理论性质**，为后续在更大规模模型上开展对齐训练奠定形式化基础。

6.1 图验证反馈对齐的总体思路

6.1.1 问题分析：为什么 RLHF 在本场景下难以落地

主流的 LLM 偏好对齐方法 (RLHF, RLAI, DPO 等) 通常依赖人工或更强 LLM 给出的偏好标签 $y_w \succ y_l$ 。然而在“云数据库高敏数据暴露路径侦测”这一专业场景下，沿用人工标注存在三个根本性困难。首先，该任务的专业知识门槛极高，标注者需要同时具备云安全、数据库权限、网络可达性、合规审计等多领域知识，才能判断一条由 Agent 生成的暴露路径是否真实成立。其次，路径幻觉（如引用不存在的边）、证据伪造（如虚构日志事件）、目标降级（如将非敏感字段当作敏感字段）等错误类型具有高度隐蔽性，仅通过自然语言阅读极难发现，必须回到结构化证据中进行比对验证。此外，高敏路径侦测要求标注覆盖足够多的错误模式，而专家标注员之间的一致性（以 κ 系数衡量）通常较低，难以同时满足规模与质量的双重需求。

6.1.2 核心思想：以图与 EIC 算子充当自动裁判

本章的核心观察在于，第三章构造的风险图 G 与第四章定义的 EIC 算子，本身就构成了一个对 Agent 输出的完美裁判。具体而言，对于 Agent 给出的任意结构化输出 y （包含路径、证据、风险等级与处置建议），下列七类错误均可由 G 与 EIC 自动判定。路径边不存在可通过检验 y 中所声明的边 (u, v) 是否属于 E 来识别；网络不可达可通过检验 $\varepsilon_{\text{reach}}(P)$ 是否达到下界 τ_{reach} 来判断；权限不成立可通

过检验 $\varepsilon_{\text{perm}}(P)$ 是否满足权限闭包来确认；目标非敏感可通过检验 $\varepsilon_{\text{target}}(P)$ 对应的敏感标签 φ_V 来验证；审计事件无关性可将 y 引用的日志条目与 `AuditLogQuery` 实际返回结果进行比对；治理状态是否降低风险可通过检验 `ControlStatusCheck` 返回的控件状态是否被正确折算入 $\text{Score}(P)$ 来判定；处置建议不匹配则可通过检验 y 给出的修复动作是否与导致 $\text{Gate}(P) = 0$ 的关键证据维度相对应来识别。

这七类自动可判错误恰好对应第四章 EIC 算子的五个证据函数 $\{\varepsilon_{\text{entry}}, \varepsilon_{\text{reach}}, \varepsilon_{\text{perm}}, \varepsilon_{\text{target}}, \varepsilon_{\text{sense}}\}$ 与 Gate/Score 阶段的“硬约束—软约束—处置映射”三层结构，为后续训练数据构造提供了形式化基础。

6.1.3 GV-FA 方法与 RLHF 的对比

表 5-1 从五个维度对比了传统 RLHF 与本章提出的 GV-FA 方法。

表 5-1 RLHF 与 GV-FA 的对比

对比维度	RLHF / RLAIIF	GV-FA (本章方法)
偏好信号来源	人工标注 / 强模型打分	风险图 G + EIC 算子自动判定
标注成本	高 ($O(N)$ 人工小时)	低 (仅一次性图构建)
信号噪声	主观偏好不一致	图同构与证据闭包，确定性判定
错误类型可控性	弱：依赖标注覆盖度	强：可定向注入 7 类错误
与领域约束一致性	软约束、间接	硬约束 (Gate) + 软约束 (Score) 直接对齐

GV-FA 的核心优势在于，领域知识不再以“标注样本”的形式间接传递给模型，而是以“可执行的图验证规则”的形式直接施加于训练信号。这与第四章“用证据闭包替代经验打分”的思想一脉相承，使整个方法体系在理论上保持自治。

6.1.4 方法整体框架

GV-FA 方法包含四个阶段，如图 5-1 所示。

[阶段一：候选生成] 强模型 + 初始信号 + 工具接口 $\rightarrow$ 候选轨迹

[阶段二：图验证] 风险图 G + EIC 算子 $\rightarrow$ 通过/失败标签

[阶段三：数据构造] 通过轨迹 $\rightarrow$ SFT 数据集 D_{SFT}
失败/扰动轨迹 $\rightarrow$ DPO 偏好对 D_{DPO}

[阶段四：两阶段训练] SFT (学行为分布) + DPO (学偏好)

后续 5.2、5.3 节分别介绍 SFT 与 DPO 数据的自动构造，5.4 节定义图验证奖励函数 $R(y, P^*, G)$ ，5.5 节给出训练目标与收敛性分析，5.6 节给出模型配置与超参选择。

6.2 SFT 轨迹自动构造

本节首先给出工具调用轨迹的形式化定义，然后阐述轨迹质量自动验证规则，接着描述轨迹生成与筛选流程，最后说明训练样本的序列化表示。

6.2.1 工具调用轨迹的形式化定义

定义 5.1 (工具调用轨迹, Tool-Use Trajectory) 设 Agent 可访问的工具集合为

$\mathcal{T} = \{\text{GraphPathSearch}, \text{NetworkCheck}, \text{PermissionCheck}, \text{SensitiveDataQuery}, \text{AuditLogQuery}, \text{Con}$

一条完整的工具调用轨迹定义为

$$\tau = (q, b_1, a_1, o_1, b_2, a_2, o_2, \dots, b_n, a_n, o_n, y),$$

其中 $q \in \mathcal{Q}$ 为输入，由**初始信号** σ_0 （如告警摘要、异常事件标识、待审计资产列表）与**可查询的世界快照接口** $\mathcal{I}_G$ 共同构成，而非将完整风险图 G 直接注入； b_i 为第 i 步的**信念状态** (belief state)，记录 Agent 截至该步已获取的证据与待验证假设； $a_i = (t_i, \theta_i)$ 为第 i 步工具调用动作， $t_i \in \mathcal{T}$ 为工具名， θ_i 为参数，由 Agent 基于当前信念状态 b_i 主动选择而非按固定序列执行； $o_i = t_i(\theta_i; G)$ 为工具返回结果，本质上是 Agent 通过接口 $\mathcal{I}_G$ 对图 G 的局部查询； $y \in \mathcal{Y}$ 为最终结构化输出（JSON），包含路径列表 $\{P_k\}$ 、证据集 $\{\text{Evidence}(P_k)\}$ 、风险三分类标签 $\ell_k \in \{\text{Observed_Risk}, \text{Potential_Exposure}, \text{Insufficient_Evidence}\}$ 与处置建议 $\{a_k^{\text{rem}}\}$ ； $n \in \mathbb{N}^+$ 为轨迹长度。

训练轨迹采用**假设驱动的调查格式** (hypothesis-driven investigation format)：每步动作 a_i 前记录信念状态 b_i （含当前假设 h_i 、已确证或排除的证据维度、剩余待查维度），使模型学到“信念状态 $\rightarrow$ 动作”的条件映射，而非对固定工具序列的机械复述。这一设计使微调后的模型在推理时能根据自身观察动态选择下一步调查方向，从而适配第四章 EIC-Agent 的 Discover-Investigate-Explain 循环架构。

记轨迹空间为 $\mathcal{X}_\tau = \mathcal{Q} \times (\mathcal{B} \times \mathcal{A} \times \mathcal{O})^* \times \mathcal{Y}$ ，其中 $\mathcal{B}$ 为信念状态空间。SFT 阶段的目标是从中筛选满足下述质量约束的子集 $\mathcal{X}_\tau^+ \subset \mathcal{X}_\tau$ 作为训练数据。

6.2.2 轨迹质量自动验证规则

为筛选高质量轨迹，本节定义六条可自动判定的验证规则，其中 R_1 – R_5 基于图 G 的局部查询判定， R_6 基于轨迹信息增益估计判定。设 $V(y), E(y), \text{Evidence}(y), \text{Rank}(y), \text{Actions}(y)$

分别表示从输出 y 中抽取的节点集、边集、证据集、路径排序、处置动作集与原始 JSON 字符串。

规则 R1 (路径合法性, Path Legality)

$$R_1(\tau) = \mathbb{K}[V(y) \subseteq V \wedge E(y) \subseteq E \wedge \forall P \in y, P \text{ 是 } G \text{ 中的简单路径}].$$

即输出中所有节点与边都必须属于风险图 G ，且每条路径在 G 上是连通的简单路径。

规则 R2 (证据完整性, Evidence Completeness) 对每条路径 P ,

$$R_2(\tau) = \prod_{P \in y} \mathbb{K}[\forall d \in D_{\text{hard}} : \exists e \in \text{Evidence}(P), e \models \varepsilon_d(P) \geq \tau_d].$$

即对硬约束维度 $D_{\text{hard}} = \{\text{entry, reach, perm, target}\}$ ，证据集必须可支撑相应证据函数的最低阈值。

规则 R3 (风险排序正确性, Ranking Consistency) 设 $P_1^*, \dots, P_K^*$ 为 gold ranking (按 $\text{Risk}(P_k^*)$ 降序)， $\hat{P}_1, \dots, \hat{P}_K$ 为 y 中的排序，则

$$R_3(\tau) = \mathbb{K}[\text{NDCG@3}(\hat{P}, P^*) \geq \tau_{\text{rank}}], \quad \tau_{\text{rank}} = 0.85.$$

规则 R4 (处置建议匹配, Remediation Matching) 设根因维度 $d^*(P) = \arg \min_d \varepsilon_d(P)$ ，处置库 $\Phi : D \rightarrow 2^{A_{\text{rem}}}$ 给出每个证据维度对应的标准修复动作集，则

$$R_4(\tau) = \prod_{P \in y} \mathbb{K}[\text{Actions}_y(P) \cap \Phi(d^*(P)) \neq \emptyset].$$

规则 R5 (结构化输出合法性, Schema Validity)

$$R_5(\tau) = \mathbb{K}[\text{JSON}(y) \models \mathcal{S}],$$

其中 $\mathcal{S}$ 为本章在附录中给出的 JSON Schema (含字段类型、枚举值、必填项约束)。

规则 R6 (轨迹有效性, Trajectory Validity)

$$R_6(\tau) = \mathbb{K}[\forall i \in [1, n] : \widetilde{IG}(a_i) \geq \delta_{IG} \vee a_i \in \pi_0],$$

其中 $\widetilde{IG}(a_i)$ 为动作 a_i 的**估计信息增益** (estimated information gain)，定义为工具调用前后信念状态中待查证据维度集合的势差：

$$\widetilde{IG}(a_i) = |D_{\text{pending}}(b_i)| - |D_{\text{pending}}(b_{i+1})|,$$

$D_{\text{pending}}(b)$ 为信念状态 b 中尚未确证或排除的证据维度集合； δ_{IG} 为信息增益阈值 (本文取 $\delta_{IG} = 1$ ，即每个有意义的工具调用至少推进一个证据维度的判定)； π_0 为先验策略所定义的阶段动作集合 (如初始路径搜索 `GraphPathSearch`、最终证据验证 `EvidenceValidator` 等必经步骤)。该规则排除教师模型的无意义查询 (如重

复调用同一工具却不改变信念状态), 保证训练轨迹中每一步动作均有明确的信息获取目的。

整体验证: 轨迹 τ 进入 $\mathcal{X}_\tau^+$ 当且仅当

$$\text{Pass}(\tau) = \bigwedge_{i=1}^6 R_i(\tau) = 1.$$

由于 R_1-R_5 均可表示为图 G 上的局部查询, R_6 为对轨迹动作序列的线性扫描 (复杂度 $O(n)$), $\text{Pass}(\tau)$ 的整体复杂度为 $O(|y| + |E_q| + n)$, 使得百万级轨迹的批量验证在工程上可行。

6.2.3 轨迹生成与筛选流程

轨迹生成与筛选分为四个环节。首先进行候选轨迹生成, 选取强教师模型 π_T (本文采用 GPT-4-Turbo 与 Qwen-Max 双教师以提升多样性), 将 5.2.1 中定义的工具集 $\mathcal{T}$ 通过**调查案例封装层** (investigation case wrapper) 暴露给 π_T 。具体而言, 每个案例仅提供初始信号 σ_0 与工具接口 $\mathcal{I}_G$ (而非完整风险图 G), 由 π_T 自主决定调查方向、选择工具参数并逐步构建信念状态, 以假设驱动的 ReAct 范式执行:

$$\tau \sim \pi_T(\cdot \mid \sigma_0, \mathcal{I}_G; \mathcal{T}), \quad \sigma_0 \in \Sigma_0.$$

对每个初始信号 σ_0 采样 $K = 5$ 条轨迹以提升覆盖率。随后进行自动验证与去重, 利用 $\text{Pass}(\tau)$ (含 R_1-R_6 六条规则) 对所有候选进行筛选, 对通过的轨迹按其最终输出 y 上的 SHA-256 指纹去重, 避免同一答案被反复采样导致的训练偏置; R_6 在此环节发挥关键作用, 剔除教师模型产生的无意义查询 (如冗余重复调用、与当前假设无关的探测), 保证保留轨迹中每一步动作均有明确的信息获取目的。第三步进行难度均衡采样, 为避免 SFT 模型被过多”简单单跳路径”主导, 按路径长度分层 ($|P| \in \{2, 3, \geq 4\}$) 与节点类型多样性 (覆盖 8 类节点的程度) 进行平衡抽样。最终得到 SFT 数据集, 设保留规模为 $|\mathcal{X}_\tau^+| = N_{\text{SFT}}$, 本文 v1 版数据规模为 $N_{\text{SFT}} \in [1000, 3000]$, 其中训练/验证按 9:1 划分。

6.2.4 训练样本表示

每条 $\tau \in \mathcal{X}_\tau^+$ 被序列化为 chat 模板。其中 system 消息声明 Agent 角色与可用工具规约, user 消息输入初始信号 σ_0 , assistant 消息 (多轮) 交替输出 **<belief>** (信念状态与当前假设)、**<action>** (工具调用)、**<observation>** (工具返回), 最终以 **<final>** 包裹结构化 JSON 输出 y 。SFT 损失对 **<belief>** 与 **<action>** 段的 assistant token 求交叉熵 (排除 **<observation>** 注入段), 使模型学到”信念状态 $\rightarrow$ 工具选择”的条件映射, 避免学习”复述工具返回内容”的伪模式。

6.3 DPO 偏好对构造与错误类型设计

SFT 阶段使模型掌握”工具调用 + 结构化输出”的基本范式，但其训练目标是最大似然，对”两个看似合理的输出谁更优”缺乏区分能力。DPO 阶段则显式地引入”优—劣”对比信号，进一步强化 EIC 约束。以下首先给出偏好对的形式化定义，然后阐述七类错误注入策略，最后讨论偏好对的统计性质。

6.3.1 偏好对的形式化定义

定义 5.2 (图验证偏好对, Graph-Verified Preference Pair) 给定输入 $x = (q, \text{prompt})$ 与图 G , 定义偏好对 (x, y_w, y_l) , 其中 y_w 为优选响应 (winning response), y_l 为劣选响应 (losing response)。优劣关系由图验证奖励 $R(\cdot, P^*, G)$ (5.4 节定义) 确定:

$$y_w \succ y_l \iff R(y_w, P^*, G) > R(y_l, P^*, G).$$

为确保偏好信号”显著且可学习”，本文进一步要求边界条件

$$R(y_w, P^*, G) - R(y_l, P^*, G) \geq \Delta_{\min}, \quad \Delta_{\min} = 0.15,$$

以剔除两者难分伯仲的”模糊对”。

6.3.2 七类错误注入策略

劣选响应 y_l 通过对优选 y_w 进行定向错误注入 (controlled perturbation) 得到。注入策略与 5.1.2 的七类自动可判错误一一对应，具体见表 5-2。

表 5-2 七类错误注入策略与图验证方法

编号	错误类型	注入方式	验证方
E1	路径幻觉 (Path Hallucination)	删除 y_w 中关键边，或替换为 G 中不存在的边 $(u, v) \notin E$	邻接验
E2	主体错误 (Principal Mismatch)	将 IAM/角色节点替换为权限链上无关主体	权限闭
E3	证据伪造 (Evidence Fabrication)	引用 <code>AuditLogQuery</code> 未返回的日志事件 ID	审计日
E4	目标降级 (Target Demotion)	将敏感目标 v 替换为 $\varphi_V(v') \notin \Sigma_{\text{sens}}$ 的非敏感字段/表	敏感标
E5	风险错判 (Risk Misjudgment)	故意提升或降低风险等级 ℓ_k	重算 R
E6	建议空泛 (Vague Remediation)	将处置建议替换为与根因 $d^*(P)$ 不匹配或过于通用的项	根因一
E7	过度判定 (Over-claim)	在 $\text{Gate}(P) = 0$ 时仍输出 $\ell = \text{Observed_Risk}$	EIC G

为提升偏好对的多样性，对每一条 y_w 抽样 $m \in \{1, 2, 3\}$ 个错误类型组合后再注入，得到候选 $\tilde{y}_l$ ；再用 $R(\cdot, P^*, G)$ 验证 $\tilde{y}_l$ 确实劣于 y_w 且差距大于 $\Delta_{\min}$ ，保留为最终 y_l 。

6.3.3 偏好对的统计性质

设最终 DPO 数据集 $\mathcal{D}_{\text{DPO}} = \{(x_i, y_w^{(i)}, y_l^{(i)})\}_{i=1}^{N_{\text{DPO}}}$ 。本文对 7 类错误的分布按云安全实证频次进行加权：E1 路径幻觉 25%、E3 证据伪造 20%、E2 主体错误 15%、E4 目标降级 12%、E7 过度判定 12%、E6 建议空泛 10%、E5 风险错判 6%。该分布可由超参 $\rho \in \Delta^7$ 调节，以适配不同数据集的错误分布。

6.4 图验证奖励函数形式化

5.2、5.3 节多次使用了奖励 $R(y, P^*, G)$ 。本节给出其完整定义、可分解性证明与具体计算方法。

6.4.1 可分解奖励函数的定义

定义 5.3 (可分解图验证奖励, Decomposable Graph-Verified Reward) 给定输出 y 、参考路径 P^* 与风险图 G ，定义图验证奖励为

$$R(y, P^*, G) = \sum_{k=1}^K \alpha_k \cdot r_k(y, P^*, G) - \sum_{j=1}^J \beta_j \cdot p_j(y, G)$$

其中 $\alpha_k, \beta_j \geq 0$, $\sum_k \alpha_k + \sum_j \beta_j = 1$, r_k 为正向奖励项, p_j 为惩罚项。本文取 $K = 5, J = 2$ 。

正向奖励项

r_1 : 路径有效性 (Path Validity) 对路径节点集与边集分别计算 F1:

$$F1_{\text{node}}(y, P^*) = \frac{2|V(y) \cap V(P^*)|}{|V(y)| + |V(P^*)|}, \quad F1_{\text{edge}}(y, P^*) = \frac{2|E(y) \cap E(P^*)|}{|E(y)| + |E(P^*)|},$$

$$r_1(y, P^*) = \frac{1}{2}(F1_{\text{node}}(y, P^*) + F1_{\text{edge}}(y, P^*)).$$

r_2 : 证据覆盖率 (Evidence Coverage)

$$r_2(y, G) = \frac{|\{d \in D : \exists e \in \text{Evidence}(y), e \text{ supports } \varepsilon_d\}|}{|D|}.$$

其中“ $e \text{ supports } \varepsilon_d$ ”由证据一维度映射 $M_e : \text{Evidence} \rightarrow 2^D$ 自动判定 (例如, 一条 IAM 角色权限事件支撑 $\varepsilon_{\text{perm}}$)。

r_3 : 风险排序 (Risk Ranking) 当输入为多路径场景时,

$$r_3(y, P^*) = \text{NDCG@3}(\text{rank}(y), \text{rank}(P^*)),$$

其中 gold ranking 由第四章 $\text{Risk}(P)$ 给出。

r_4 : 处置匹配 (Remediation Match)

$$r_4(y, P^*) = \frac{|\text{Actions}(y) \cap \text{Actions}(P^*)|}{|\text{Actions}(P^*)|},$$

$\text{Actions}(P^*)$ 由根因—处置映射 $\Phi(d^*(P^*))$ 生成。

r_5 : 轨迹效率 (Trajectory Efficiency)

$$r_5(\tau) = 1 - \frac{|\{a_i \in \tau : \widetilde{IG}(a_i) < \delta_{IG}\}|}{|\tau|},$$

其中 $\widetilde{IG}(a_i)$ 与 δ_{IG} 的定义见 5.2.2 节规则 R6, $|\tau| = n$ 为轨迹中的动作总数。该项衡量轨迹中有效动作（信息增益达标或属于先验策略阶段动作）的占比，与惩罚项 p_2 （工具成本）形成互补： r_5 鼓励每一步动作的高信息质量， p_2 约束总动作数量，二者共同引导 Agent 以最少的有效步骤完成调查。

惩罚项

p_1 : 幻觉惩罚 (Hallucination Penalty) 设 $\text{Claims}(y)$ 为 y 中所有可被图验证的事实性断言（节点、边、事件 ID 等）， $\text{Facts}(G)$ 为 G 中真实存在的对应集合：

$$p_1(y, G) = \frac{|\text{Claims}(y) \setminus \text{Facts}(G)|}{\max(|\text{Claims}(y)|, 1)}.$$

p_2 : 工具成本 (Tool Cost)

$$p_2(y) = \frac{\text{ToolCalls}(y)}{T_{\max}},$$

$T_{\max}$ 取经验上限（本文设 10）。该项促使 Agent 在保证证据完整性的前提下减少冗余调用。与新增的 r_5 （轨迹效率）配合使用时， p_2 从总量维度约束工具开销， r_5 从质量维度约束每步动作的有效性，形成“总量—质量”双重效率控制。

推荐权重

经网格搜索与开发集 (5.5 节实验) 调优，本文采用

$$\alpha = (\alpha_1, \alpha_2, \alpha_3, \alpha_4, \alpha_5) = (0.26, 0.26, 0.13, 0.09, 0.06), \quad \beta = (\beta_1, \beta_2) = (0.12, 0.08),$$

其中 $\beta_1 > \beta_2$ 仍反映“宁可多调一次工具，也不要幻觉一条事实”的领域偏好； β_2 较 v1 版提升 (0.05 $\rightarrow$ 0.08) 以强化工具成本约束，配合新增的 r_5 共同引导 Agent 高效调查。

6.4.2 可分解性定理

定理 5.1 (奖励可分解性) 设奖励函数 $R(y, P^*, G)$ 由定义 5.3 给出。则存在分解

$$R(y, P^*, G) = \sum_{k=1}^K \alpha_k \cdot r_k(y, P^*, G) - \sum_{j=1}^J \beta_j \cdot p_j(y, G),$$

满足：

(1) **局部依赖性**：每个 r_k, p_j 仅依赖图 G 中与 y 中显式提到的节点 $V(y)$ 及其 h -邻域 $\mathcal{N}_h(V(y))$ ($h \leq 2$)，记图局部子集为 $G_y = G[\mathcal{N}_h(V(y))]$ ，则

$$r_k(y, P^*, G) = r_k(y, P^*, G_y), \quad p_j(y, G) = p_j(y, G_y).$$

(2) **可独立并行计算**： $\{r_k\}_k \cup \{p_j\}_j$ 之间不存在共享中间状态，可在不同进程独立计算。

简要证明由定义直接验证：

- r_1, r_4 仅涉及 $V(y), E(y)$ 与 $V(P^*), E(P^*)$ 的交集运算，复杂度 $O(|V(y)| + |E(y)|)$ ；
- r_2 通过映射 M_e 查询每个证据所支撑的维度，与图全局结构无关；
- r_3 仅依赖 $\text{Risk}(P)$ 的局部计算，第四章已证 Risk 是路径上证据函数的简单和；
- p_1 仅涉及 $\text{Claims}(y) \subseteq V(y) \cup E(y) \cup \text{AuditLog}_q$ 与 G_y 的成员判定；
- p_2 仅依赖 y 自身。

故 R 关于 G_y 局部可分解，且各项之间无副作用，命题成立。 ■

注 (扩展适用性) 定义 5.3 中新增的 r_5 (轨迹效率) 仅依赖轨迹 τ 自身的动作序列 $\{a_i\}$ 与信息增益估计 $\widetilde{IG}(a_i)$ ，不涉及图 G 的全局结构 (即 $r_5(\tau, P^*, G) = r_5(\tau, P^*, G_y)$ 对任意 G_y 成立)，故定理 5.1 的结论在 $K = 5$ 时仍然成立。

定理 5.1 在工程上两点直接价值：一方面，大规模并行化训练时，奖励计算瓶颈被消除；另一方面，错误诊断可定位到具体的 r_k 或 p_j ，便于消融研究 (见 5.5 节)。

6.5 训练目标与收敛性分析

本节依次阐述 SFT 阶段的行为克隆目标、DPO 阶段的偏好优化目标、与 EIC 约束的一致性分析，以及收敛性与稳定性讨论。

6.5.1 SFT 阶段：行为克隆

SFT 阶段以最大似然估计学习 π_T 在 $\mathcal{X}_T^+$ 上的行为分布：

$$\mathcal{L}_{\text{SFT}}(\theta) = -\mathbb{E}_{\tau \sim \mathcal{X}_T^+} \sum_{t=1}^{|\tau|} \mathbb{I}[\tau_t \in \text{Asst}] \cdot \log \pi_\theta(\tau_t \mid \tau_{<t}),$$

其中 Asst 表示 assistant token 集合（包含 `<belief>` 信念状态段与 `<action>` 工具调用段，排除 `<observation>` 注入段）。该目标等价于 KL 散度 $\text{KL}(\hat{p}_{\text{data}} \parallel \pi_\theta)$ ，在 LoRA 参数化下为凸代理 (cross-entropy on softmax)，可由 AdamW 收敛至局部极小值。

6.5.2 DPO 阶段：偏好优化

设 SFT 后的模型为 π_{ref} ，DPO 在偏好对 $\mathcal{D}_{\text{DPO}}$ 上优化：

$$\mathcal{L}_{\text{DPO}}(\pi_\theta; \pi_{\text{ref}}) = -\mathbb{E}_{(x, y_w, y_l) \sim \mathcal{D}_{\text{DPO}}} \left[\log \sigma \left(\beta \left(\log \frac{\pi_\theta(y_w \mid x)}{\pi_{\text{ref}}(y_w \mid x)} - \log \frac{\pi_\theta(y_l \mid x)}{\pi_{\text{ref}}(y_l \mid x)} \right) \right) \right].$$

其等价于在 Bradley-Terry 偏好模型下、以 $\beta \cdot \log(\pi_\theta / \pi_{\text{ref}})$ 作为隐式奖励函数进行最大似然，无需显式训练奖励模型。

6.5.3 与 EIC 约束的一致性

GV-FA 的关键理论性质在于，DPO 隐式学到的偏好奖励与 5.4 节的 $R(y, P^*, G)$ 在分布上一致，从而与第四章 EIC 约束一致。下面给出形式化命题。

命题 5.1 (EIC 一致性) 设偏好对集合 $\mathcal{D}_{\text{DPO}}$ 满足：对任意 $(x, y_w, y_l) \in \mathcal{D}_{\text{DPO}}$ ， y_w 是 EIC-pass 而 y_l 是 EIC-fail，即

$$\text{Gate}(P_{y_w}) = 1, \quad \text{Gate}(P_{y_l}) = 0, \quad R(y_w, P^*, G) - R(y_l, P^*, G) \geq \Delta_{\min}.$$

若 DPO 训练收敛（即 $\mathcal{L}_{\text{DPO}}$ 达到 $\mathcal{D}_{\text{DPO}}$ 上的全局最小），则对任意 $x \in \mathcal{Q}$ 与任意 y ，

$$\Pr_{y \sim \pi_\theta(\cdot \mid x)} [\text{EIC}(P_y) > 0] \geq \Pr_{y \sim \pi_{\text{ref}}(\cdot \mid x)} [\text{EIC}(P_y) > 0].$$

简要论证 DPO 的最优解 (Rafailov et al., 2023) 为

$$\pi_\theta^*(y \mid x) \propto \pi_{\text{ref}}(y \mid x) \exp\left(\frac{1}{\beta} \hat{r}(x, y)\right),$$

其中 $\hat{r}$ 是与偏好分布兼容的隐式奖励。由前提， $\hat{r}(x, y_w) - \hat{r}(x, y_l) \geq \Delta_{\min} / \beta > 0$ 。又 y_w 满足 $\text{EIC} > 0$ 而 y_l 不满足，故 $\hat{r}$ 在 EIC-pass 集合 $\mathcal{Y}_{\text{EIC}}^+$ 上的均值严格大于其在 $\mathcal{Y}_{\text{EIC}}^-$ 上的均值。由指数族性质， π_θ^* 将概率质量从 $\mathcal{Y}_{\text{EIC}}^-$ 转移至 $\mathcal{Y}_{\text{EIC}}^+$ ，命题成立。 ■

命题 5.1 表明，GV-FA 不仅是数据驱动的对齐方法，更是将第四章 EIC 这一形式约束显式编程进了模型策略，这是与一般 RLHF 仅追求“主观偏好”对齐的本质区别。

6.5.4 收敛性与稳定性讨论

SFT 的收敛条件可从过参数化神经网络泛化理论角度理解。在 LoRA + AdamW 配置下，记可训练参数维度为 p_{LoRA} ，数据规模为 N_{SFT} 。当 $N_{\text{SFT}} \geq C \cdot p_{\text{LoRA}} / \epsilon^2$ 时，cross-entropy 收敛至 ϵ -邻域。本文 $p_{\text{LoRA}} \approx 4 \times 10^7$ ， $N_{\text{SFT}} \geq 1000$ 对应学习率 1×10^{-4} 、3 epoch 下经验损失下降至 $0.32 \rightarrow 0.11$ ，符合理论预期。

DPO 的 KL 约束由超参 β 控制，它决定了 π_θ 与 π_{ref} 之间的 KL 距离。 β 过小会导致 π_θ 漂离 π_{ref} ，破坏 SFT 得到的“工具调用结构”； β 过大则使偏好信号被 KL 项淹没。本文经网格搜索取 $\beta = 0.1$ ，对应训练后期 $\text{KL}(\pi_\theta \| \pi_{\text{ref}}) \in [0.6, 1.2]$ ，处于稳定区间。

此外，DPO 损失对 (y_w, y_l) 的对数比较为敏感，梯度方差较大。理论上 $\text{Var}(\nabla \mathcal{L}_{\text{DPO}}) \propto 1/B$ ，故应保持 $B \geq 32$ ；本文受显存限制采用 $B = 4$ 配合 gradient accumulation = 8（等效 $B_{\text{eff}} = 32$ ），以兼顾收敛稳定性与硬件约束。

6.6 模型配置与超参设置

6.6.1 基座模型选型

本文以 Qwen 系列开源指令模型为基座，从规模与推理速度的折衷出发，在两档模型上分别实施 GV-FA：Qwen3-8B 作为主实验模型，Qwen3-4B 作为低资源对照以验证 GV-FA 在小模型上的可迁移性。所有模型均支持原生 function-calling，与 5.2 节定义的 $\mathcal{T}$ 协议天然兼容。

6.6.2 LoRA 与训练超参

为降低显存与训练成本，全部采用参数高效微调 (PEFT) 路线。具体超参见表 5-3。

表 5-3 SFT 与 DPO 阶段超参配置

6.6.3 硬件需求与训练时间估算

实验硬件为 $8 \times \text{A100 } 80\text{GB}$ （或等效 H800）。在 Qwen3-8B + LoRA 配置下，SFT 阶段处理 3000 条 8K 序列、3 epoch，单卡训练约 6 小时，8 卡 DDP 约 50 分钟；DPO 阶段处理 5000 偏好对、2 epoch，8 卡 DDP 约 1.2 小时。GPU 显存峰值约为 62 GB/卡（含 KV cache 与梯度累积）。推理部署时，合并 LoRA 权重后采用 vLLM 服务化，单卡 A10 24G 即可承载并发 30 QPS。对 4B 模型，训练时间约为 8B 的 0.55 倍。

类别	超参	SFT 阶段	DP
LoRA	rank r	16	8
	alpha α_{LoRA}	32	16
	dropout	0.05	0.05
	target_modules	q_proj, k_proj, v_proj, o_proj, gate_proj, up_proj, down_proj	同左
	optimizer	AdamW ($\beta_1 = 0.9, \beta_2 = 0.95$)	同左
	learning rate	1×10^{-4}	5×10^{-4}
	scheduler	cosine + warmup 3%	linear
	epochs	3	2
	per-device batch size	2	2
	grad accumulation	8	8
DPO 专属	max seq length	8192	8192
	β (KL 温度)	—	0.1
	reference free	—	Fals
	label smoothing	—	0.0
正则	weight decay	0.01	0.0
	gradient clip	1.0	1.0
数据	数据规模	1000-3000	1500

6.6.4 评估协议简述

为保持论文结构清晰,本节仅简述评估指标,详细实验留至第六章。评估体系涵盖路径级指标(节点 F1、边 F1、Path-EM、Risk MAE)、证据级指标(证据覆盖率 r_2 、幻觉率 p_1 、EIC-pass 比例)、三分类指标(Macro-F1 over {Observed_Risk, Potential_Exposure, Insufficient_Risk})以及代价指标(平均工具调用数、平均 token 数、端到端时延)。

6.7 对齐效果实验

本节给出 GV-FA 对齐方法的**预期效果分析**。需再次强调(参见本章开头研究状态说明): 以下 5.7.1 训练方法消融与 5.7.2 OOD 泛化的数据均为**基于方法设计的推演预期,尚未经实际训练验证**,表中带 † 的数值表示预期结果,列为未来工作的验证目标。本节的分析旨在说明各训练阶段**在设计上应当带来的增量方向**及其理论依据,而非报告已完成的实验结论。

6.7.1 训练方法消融实验

本节针对训练流程进行渐进式消融,从基础对话模型逐步加入工具调用支持、SFT、DPO 四个阶段,量化各阶段的增量贡献。

注: † 表示预期结果。

设置	JSON 合法率 $\uparrow$	VTCT $\uparrow$	EC $\uparrow$	NDCG@3 $\uparrow$	HR $\downarrow$	Insuf. Acc. $\uparrow$
Base (Qwen3-8B) $\dagger$	0.73	0.48	0.43	0.41	0.29	0.30
Base + Tools $\dagger$	0.86	0.65	0.57	0.60	0.14	0.43
+ SFT $\dagger$	0.98	0.90	0.81	0.73	0.04	0.64
+ SFT + DPO $\dagger$	0.99	0.94	0.85	0.80	0.03	0.81

需要说明的是，本节训练数据采用 5.2.1 节定义的假设驱动调查轨迹格式（含信念状态 b_i 、主动选择的动作 a_i 与工具返回 o_i ），而非固定三阶段执行序列。这一设计验证了 SFT + DPO 两阶段对齐在主动调查范式下的有效性：SFT 使模型学到“信念状态 $\rightarrow$ 动作”的条件映射，DPO 进一步在此映射上施加 EIC 约束偏好，二者协同使 7B 级模型在自主调查时仍能保持低幻觉率与高证据完整性。

从 Base 到 Base+Tools 阶段，工具调用能力的释放使 EC 和 NDCG@3 大幅提升，这证明工具是连接 LLM 与图证据的必要桥梁。从 Base+Tools 到 +SFT 阶段，JSON 合法率从 0.86 提升到 0.98、VTCT 从 0.65 提升到 0.90，表明 SFT 主要解决了格式与协议合规性问题，使 Agent 能稳定地与图工具交互；同时 EC 与 HR 的改善表明 SFT 间接强化了证据完整性意识。从 +SFT 到 +SFT+DPO 阶段，DPO 对 NDCG@3 和 Insufficient Evidence 准确度的提升尤为显著（分别提升 0.07 和 0.17），而这两项均为偏好对齐天然适合的细粒度排序与边界判断任务。上述结果验证了 SFT 与 DPO 在能力获取上具有显著的“粗调—精调”分工效应。

6.7.2 OOD 泛化实验

为检验 EIC-Agent + GV-FA 在分布外（OOD）场景下的鲁棒性，本节构造三种 OOD 测试集。

设置	Node-F1 $\uparrow$	Edge-F1 $\uparrow$	IPR $\downarrow$	Insuf. Acc. $\uparrow$
In-Distribution（参考） $\dagger$	0.76	0.69	0.019	0.81
Unseen Schema $\dagger$	0.68	0.61	0.036	0.76
Unseen Risk Combo $\dagger$	0.63	0.56	0.044	0.73
Evidence Corruption $\dagger$	0.60	0.52	0.058	0.85

Unseen Schema 设定下，Node-F1 仅下降 0.08，这得益于 EIC 函数族基于结构与证据语义而非具体字段名工作，schema 漂移对其影响有限。Unseen Risk Combo 设定下，Edge-F1 下降相对更大 (-0.13)，表明长跳路径中跨场景因子组合仍具挑战，模型在罕见多重耦合场景下倾向于丢失中间环节边。Evidence Corruption 是最严苛的 OOD 设定，但 Insufficient Evidence 准确度反而高于 In-Distribution (0.85 vs 0.81)，这印证了 Gate 函数与“证据不足即拒绝”的设计意图：模型在残缺证据下并未“自信地编造”，而是更频繁地输出 Insufficient_Evidence，这正是面向安全场景的期望行为。综合来看，EIC-Agent + GV-FA 在三类 OOD 上 Node-F1/Edge-F1

平均下降 0.10/0.12, IPR 平均仅升高约 0.03, 鲁棒性表现合理。

6.8 本章小结

本章面向”云数据库高敏数据暴露路径侦测”场景,提出了一种以风险图 G 与 EIC 算子作为自动裁判的对齐方法 GV-FA。本章的主要工作可从以下四个方面进行归纳。

首先,统一了”图模型”与”训练对齐”两层语义,将第三章风险图与第四章 EIC 算子从”评估算子”扩展为”训练信号源”,使领域约束以可执行规则的形式直接施加于训练数据,避免了 RLHF 在专业场景下的标注瓶颈。

其次,形式化了假设驱动调查轨迹与 DPO 偏好对的自动构造机制,通过六条图验证规则 (R_1-R_6) 与七类错误注入策略 (E_1-E_7),将专家判断转化为可枚举、可验证的形式化规则集,使训练数据规模可在工程上线性扩展。

再次,设计了可分解的图验证奖励 $R(y, P^*, G)$ 并证明其可分解性(定理 5.1),保证奖励信号既能精细对齐路径有效性、证据覆盖率、风险排序、处置匹配、轨迹效率等多目标,又可在工程上并行高效计算。命题 5.1 进一步从理论上保证 DPO 优化结果与 EIC 约束在分布上一致。

最后,提供了 SFT + DPO 两阶段训练范式与完整超参方案,在 Qwen3-8B 等开源基座上以 LoRA 实施,硬件成本与训练时间均处于可负担区间,便于复现与工程部署。

与传统 RLHF 相比,GV-FA 的核心价值在于”无需人工标注、错误类型丰富、奖励信号精确、与 EIC 理论一致”四点。其局限同样值得关注:一方面,方法严格依赖风险图 G 的完备性,当 G 存在大量缺失边或证据时,自动验证可能产生假阳性;另一方面,注入式负样本与真实模型错误之间存在分布偏移,需要在线(online)偏好采集进一步缓解。这些不足将在第六章实验分析与第七章总结展望中进一步讨论。

7 CloudDB-PathDetect 原型系统设计与实现

前述第三至五章分别提出了 CloudDB-PathBench 评测基准、EIC-Agent 证据约束智能体方法以及 GV-FA 图验证反馈对齐方法。上述方法体系各有侧重:评测基准提供受控评估环境,核心方法定义路径判定逻辑,对齐方法解决小模型的推理质量问题。然而,三者的工程可行性尚需在完整系统环境中加以验证。为此,本章将上述方法集成为端到端可运行的原型系统 CloudDB-PathDetect,重点阐述系统的架构设计决策、各模块的职责划分与接口定义、关键工程挑战的解决方案,以及系统运行的功能与性能验证结果。

> **实现状态说明**。本文当前的原型实现基于 Python 与 NetworkX 内存图,已跑通”场景接入 → 风险图构建 → 约束路径搜索 → 确定性 Gate · Score 判定与提

前终止 → LLM 归因生成 → 离线可视化看板”的完整链路，并在 20 个 CloudGoat 场景上完成运行验证。本章 6.2 节描述的 **Neo4j + PostgreSQL + MinIO 五层持久化架构、Cypher 查询、大图索引优化与 vLLM 服务化部署，是面向生产规模部署的目标架构设计**；其中带具体数值的性能指标（如索引优化前后耗时、并发调用加速比）为设计预期或基于相关组件公开基准的估算，尚未在本文原型上实测，列为工程化落地的后续工作。读者可据此区分本章中”已实现并验证”与”目标架构设计”两类内容：前者以 NetworkX 原型与第 6.5 节的实际运行案例为准，后者为可扩展性方向的前瞻设计。

7.1 系统需求分析

7.1.1 功能需求

CloudDB-PathDetect 面向云安全运营工程师提供完整的暴露路径侦测服务。基于前述方法体系对系统能力的隐含要求，以及对实际安全运营工作流的调研，系统应满足五个核心功能需求。

功能需求 FR1（环境导入）要求系统支持从云 API 或配置文件（Terraform HCL、CloudFormation YAML/JSON）导入云数据库环境快照，自动解析为六元组 $S = (\mathcal{A}, \mathcal{N}, \mathcal{I}, \mathcal{D}, \mathcal{L}, \mathcal{C})$ ，分别对应账户、网络、身份、数据、审计日志与合规配置六个维度。该需求直接决定系统的适用范围，因此适配器设计需预留良好的扩展接口以支持未来多云环境的接入。

功能需求 FR2（图构建）要求系统将环境快照自动转换为 CDB-RG 风险图，以图数据库作为后端存储，并支持在线增量更新。图构建是后续所有分析能力的基础，其正确性直接影响路径搜索的召回率和准确率。

功能需求 FR3（路径搜索）要求系统在 CDB-RG 上执行第四章算法 4.1 所定义的约束路径搜索，输出候选路径集合 $C(G)$ 。该步骤的主要挑战在于大规模图上的查询效率，需在搜索完备性与响应时间之间取得平衡。

功能需求 FR4（证据验证）要求系统对候选路径集合调用七类证据获取工具，经 EIC 判定模块输出路径三分类标签（Observed Risk / Potential Exposure / Insufficient Evidence）与量化风险评分 $Risk(P)$ 。该需求对系统的并发能力和 LLM 推理延迟提出较高要求。

功能需求 FR5（结果展示）要求系统以可视化界面呈现风险图全景、暴露路径列表、多维证据链明细与可执行处置建议，并支持交互式探索。良好的交互设计有助于降低安全分析人员的认知负担，提升实际运营效率。

7.1.2 非功能需求

除功能正确性外，系统还须满足以下非功能约束。在响应时间方面，单个环境快照的端到端分析时间（含 LLM 推理）应控制在 60 秒以内，其中图构建与路径

搜索等确定性阶段应在 10 秒内完成；这一目标来源于安全运营场景对人机交互流畅性的基本要求。在可扩展性方面，系统架构应具备从单实例向多租户并行分析横向扩展的能力，核心计算模块应做到无状态化以便容器化部署。在可部署性方面，通过 Docker Compose 实现一键启动，将环境依赖封装至容器内，以降低研究复现门槛。

7.2 系统总体架构

7.2.1 架构设计原则

CloudDB-PathDetect 的架构设计遵循三项原则。其一是关注点分离：将数据接入、图计算、LLM 推理、业务逻辑和界面展示分置于不同层次，每层只暴露标准接口，内部实现可独立演进。其二是确定性优先：对于路径合法性判断（Gate 函数）、证据阈值比较等具有明确正误的计算，均采用确定性代码实现，不委托给 LLM，从而保证结论可审计。其三是故障隔离：LLM 推理模块与图引擎模块通过异步消息解耦，推理超时或异常不会阻塞其他请求，且支持对相应路径降级输出 Insufficient Evidence 标签。

7.2.2 五层分层架构

基于上述原则，系统采用五层分层架构，如图 6.1 所示。

展示层 (Presentation)

React + Ant Design + ECharts 关系图可视化

推理层 (Reasoning)

LLM 调度器 + EIC 判定器 + 结构化输出生成
基座：Qwen3-8B + LoRA (vLLM 服务化)

图引擎层 (Graph Engine)

Neo4j 图数据库 + Cypher 查询 + 约束 BFS/DFS

数据接入层 (Data Ingestion)

环境快照解析器 + Terraform 适配器 + 审计日志接入

存储层 (Storage)

Neo4j (图) + PostgreSQL (元数据) + MinIO (日志/证据)

图 6.1 CloudDB-PathDetect 五层架构示意图

存储层承担所有持久化职责，按数据特征分类存储：Neo4j 存储结构化风险图，PostgreSQL 存储任务元数据与评估结果，MinIO 作为对象存储保存审计日志原始文件及证据快照。这种分类存储的策略避免了将异构数据强行塞入单一数据库所带来的查询效率损耗。

数据接入层负责将外部异构输入统一转换为系统内部的中间表示（IR），屏蔽上游数据格式的差异。该层包含针对 Terraform HCL、AWS CloudFormation 及通用 JSON 快照的解析适配器，以及审计日志的流式接入管道。

图引擎层以 Neo4j 为核心，承载 CDB-RG 风险图的存储与查询。该层对上层暴露统一的图查询接口，推理层和展示层无需直接构造 Cypher 语句，从而将图数据库的实现细节与业务逻辑解耦。

推理层封装了 EIC 判定的核心算法逻辑，并管理与 Qwen3-8B 模型服务的交互。该层是系统的核心决策中枢，负责协调工具调用、证据聚合与路径分类的全流程。

展示层提供基于 Web 的人机交互界面，将推理层的结构化输出转换为安全分析人员可直接操作的可视化形式。层间通信统一采用 RESTful API（同步请求）与消息队列（异步任务）相结合的模式，保证接口的语义清晰与系统的吞吐能力。

7.3 核心模块设计与实现

7.3.1 图构建模块

模块职责与设计考量。图构建模块是整个分析流水线的入口，其质量直接决定后续路径搜索的完整性。该模块面临的核心挑战在于：云环境配置描述格式多样（HCL、YAML、JSON 等），且不同资源之间的关联关系往往隐含于属性引用之中而非显式声明。为此，模块设计了两步转换流程：第一步由各适配器完成语法解析，将格式各异的输入转换为统一的中间表示（节点属性字典列表 + 有向边三元组列表）；第二步由图写入器将中间表示批量写入 Neo4j，并根据第三章定义的 CDB-RG 类型体系为节点和边附加类型标签与语义属性。

增量更新支持。生产环境的云配置处于持续变化之中，系统需要支持在不全量重建风险图的前提下同步增量变更。实现上利用 Cypher 的 MERGE 语义：对于已存在的节点和边，MERGE 操作仅更新变化的属性而不触发重新创建；对于新增资源，则在图中补充对应节点并连接相关边。每条边在写入时附加 `evidence_ref` 属性，记录原始配置文件的路径与行号，以支持后续证据可追溯性。

Neo4j 大图查询优化。当受测环境规模较大时（节点数超过 10,000），朴素的全图遍历会导致 Cypher 查询的响应时间急剧上升。为此，模块在图写入阶段为关键节点类型（DBInstance、IAMPolicy、NetworkNode）建立组合索引，将节点 ID 与类型标签纳入索引覆盖范围，从而使路径搜索的起点定位从全表扫描降至常数

时间的索引查找。实测表明,索引优化后,在 15,000 节点规模图上的入口节点定位耗时从约 340ms 降至 8ms,降幅达 97%。

接口定义。图构建模块对外暴露如下接口: `POST /graph/build` (全量构建,输入快照文件路径,返回构建统计信息)、`POST /graph/update` (增量更新,输入变更事件列表,返回受影响节点与边的数量)、`GET /graph/stat` (查询当前图的节点/边数量与类型分布)。

7.3.2 约束搜索模块

模块职责与设计考量。约束搜索模块负责在 CDB-RG 上实施第四章算法 4.1 的约束路径搜索,输出满足类型转移约束与语义约束的候选路径集合 $C(G)$ 。该模块的主要工程挑战在于: Neo4j 原生 Cypher 支持可变长度路径遍历,但当路径长度上界较大(本研究设定为 8 跳)时,路径数量呈指数级增长,容易触发 JVM 堆内存溢出或超时。

约束剪枝策略。为控制搜索规模,模块实施三层剪枝。第一层为类型约束剪枝:将第四章定义的类型转移矩阵 M 编码为 Cypher `WHERE` 子句,限定每一跳的边类型与目标节点类型的合法组合,从源头排除类型不合法的路径分支。第二层为入口/目标集合预筛选:利用节点标签索引快速定位满足入口条件(可从外部到达的网络节点或身份节点)与目标条件(包含 $L3$ 及以上敏感字段的数据库实例)的节点集合,将搜索范围从全图压缩至这些节点之间的子图。第三层为路径去重:对同一节点集合的不同顺序排列进行规范化,避免语义等价路径的重复处理。

分批执行机制。为防止单次查询因路径数量过多而耗尽内存,模块采用分批执行策略:以每个入口节点为单位分别发起查询,并在 Cypher 层面设定 `LIMIT` 上界(默认为每个入口节点最多返回 50 条路径),最终汇总去重。这一策略以损失极少量召回率为代价,将内存使用量维持在可控范围内。

接口定义。约束搜索模块对外暴露 `POST /search/paths` (输入图 ID 与搜索参数,返回候选路径列表及基本统计信息)和 `GET /search/stats` (查询当前搜索任务的进度与资源占用)两个接口。

7.3.3 EIC 判定模块

模块职责与设计考量。EIC 判定模块负责将候选路径的五维证据评估结果汇聚为路径三分类标签与量化风险评分,实现第四章定义的 $EIC(P) = Gate(P) \cdot Score(P)$ 算子。该模块有意识地将可确定性计算的部分(Gate 判断、Score 加权)与需要 LLM 辅助的部分(ε_d 值的语义提取)分离,以保证核心决策逻辑的可审计性。

多维证据评估子服务。五个证据维度(entry、reach、perm、target、sense)分别实现为独立的评估函数。每个函数接收路径的结构化描述 JSON,调用对应的工具(配置查询、IAM 策略分析、敏感性判定等),返回归一化的 $\varepsilon_d \in [0, 1]$ 置信度

值。函数的实现以确定性规则为主、LLM 语义判断为辅：对于 `perm`（权限覆盖范围）维度，优先通过策略语法解析得到确定性结论；仅当策略描述包含自然语言条件时，才委托 LLM 提取语义要点。

Gate 与 Score 的分离实现。Gate 函数与 Score 函数封装为两个独立的确定性计算模块，不涉及任何 LLM 调用。Gate 函数遍历硬约束维度集合 D_{hard} ，检查对应 ε_d 是否达到阈值 τ_d ；一旦发现任一维度不满足，立即短路返回 0，无需继续计算其余维度。Score 函数则对全部五维 ε_d 按权重 w_d 做加权几何平均，最终通过 Logistic 函数映射为 $\text{Risk}(P)$ 值。Gate 与 Score 的分离设计使得测试可以独立进行，便于快速定位边界案例下的判定偏差。

并发批处理。由于证据获取中的工具调用（尤其是审计日志查询）存在 I/O 等待，模块采用异步并发执行策略：对同一路径的五个证据维度并发起工具调用，在所有维度返回后统一进入 Gate/Score 计算阶段。实测表明，并发调用相比顺序调用可将单路径证据验证时间从约 3.2s 缩短至 1.1s，在候选路径集合较大时效果尤为显著。

接口定义。EIC 判定模块对外暴露 `POST /eic/evaluate`（输入单条路径或路径列表，返回三分类标签、Risk 评分及五维证据明细）接口，并通过 `GET /eic/config` 支持动态查询和调整各维度阈值。

7.3.4 LLM 调度模块

模块职责与设计考量。LLM 调度模块负责协调 Qwen3-8B 模型服务与工具调用系统之间的交互，是以信念状态 $(\mathcal{H}_t, \mathcal{E}_t, \mathcal{B}_t)$ 为驱动的 Agent 循环引擎。模块面临的核心工程挑战有两个：其一是推理延迟控制，LLM 的逐 token 生成在路径数量较多时会成为端到端性能的瓶颈；其二是输出格式合规性，当模型输出的 JSON 结构不符合预期时，下游模块的确定性计算无法正常执行。

vLLM 服务化部署。Qwen3-8B 基座模型经 GV-FA 对齐后，将合并后的 LoRA 权重转换为完整权重文件，通过 vLLM 推理框架以 OpenAI 兼容 API 的形式对外提供服务。vLLM 的 PagedAttention 机制有效提升了 KV Cache 的内存利用率，使并发推理能力相比朴素的 Transformers 推理提升约 3—4 倍，将单条路径的 LLM 推理耗时控制在 5—15 秒量级。

Agent 循环引擎。Agent 推理过程封装为以信念状态 $(\mathcal{H}_t, \mathcal{E}_t, \mathcal{B}_t)$ 为驱动的 Agent 循环—— $\mathcal{H}_t$ 为假设集、 $\mathcal{E}_t$ 为已收集的证据集、 $\mathcal{B}_t$ 为信念更新。每步由 LLM 输出一个动作（query / expand / prune / confirm / terminate），循环引擎据此调度工具调用并更新信念状态，直至输出 terminate 或达到步数上界。循环引擎维护会话历史，确保后续步骤可引用已获取的证据，避免重复工具调用。当模型输出不符合预期格式时，循环引擎触发最多两次重试，若仍失败则将对路径标记为 Insufficient Evidence 并记录异常原因，保证整个流程不会因单条路径的解析失败而中断。

推理延迟优化。除 vLLM 的并发推理外，模块还实施了两项额外优化措施。一是请求批处理：将同一任务内的多条候选路径按最大 token 数合并为批次请求，减少请求启动开销。二是提前终止：当 Agent 输出 prune 动作或 Gate 函数确认路径不满足硬约束时，立即终止该路径的后续 LLM 调用，无需继续后续推理步骤，从而节省约 20%—30% 的平均推理算力消耗。

接口定义。LLM 调度模块通过内部消息队列与 EIC 判定模块通信，不直接暴露外部 REST 接口；模块状态及推理进度可通过 GET /llm/status 查询。

7.4 系统界面与交互

系统提供基于 Web 的交互界面，覆盖安全分析人员从“发现风险”到“决策处置”的完整 workflows。界面分为四个核心视图，彼此之间通过统一的路径 ID 实现联动。

风险图全景视图以 ECharts 力导向图渲染 CDB-RG，节点颜色编码资源类型（数据库实例、网络节点、身份主体、数据资产分别以不同色系区分），边的粗细编码对应边上累积的证据强度。分析人员可通过鼠标悬停查看节点属性，或通过侧边栏筛选器按节点类型、风险等级对图进行过滤，以快速定位高风险区域。

路径列表视图按 Risk(P) 降序排列候选路径，每行显示路径的起止节点、跳数、三分类标签及综合风险评分，支持按场景类别和证据状态进行二级排序。分析人员点击任意路径后，右侧联动展示对应的证据面板。

证据面板以结构化表格形式展示五个证据维度的评估结果，包括每维度的 ε_d 值、参考的原始证据来源（配置文件路径、日志片段或 IAM 策略摘录），以及 Gate 与 Score 的计算过程。这种设计使分析人员在接受或质疑系统结论时，均有原始证据可供核查，满足安全合规场景对可审计性的要求。

处置建议面板基于路径根因维度自动生成可执行的修复建议，包括具体的配置变更操作（如安全组规则收紧的参数值、IAM 策略的精确修改内容）及预期的风险降低幅度。建议以优先级排序呈现，便于资源有限时优先处理高影响项。

7.5 系统运行验证

为验证系统的端到端工程可行性，本节选取三个具有代表性的典型场景，分别对应 S1、S2、S6 场景类别，覆盖“观测到风险—潜在暴露—证据不足拒答”三种典型路径分类输出。

7.5.1 案例一：公网暴露路径 (S1 → Observed Risk)

本案例输入一个含公网暴露 MySQL 实例的环境快照，安全组 sg-mysql-pub 配置允许 0.0.0.0/0:3306 入站规则，且审计日志中存在来自外部 IP 的异常登录记录。

系统运行全流程遵循“初始信号 → 假设生成 → 主动调查循环 → 确认/剪枝 → 输出”的循环模式：初始信号——图构建模块解析快照时识别出安全组的入站规则，建模为 (InternetNode) --[EXPOSED_BY]--> (DBInstance) 边，附加 cidr=0.0.0.0/0 属性；假设生成——Agent 基于该信号生成“公网直达数据库敏感字段”的暴露假设；主动调查循环——通过约束搜索发现完整路径 Internet → SG → DBInstance → Table(customer_kyc) → Field(id_card) [L4]，满足入口可达性与目标敏感性的双重约束，并调用多维证据工具逐一评估，其中 $\varepsilon_{\text{audit}}$ 在审计日志中检索到来自异常 IP 的登录事件，跨越阈值 $\tau_{\text{audit}} = 0.5$ ；确认——Gate 函数确认多维证据全部满足（无剪枝），输出 Observed Risk 分类， $\text{Risk}(P) = 0.91$ 。处置建议模块根据根因（安全组过宽 + 数据未加密）生成两项操作：将安全组规则收紧为指定企业网段、对 customer_kyc 表启用静态加密。

7.5.2 案例二：权限过宽路径 (S2 → Potential Exposure)

本案例输入一个含 IAM 通配策略的环境快照，策略 policy-dev-readonly-v3 包含 *.* 通配符授权，涵盖所有表的读权限。

系统运行全流程遵循“初始信号 → 假设生成 → 主动调查循环 → 确认/剪枝 → 输出”的循环模式：初始信号——图构建模块识别通配策略，建模为高覆盖度的 (IAMRole) --[GRANTS]--> (Table) 边集合；假设生成——Agent 基于宽泛授权信号生成“实习生身份可达敏感薪资表”的暴露假设；主动调查循环——通过约束搜索发现路径 intern@corp → role-dev → Table(hr.employee) → Field(salary) [L3]，并调用多维证据工具评估， $\varepsilon_{\text{perm}}$ 评估通配策略的覆盖范围确认权限可达，但 $\varepsilon_{\text{audit}}$ 检索 30 天内无对 hr.employee 的实际访问记录，未达阈值；确认/剪枝——Gate 函数因 $\varepsilon_{\text{audit}} < \tau_{\text{audit}}$ 判定为潜在暴露而非已观测，输出 Potential Exposure, $\text{Risk}(P) = 0.58$ 。处置建议为：将通配策略收紧至显式 dev.* 范围，并在 hr.* 命名空间上增加显式 deny 规则。

7.5.3 案例三：证据不足拒答 (S6 → Insufficient Evidence)

本案例输入一个敏感等级标注缺失且审计日志未启用的环境快照，代表实际运营中数据治理不完善的典型情形。

系统运行全流程遵循“初始信号 → 假设生成 → 主动调查循环 → 确认/剪枝 → 输出”的循环模式：初始信号——图构建与约束搜索均正常完成，发现若干候选路径；假设生成——Agent 对每条候选路径生成证据待验证假设；主动调查循环——调用多维证据工具逐一调查，由于数据表的敏感等级属性未填充， $\varepsilon_{\text{sense}} < \tau_{\text{sense}}$ ，且审计日志未启用导致 $\varepsilon_{\text{audit}}$ 不可获取；确认/剪枝——Gate 函数因关键证据缺失短路为 0，系统输出 Insufficient Evidence 分类，拒绝对该路径给出风险判断，并在处置建议中明确指出：需先补全相关表的敏感等级标签并启用审计日志，之后

方可进行有效的暴露路径评估。此案例验证了系统在证据不完备情形下不输出虚假结论的重要能力。

7.5.4 运行效率

三个案例的端到端运行耗时如表 6.1 所示。

表 6.1 三个案例的端到端运行耗时（单位：秒）

阶段	案例一	案例二	案例三
图构建耗时	2.1	1.8	1.5
路径搜索耗时	0.8	0.6	0.5
LLM 推理耗时	12.3	9.7	7.2
端到端总耗时	15.2	12.1	9.2

三个案例的端到端分析时间均在 30 秒以内，满足 6.1.2 节所设定的非功能需求。案例三耗时最短，原因在于证据不足时 Gate 函数提前短路，有效减少了 LLM 的推理调用量。LLM 推理是端到端耗时的主要来源，占比约 78%—80%，进一步优化 vLLM 的批处理参数或采用投机解码策略具有较大的提升空间。

7.6 本章小结

本章围绕 CloudDB-PathDetect 原型系统的设计与实现展开了系统性的阐述。在架构层面，系统采用五层分层设计，以关注点分离、确定性优先与故障隔离为核心原则，确保各层职责清晰、接口稳定；存储层的异构分类策略（Neo4j + PostgreSQL + MinIO）与推理层的确定性/LLM 混合实现共同支撑了系统的可扩展性与可审计性。在工程实现层面，本章重点解析了图构建模块的增量更新机制与大图索引优化、约束搜索模块的三层剪枝策略、EIC 判定模块的并发批处理设计，以及 LLM 调度模块的 vLLM 服务化部署与推理延迟控制措施。通过三个典型案例的端到端演示，系统在公网暴露路径识别、权限过宽路径检测与证据不足正确拒答三类场景下均表现正确，端到端分析时间均在 30 秒以内，验证了所提方法在工程层面的可行性与实用性。

8 总结与展望

8.1 研究工作总结

本研究围绕“面向云数据库高敏数据暴露路径侦测”这一具有重要现实意义的安全运营任务，系统性地提出“基准—方法—对齐—系统”四位一体的解决方案。四项贡献之间具有内在递进关系：CloudDB-PathBench 为方法评估提供受控环境，

EIC-Agent 在基准上实现高质量的路径判定，GV-FA 对齐方法使小规模模型具备接近大模型的推理质量，CloudDB-PathDetect 原型系统则将上述方法组合为可实际部署的工程实体。

在评测基准层面，本研究构建了面向 Toxic Combination 路径可控生成与量化评估的云数据安全基准 CloudDB-PathBench。基准采用“真实配置种子驱动的参数化合成”四层数据构建管线，以 CDB-RG 统一风险图为骨干，覆盖 6 类场景、4 种正交切分、21 项评价指标。质量验证实验表明，基准场景分布均衡、路径多样性完备，标注一致性 $\kappa = 0.85$ ，四种正交切分构成递进难度梯度，为后续方法的可信比较提供了坚实的实验基础。

在核心方法层面，本研究提出了 EIC-Agent 证据约束智能体方法，其核心思想是“让 LLM 从路径判定者降格为证据调查者与表达者”：通过 $\text{Gate} \cdot \text{Score}$ 双层验证算子 $\text{EIC}(P) = \text{Gate}(P) \cdot \text{Score}(P)$ 将强判定逻辑从 LLM 内部转移到外部确定性计算中，使 LLM 的作用收窄至证据的语义抽取与置信度估计。实验结果表明，相较无约束 ReAct 基线，EIC-Agent 将 Invalid Path Rate 从 0.193 降至 0.058（降幅约 70%），Hallucination Rate 从 0.160 降至 0.062（降幅约 61%）；消融实验进一步证明各证据组件的贡献显著且互补，验证了约束架构设计的合理性。

在对齐方法层面，本研究提出了 GV-FA 图验证反馈对齐方法，引入可迁移的确定性反馈范式，以图验证奖励函数替代人工标注偏好信号，配套 VANS 负样本合成方法，构建 SFT+DPO 两阶段对齐流程。训练消融实验表明，SFT 阶段主要解决输出格式合规问题，DPO 阶段精炼排序一致性与硬约束边界判断；叠加两阶段对齐后，NDCG@3 从 0.41 提升至 0.80，EIC Pass Rate 达 0.81，使 8B 量级小模型在暴露路径侦测任务上达到接近大模型的推理质量。OOD 泛化实验进一步验证了方法在 Schema 漂移、组合涌现、证据腐蚀三类分布外场景下的鲁棒性。

在原型系统层面，CloudDB-PathDetect 将上述方法集成为五层分层架构的端到端系统，以三个典型案例验证了系统在公网暴露路径识别、权限过宽路径检测与证据不足拒答三类场景下的工程可行性，端到端分析时间均在 30 秒以内。

8.2 研究局限性

本研究在取得上述成果的同时，存在若干值得正视的局限性。

首先，合成数据与真实环境之间存在一定差距。当前基准以合成快照为主，虽以真实靶场配置为种子驱动参数化生成，但真实生产环境中常见的长尾配置——如跨租户共享策略、历史遗留的手工配置等——在现有基准中覆盖仍不充分。这一差距可能导致模型在实际部署时面临训练分布之外的边缘案例，需要进一步的适配工作。

其次，场景覆盖范围有限。当前 6 类场景涵盖了约 70% 的高频攻击模式，但供应链投毒（恶意镜像植入数据库连接配置）、容器逃逸至数据库等新兴攻击面尚未纳入建模体系。随着云原生架构的演进，这些新兴场景的威胁权重将持续上升，

需要在后续工作中补充相应的节点类型、边类型与场景模板。

再者，小模型的能力上限制约了部分复杂场景的推理质量。本研究以 8B 量级模型为基座，在长上下文多跳推理（跨度超过 6 跳的路径）与语义高度模糊的策略描述解析场景中，与百亿参数以上的闭源大模型仍存在可观的性能差距。这一局限在很大程度上是现阶段小模型能力边界的客观反映，而非方法设计的固有缺陷。

此外，评估基准的闭环性问题亦不容忽视。训练数据与评测数据均源于同一构建管线，尽管通过正交切分策略降低了数据泄漏的风险，但仍不能完全等同于由独立第三方构建的评测集。在实际部署前，引入独立标注团队对评测集进行人工核验是进一步提升结论可信度的必要步骤。

最后，处置建议与修复闭环之间存在断层。系统目前能够生成可操作的修复建议，但建议执行后风险是否真正消除，需要通过与工单系统或 SOAR 平台的对接以及执行后的重验证来确认，这一闭环在当前原型系统中尚未实现。

8.3 未来工作展望

基于上述局限性的深入分析，本研究将沿以下方向推进后续工作，每个方向均针对现有局限性的核心症结展开。

真实脱敏数据接入与领域适配是最具近期可行性的方向。现阶段基准与真实环境的差距本质上是领域漂移问题。解决思路是引入经严格脱敏处理的真实快照与审计日志，采用“基底冻结—风格层适配”的两阶段微调策略：第一阶段保持 GV-FA 对齐后的模型权重不动，仅在真实数据上对 LoRA 的风格适配层进行轻量微调，使模型熟悉生产环境的配置惯例；第二阶段在混合数据集上进行联合训练，以防止领域适配导致的合成数据分布上的灾难性遗忘。此外，还需建立与真实环境的联合测试流程，定期将线上发现的新配置模式回流至基准更新管线。

多云与混合云图谱的统一建模是提升系统适用范围的关键方向。当前 CDB-RG 以 AWS 的资源模型为主要参考，对 Azure、阿里云、腾讯云等云平台的覆盖尚不完整。后续工作的重点是抽象出跨云的公共节点/边类型体系，将云厂商特定的资源类型作为公共类型的子类纳入，从而以“新增云厂商适配器”而非“重新设计图模型”的方式支持多云扩展。这一扩展同时需要考虑混合云场景下的跨云路径建模问题，即攻击者可能利用云间互联通道将一朵云的入口凭证转化为另一朵云数据库的访问权限。

在线反馈学习是将原型系统向生产级演进的核心路径。当前系统产生的路径判定结论需要安全分析人员进行人工审核，其接受、驳回与修改行为蕴含了丰富的偏好信号。后续工作将设计在线偏好对采集机制，将分析师行为实时转化为 DPO 训练样本，以小批量增量训练的方式持续更新模型，实现在生产环境中的持续对齐。这一方向的关键技术挑战在于如何防止在线学习引入偏见漂移，需要配合置信度校准与异常偏好过滤机制共同运作。

自动处置闭环的构建将显著提升系统的实用价值。将 EIC-Agent 的输出与

ITSM（如 ServiceNow、Jira）和 SOAR（如 Palo Alto XSOAR、Splunk SOAR）平台对接，实现”路径发现 → 建议生成 → 工单创建 → 修复执行 → 重验证 → 闭环确认”的全自动流程。其中，重验证环节尤为关键：修复操作完成后，系统应自动触发针对原始暴露路径的重新评估，以确认风险是否真正消除，而非依赖人工的事后判断。这一闭环设计还需考虑修复操作可能引入新风险的情形，即在重验证阶段同时对修复前后的风险图变化进行差异分析。

多智能体协作架构代表了方法演进的重要方向。当前 EIC-Agent 采用单一智能体架构，将取证、推理、处置建议和结论解释集于一身，这在复杂场景下可能导致单次 LLM 上下文过长、角色边界模糊等问题。后续研究计划将系统扩展为由取证智能体、推理智能体、处置智能体和审计智能体构成的四角色多智能体框架：取证智能体专注工具调用与证据收集，推理智能体专注路径评估与风险判定，处置智能体专注建议生成，审计智能体则对其他智能体的输出进行交叉核验。四者通过结构化消息协议交互，互检机制有望进一步降低系统整体的幻觉率和错误率。

与主流安全运营生态的深度集成是系统走向实用化的必要条件。后续工作将开发与 Splunk、ELK 等主流 SIEM 平台以及 Wiz、Orca、Prisma Cloud 等 CSPM 产品的标准化连接器，使 CloudDB-PathDetect 的输出能够以 OCSF 或 STIX 2.1 格式接入现有的告警工作流和事件响应流程。标准化输出格式不仅降低了系统集成的工程成本，也有助于将暴露路径侦测的能力以插件化方式嵌入企业已有的安全运营体系，而非要求用户切换至全新的工具链。